安全课程：www.fcmit.cc

SRC 入门及构建渗透测试框架

如何入门 SRC

企业 SRC 是什么

SRC（ Security Response Center）安全应急响应中心，是企业用于对外接收来自用户/白帽发现并报告相关安全产品安全缺陷的站点，白帽用自己的技术合法的向企业提交漏洞，企业给予相应的赏金。

为什么要挖掘企业 SRC

为什么要挖掘企业 SRC

1、最简单的想法 就是搞钱 成为副业

日常挖掘赏金 单洞 几十到几 w 不等

对应税后现金奖励如下：积分与人民币兑换比例为 1:30

	严重	高危	中危	低危
核心系统	6000-4500	3300-1800	600-300	90-30
一般系统	3900-2400	1500-900	420-180	60-30
边缘系统	**450-720**	**210-360**	90-30	0

贡献值对应表

漏洞等级	严重漏洞	高危漏洞	中危漏洞	低危漏洞
贡献值	500	200	/	/
安全币	10000	4000	/	/
奖金	100000	40000	/	/

2、工作 挖掘企业 SRC 是简历的亮点

许多安全公司会比较看重（是哪些面试官【白嫖你思路借着面试的机会】或者 HR 会更加感兴趣【写简历 某某 SRC 年榜第一 挖掘到 5w 累计挖掘 10w 以上】）

简历上 不可替代的一块

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

渗透工程师或者安全服务工程师或者安全运营工程师　在挖掘企业 SRC 的过程中 会不断磨练个人的实力

涨薪+就业　不可替代的一个点

个人而言 多次的面试机会 TC 都是因为企业 SRC 成绩（多个学员因为挖掘 SRC 找到工作【】）

学生反馈：



A2Cai 独立研究的一种漏洞　助力学员挖掘到年榜前 15 并找到工作

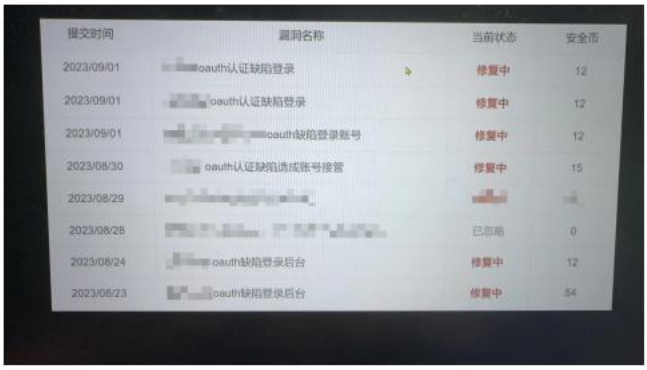
安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

11-08 20:36:02

除了你

11-08 20:37:22



11-08 20:37:34

麻了 真的 你是我的神

11-08 20:38:02

[动画表情]

11-08 20:38:16

[动画表情]

11-08 20:38:22

怪不得一种类型的洞给你挖到年榜总榜前15

如何挖掘企业 SRC（持续持续持续）

信息收集+技术+持续学习+持续挖掘

其中信息收集 个人而言是占据 60%　技术手法占据 40%

每个人的技术手法 差距不大

交了这么多洞 同时和其它大佬交流，发现每个人手法差距并不大，可能就是 20~30%的差距，当然也是这 20~30% 拉开了你我【手法】

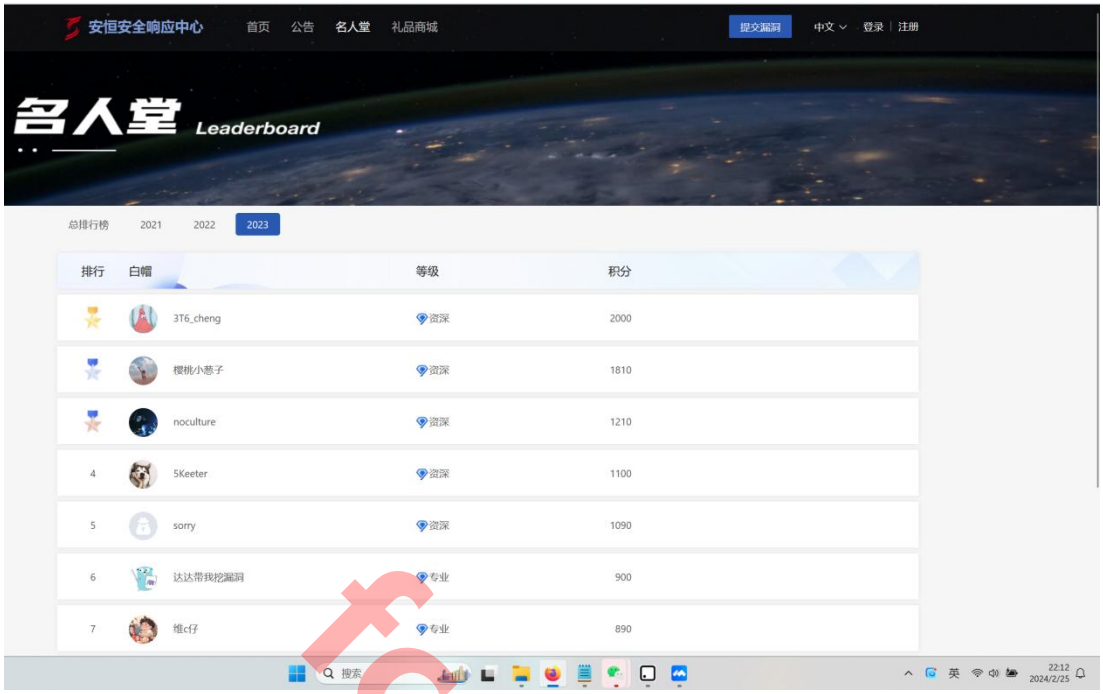
为什么信息收集这么重要？【信息收集】

fcmit.cc

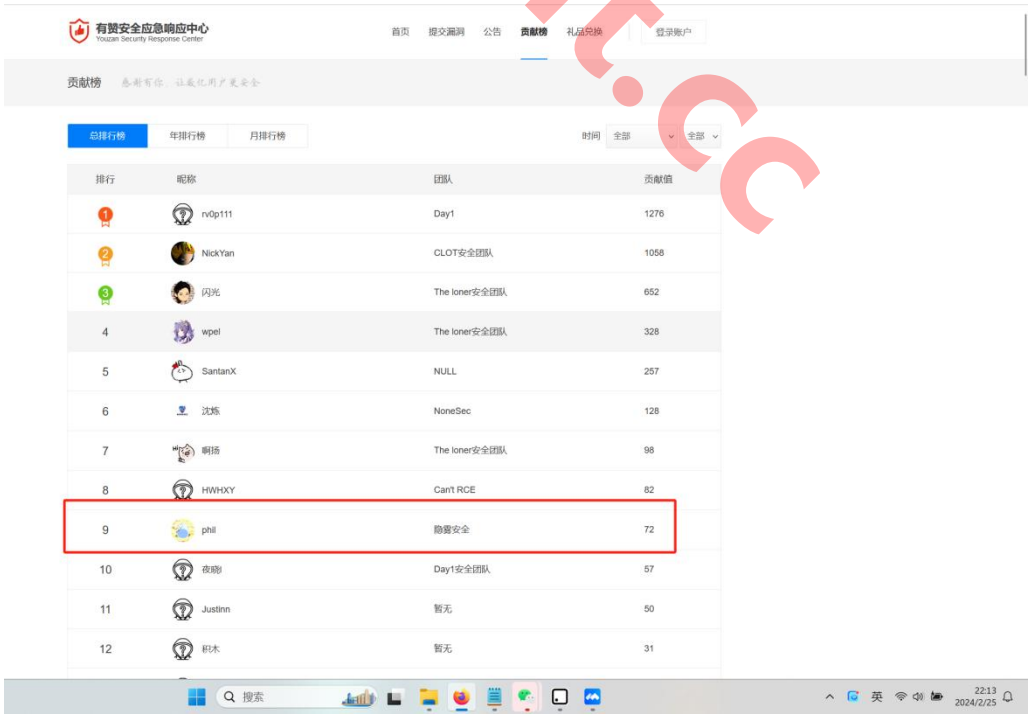
安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

从个人而来，安恒信息 SRC 年榜第一，就是信息收集给我带来的

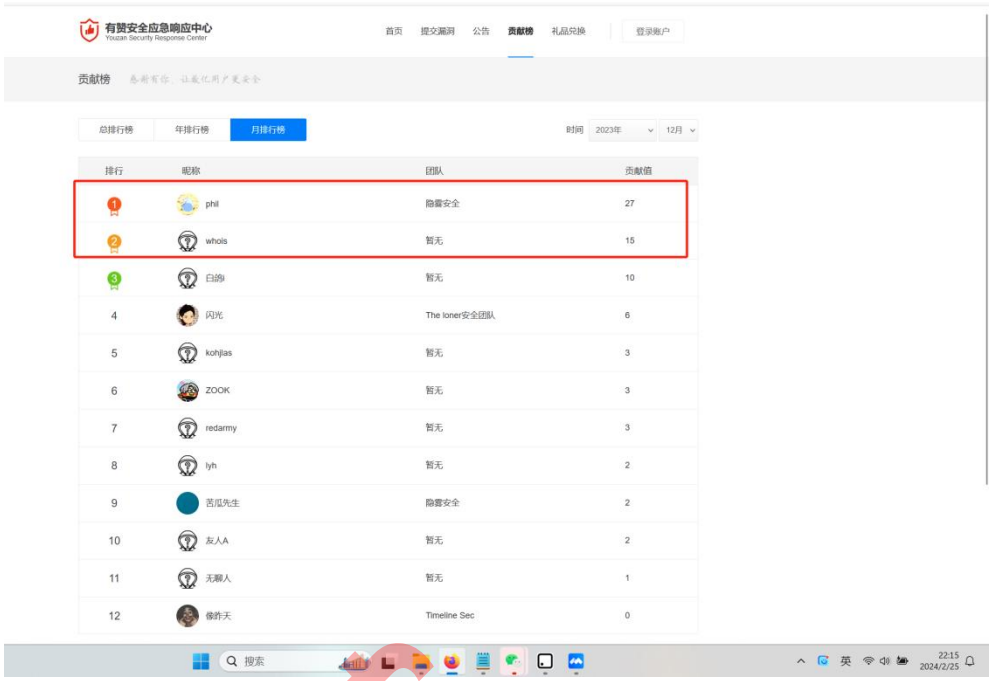


学员角度，二期课程分享某 SRC 的独特信息收集角度，助力学员实现三连月榜一且总榜前十、年榜前十



安全课程：www.fcmit.cc

安全课程：www.fcmit.cc



其次 单纯的信息收集也能捡洞 给钱 无需任何技术



个人挖掘企业 SRC 之路

自己定下的目标：教育 SRC（搞到 2 本证书以上）—>CNVD（原创证书）—>企业 SRC（5k）—>众测（企业+银行）

最后的实现：教育 SRC（3 本证书）—>企业 SRC（安恒年榜第一、其它 SRC 年榜前十若干）—>众测（雷神、漏洞盒子）-->私人项目（60w）

CNVD：在变强中挖掘，说不定日常挖掘过程中就出现了（不太建议 ）（有些企业 SRC 外包第三方的系统 ）

企业 SRC 挖掘之路（www.baidu.com，baidu.com 是百度的）

①实现人生第一个洞（CNVD 或者漏洞盒子、补天或 EDU）

②实现 EDU

③企业 SRC（大型 SRC 挖边缘性的资产，写好信息收集，不可能不返现）

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

④众测【公益性众测（360 的漏洞云）、难度中单（漏洞盒子）难度比较高的（雷神、360、补天）
⑤内部项目【简单+难】
最开始 啥都不懂 但是通过信息收集 0 技术挖到两个洞
第一个：黑站挂链（enscan 扫公司的图谱 公众号信息收集）90 块
第二个：身份证敏感信息泄露（enscan 扫公司的图谱 公众号信息收集） 30 块(EDU)

	积分流水
泄露]类型[顺[redacted]存在敏感信息泄露]的...	+1
]类型[e[redacted]存在黑站挂站]...	+3

SRC 报告编写

如何写报告-语言艺术

报告的编写————————-一般形式

漏洞名称，漏洞标题

漏洞域名 —方便审核固定资产 评判资产是否正确（域名查备案、其次审核手里一定是有一份域名的）(尽量填 SRC 认可的域名)

漏洞 URL —方便审核固定漏洞危害路径 方便复现 方便记录漏洞 有些重复也方便修复漏洞

漏洞类型 —方便归纳漏洞 方便修复 APP\WEB\二进制\车联网 业务逻辑缺陷 未授权访问

漏洞危害 方便审核评定漏洞等级 也方便厂商或业务商承认漏洞

漏洞描述（漏洞复现） 方便审核评定漏洞等级

漏洞复现/测试过程

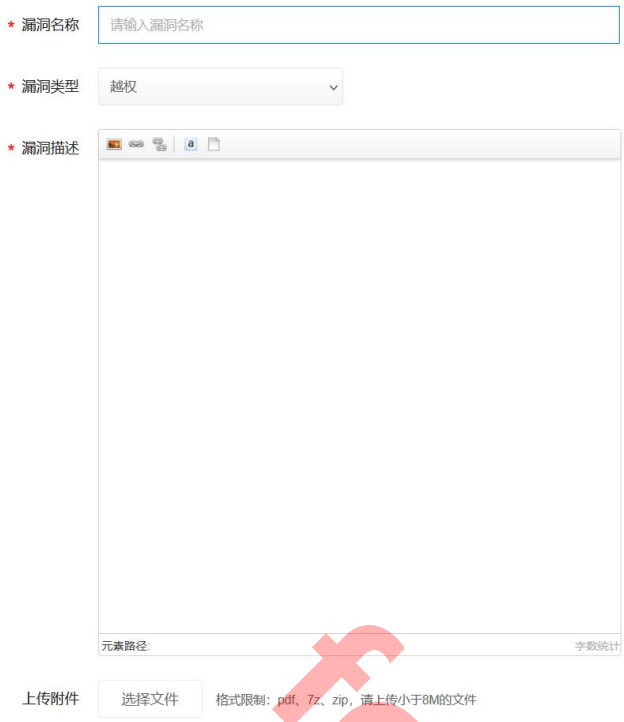
修复建议 如何去修复

很多企业 SRC 会选择这一款 开源提交漏洞的平台

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc



在上述中最为重要的是哪几块

漏洞名称，漏洞标题

漏洞危害（具体指的是漏洞导致的不好的结果）

漏洞描述

接下来详细讲解如何对以上几块进行语言的加工

漏洞名称，漏洞标题

其实交报告也和写作文一样　万事开头难

漏洞名称：xx 公司 xx 系统存在 xx 漏洞导致 xxx 危害（三要素　资产　漏洞　危害）

比如：小强公司 A 系统存在敏感信息泄露漏洞导致 20001 条敏感信息泄露（手机号码、用户名等，用户名可成为非法份子爆破账号的来源）

挖到了敏感信息泄露，一定要注明有多少条数据

比如：小强公司 A 系统存在 SQL 注入漏洞导致获取服务器权限

若存在多个漏洞　同一漏洞原理　同一个系统　但是不同注入点（SQL 注入、越权、XSS）

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

比如：小强公司 A 系统存在 SQL 注入漏洞（注入点参数为 userid）导致获取服务器权限

漏洞危害（为什么有些同学一定要去站在审核角度的出发，觉得这个不是漏洞）

漏洞危害一定不要自己想着不是危害 不要去站在审核角度去考虑问题

而是站在如何给自己获取利益的角度出发

如果连自己都战胜不了，自然是不可能战胜审核的

如何写漏洞危害，建议分以下几步描写

1、什么地方导致漏洞的产生【某某功能点】

2、什么原因导致漏洞的产生【漏洞原因】

3、漏洞的危害，能导致什么样的结果

举例：A 小程序内置跑步小游戏，在跑步排行榜的返回包存在敏感信息泄露，遍历 id 参数导致泄露 20001 条敏感信息，敏感信息包括用户的手机号码、用户名、住宅地址等，用户的敏感信息泄露会对公司及用户本人带来一定的影响，如用户的安全遭到威胁，被不法分子售卖给敌对公司，可能会影响公司业务。

补充：在写漏洞的危害的时候，需要从以下几个方面去考虑：

1、对用户的影响

2、对公司的影响

而公司的影响也可分为大小，如在职员工、公司整体

举例：

简历多次投递 业务场景：单个职位只允许投递一次 怎么写漏洞危害？1、并发导致 2、替换数据包

简历正常情况只能投递一次，（从个人及他人出发）多次投递，被录取的概率越大，如这次投递失败，下次成长后修改简历再次投递，对他人不公平;（对公司的影响）影响 HR 工作，增加压力;（业务场景出发）总投递数，一般会有一定的收录范围，如只允许投递 100 次。

漏洞描述（详细过程）（猪肚）【业务逻辑 危害比较大的漏洞 是需要去写好的】（如何复现）

1、资产证明

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

2、测试过程

一般个人，第一个会写资产证明

资产证明：icp 备案查询、企业 SRC 通告、微信小程序所属企业、资产表格明细

icp 备案查询：

https://beian.miit.gov.cn/



www.baidu.com　baidu.com

企业 SRC 通告：



	A	B	C
1	业务	入口	备注
2	微商城PC、H5、小程序及APP	www.youzan.com	可免费试用
3	连锁PC、H5、小程序及APP	www.youzan.com	可免费试用
4	教育PC、H5、小程序及APP	www.youzan.com	可免费试用
5	美业PC、H5、小程序及APP	www.youzan.com	可免费试用
6	有赞客PC、APP	youzanke.youzan.com	可免费试用
7	应用中心	www.youzan.com/v4/apps/new-app-center	属于youzan.com且非isv的营销插件都收
8	企微助手	qiwei.youzan.com	可免费试用
9	供货商后台	fx.youzan.com/v4/dashboard	
10	分佣推广后台	fenyong.youzan.com/dashboard	
11	有赞SCRM	crm.youzan.com/crm/dashboard	
12	有赞客服	b-im.youzan.com	
13	应用市场	app.youzanyun.com	
14	AllValue	admin.allvalue.com.cn	可免费试用
15	爱逛后台	guang.com	可免费试用
16	服务市场	fuwu.youzan.com	
17	有赞云	diy.youzanyun.com	
18	爱逛APP、小程序		
19	爱逛卖家版APP		
20	爱逛买手店APP		
21	有赞精选APP、小程序		
22	微小店APP		
23	群团团小程序		
24	旺小店小程序、APP		
25			
26			

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

微信小程序所属企业：



从第二点开始写测试过程

2、

3、

4、

等等，但是这一过程中，你写的漏洞危害一定是要贯穿在其中的

举例：

漏洞标题的魅力：

低危：A 系统存在敏感信息泄露漏洞

中危：A 系统存在敏感信息泄露漏洞（5000 条）

高危：小强公司 A 系统存在敏感信息泄露漏洞导致 20001 条敏感信息泄露（手机号码、用户名等）

哪些漏洞是需要精写的：

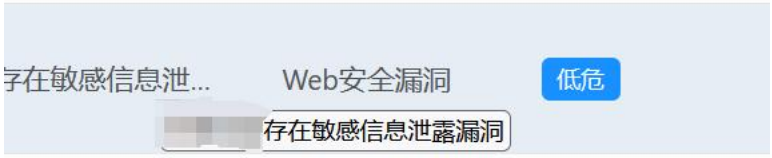
1、危害比较大 的　高危 严重

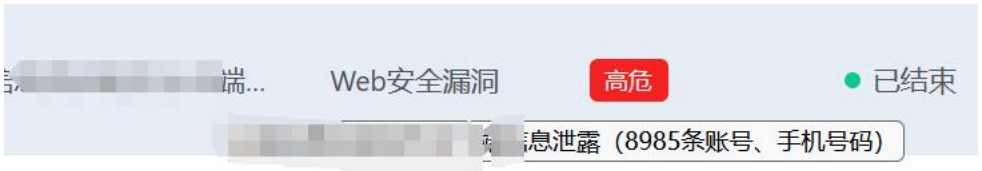
2、从漏洞类型：信息泄露、未授权访问、越权、业务逻辑

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc





漏洞描述的魅力

最高赏金为 200 金币 也就是 2k

二、业务漏洞评分标准

业务漏洞指的是安恒信息所有在线业务的漏洞。根据漏洞的危害程度，外部业务系统漏洞等级分为【严重】、【高】、【中】、【低】四个等级。

【严重】150-200金币

危害程度非常严重，可直接通过互联网进入安恒信息内网的安全漏洞。

1)系统权限：指获得包含但不仅限于ssh、webshell、shell、3389、远程桌面控制权限、rce等的漏洞，成功进入安恒信息内网的安全漏洞与过程。

2)内网穿透：指通过互联网可进入内网（除物理接入与SSRF外），访问内部网络系统，并可以执行任意操作的漏洞与过程，包含通过VPN弱口令进入内部网络，获得目标内网跳板等。

【高危】50-100金币

危害程度比较严重，可直接获得系统权限、云系统（部署在阿里云、腾讯云、华为云等）系统权限、业务管理员权限、重要的信息泄露，任意文件操作等。

1)系统权限：指获得包含但不仅限于ssh、webshell、shell、3389、远程桌面控制权限、rce等的漏洞或过程，且能有效利用。包含但不仅限于可利用的ActiveX堆栈溢出、可利用的浏览器use after free、可利用的远程缓冲区溢出。

2)核心业务信息：指获得大量用户敏感信息的控制权，如获得下载、修改与删除权限等；包含SQL注入可获得完整数据库（只允许读取到数据库名、用户名字段）。

3)系统敏感信息：指大量系统敏感信息泄露的漏洞与过程。系统敏感信息包含但不仅限于由服务器泄露的核心源代码。

4)重大经济损失：指获得包含但不仅限于造成大量金钱（或金钱等价物有套现渠道，如可兑换话费的积分，可兑换充值卡的积分等）损失的操作过程，与金钱相关的逻辑漏洞，如恶意消费漏洞、盗刷、资金窃取等。

5)业务权限：获得业务系统管理员权限，包含但不仅限于：管理员弱口令（非测试站点，需包含真实业务数据）。

6)任意文件操作：包含但不仅限于任意文件下载、删除。

直接突破上限

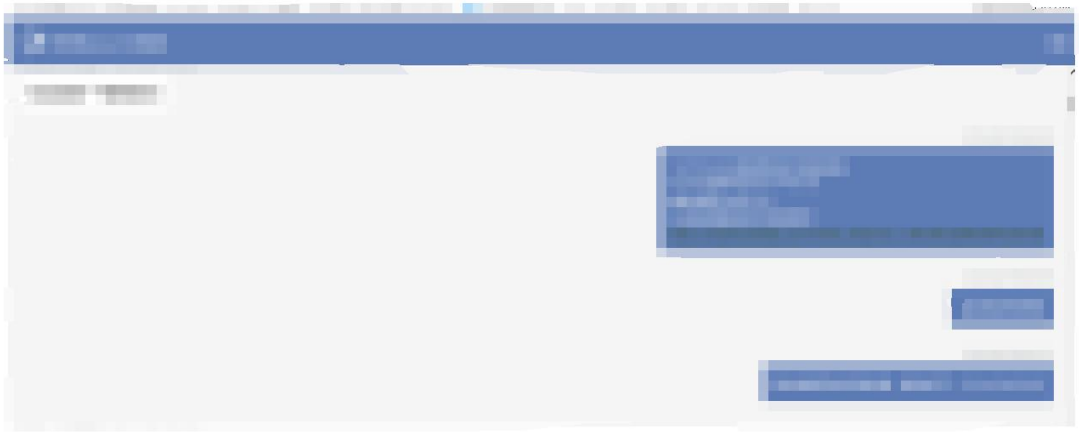
获得积分	获得金币
100	300

一些描述

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

6、这放在攻防绝对是绝杀：



真的值严重，这应该是产品的通杀了，谢谢审核，再给你看一个图



打电话，钓鱼，精准投喂

漏洞盒子平台-SRC 报告编写

公益型漏洞提交-如何在漏洞盒子平台上提交报告

漏洞盒子平台介绍

漏洞盒子是由上海斗象信息科技有限公司打造的中国领先的漏洞平台与白帽社区，也是安全众测与安全运营服务平台

漏洞盒子平台介绍

https://www.vulbox.com/

fcmit.cc

安全课程：www.fcmit.cc

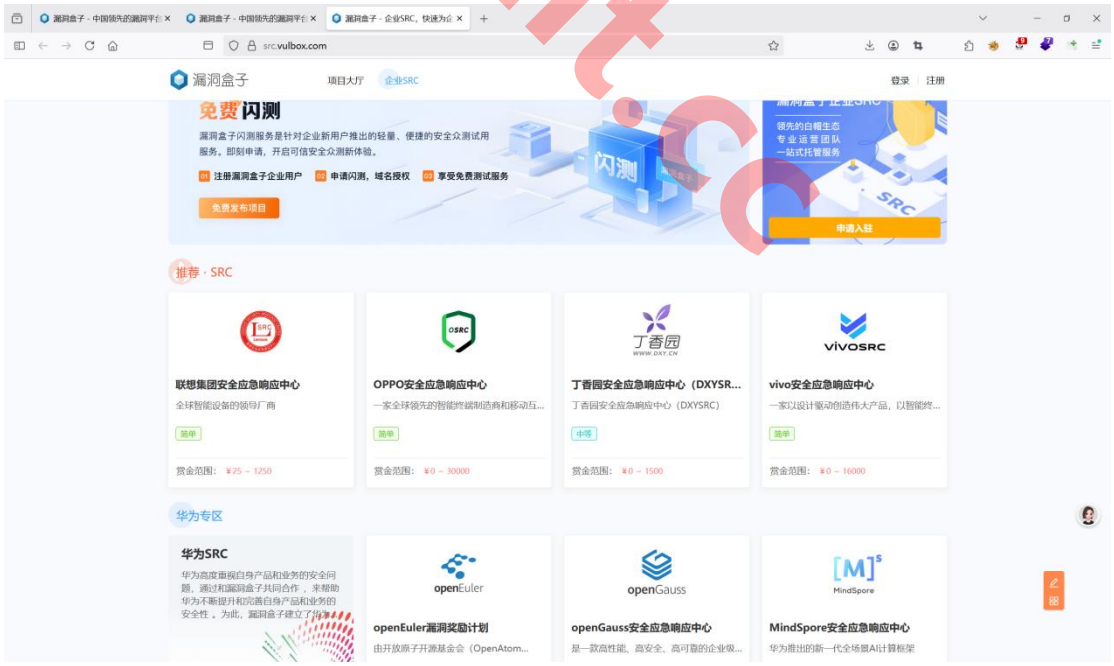
安全课程：www.fcmit.cc



公益型漏洞，漏洞盒子基本上都会收录

收录对象

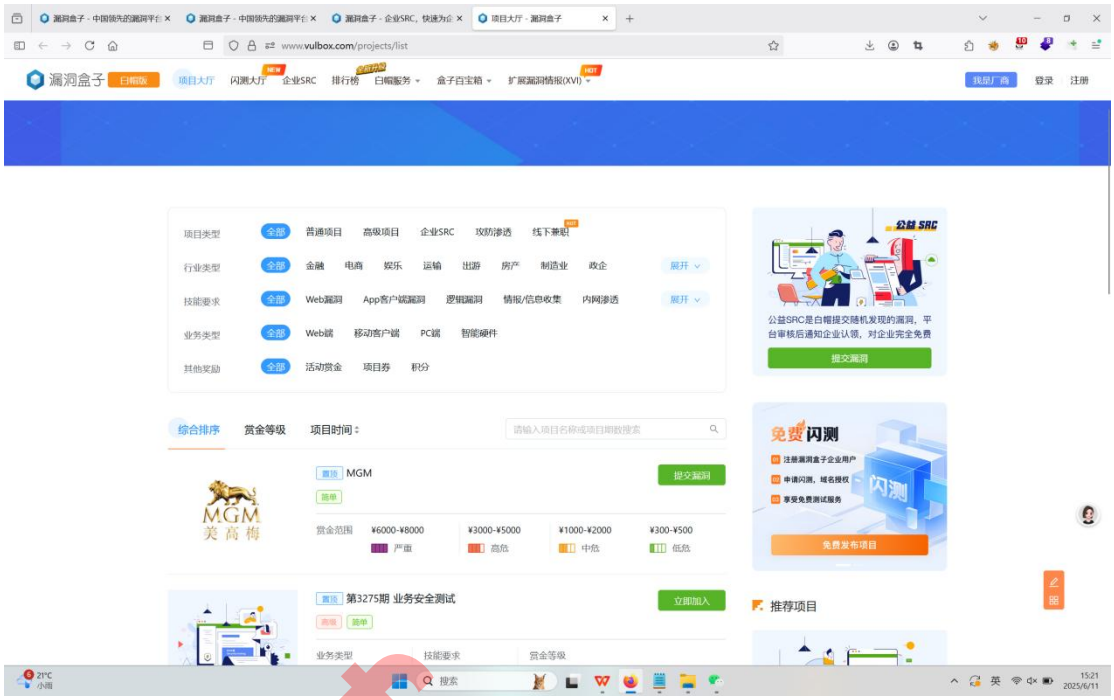
企业 SRC，与漏洞盒子平台有合作的 SRC（https://src.vulbox.com/）

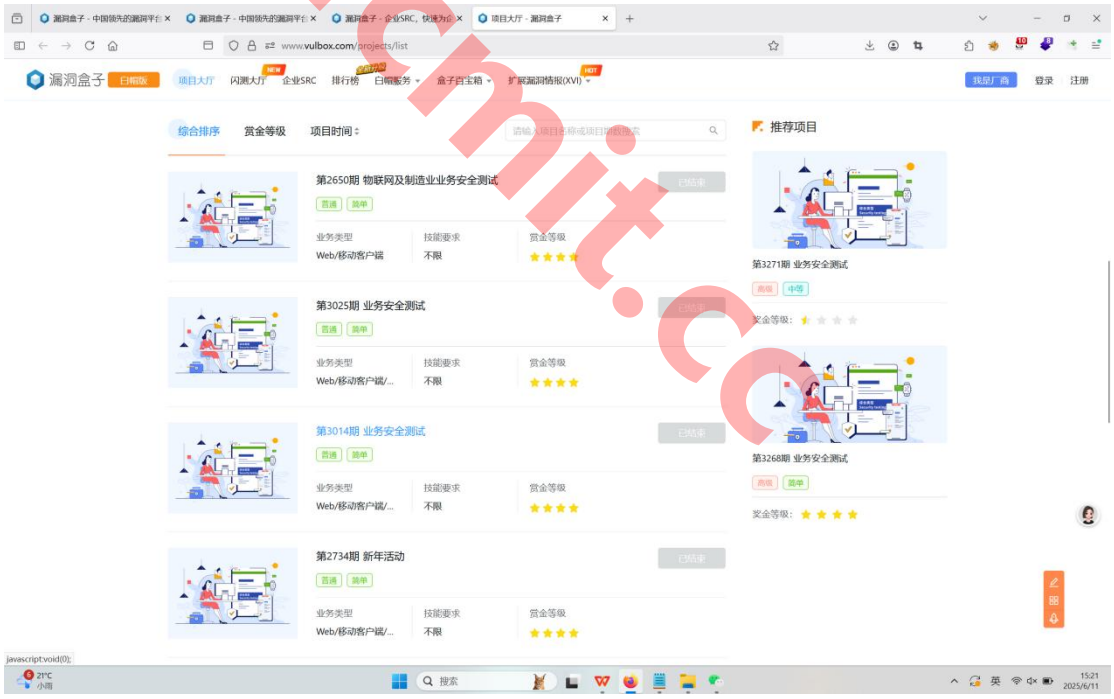


众测项目,部分单位会通过漏洞盒子平台上线项目，企业、事业单位、国企、GOV等

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc





公益型漏洞

公益 SRC 是白帽子随机发现的漏洞提交漏洞盒子平台，平台对漏洞审核后通知企业认领。厂商注册公益 SRC 成功后即可认领漏洞，公益 SRC 服务不收取企业任何费用。

提交报告

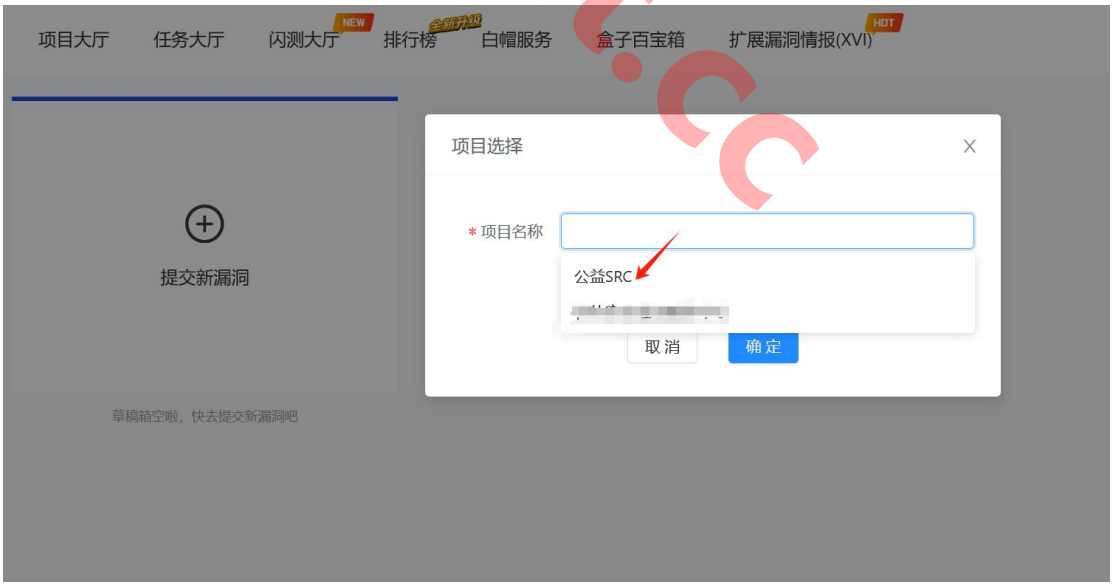
安全课程：www.fcmit.cc

安全课程：www.fcmit.cc





选择项目



若未加入公益 SRC，需先申请加入

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc



提交漏洞框架



fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc



项目名称：选择公益 SRC

漏洞标题：xxxx 公司 xxx 系统 xxx 功能点存在 xx 漏洞导致 xxx 影响

漏洞类型：事件型漏洞/通用型漏洞

事件型漏洞（单次的漏洞）

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

通用型漏洞（指广泛存在于某一类软件、系统或组件中的固有缺陷，影响所有使用该产品的用户或设备。其核心特征是规模化、普适性，而非特定场景或个体问题。）

厂商名称：填写公司全称/单位全称等

厂商域名：xxx.xxx.com（如某系统的系统地址为,xxxx.xxx.xxx.com/login，则其厂商域名为 xxxx.xxx.xxx.com）

漏洞类型：按实际填写，填写错误没关系，后期审核或运营会作纠正

漏洞等级：严重/高危/中危/低危

漏洞简述: xxxx 公司 xxx 系统 xxx 功能点存在 xx 漏洞导致 xxx 影响，此处的影响可扩大描写，通过多方面的角度。比如某商城系统存在支付漏洞，写影响：从消费者角度看，支付漏洞 0 元购，消费者可任意购买商品，将商品清空，对他人购买不利；从卖家看，商品正常发货，但未收到钱，自身利益收到影响；从平台侧公司侧看：对公司及平台信誉造成影响，甚至引起舆论。

复现步骤：

1、资产证明【可通过多途径证明如：ICP 备案官方查询（最权威）/其它】

2、系统入口+地址

3、复现步骤 1

4、复现步骤 2

.....

注意在复现步骤中需时刻提影响

修复建议：依据真实漏洞提交修复建议，填写错误没关系，后期审核或运营会作纠正。

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

360SRC 报告编写

SRC 漏洞提交-如何在 360SRC 平台上提交报告



360 众测报告编写

SRC 漏洞提交-如何在众测平台上提交报告



安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

构建渗透测试框架

漏洞是什么（工作及 SRC 收录逻辑）

工作漏洞收录规则-金融版

漏洞名称	漏洞定级及说明	漏洞描述	漏洞原理	修复建议
启用不安全的 HTTP 方法	高危：PUT、DELETE 方法可利用情况下。 中危：TRACE 方法可利用的情况下（如导致 XSS 漏洞）。 低危：PUT、DELETE 方法不可利用情况下（返回 200 但是没有实际执行）。	目标服务器启用了不安全的传输方法，如 PUT、DELETE、TRACE 等，这些方法表示可能在服务器上使用了 WebDAV，由于 dav 方法允许客户端操纵服务器上的文件，如上传、修改、删除相关文件等危险操作，如果没有合理配置 dav，有可能允许未授权的用户对其进行利用，修改服务器上的文件。	检查原始测试响应的“Allow”头，并验证是否包含下列一个或多个不需要的选项：DELTE，SEARCE，COPY，MOVE，PROPFIND，PROPPATCH，MKCOL，LOCK，UNLOCK，PUT。	1、在不影响业务的前提下，禁用不必要的 HTTP 方法（如 PUT、DELETE）。 2、如果服务器不使用 WebDAV 可直接禁用，或为允许 webdav 的目录配置严格的访问权限，如认证方法，认证需要的用户名，密码。

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

点击劫持	低危	点击劫持是一种视觉上的欺骗手段，攻击者使用一个透明的、不可见的 iframe，覆盖在一个网页上，然后诱使用户在该网页上进行操作，此时用户在不知情的情况下点击了透明的 iframe 页面。通过调整 iframe 页面的位置，可以诱使用户恰好点击在 iframe 页面的一些功能性按钮上，攻击者常常配合社工手段完成攻击。	点击劫持是视觉欺骗，用户只看到了底层页面，与页面进行交互时却是与上层页面在交互。这是由于透明的 iframe 造成的，通过控制 iframe 的位置，导致上层页面的按钮等覆盖到下层上。	X-FRAME-OPTIONS 是微软提出的一个 http 头，专门用来防御利用 iframe 嵌套的点击劫持攻击，并且在 IE8、Firefox3.6、Chrome4 以上的版本均能很好的支持。 这个头有三个值： DENY：拒绝任何域加载 SAMEORIGIN：允许同源域下加载 ALLOW-FROM：可以定义允许 frame 加载的页面地址。
后台页面公网暴露	低危	应用存在未限制公网访问的后台，攻击者可能通过登录网站管理后台篡改页面，或利用上传功能上传 webshell，导致服务器被控制。	后台管理界面（包括不限于：可操作管理多个账户，具有账号权限功能增删改权限的用户界面；可发布公告等内容管理的用户界面；可查询应用日志系统日志账户；可更改应用系统界面内容配置账户；）暴露在互联网上。	建议在不影响业务的前提下，将管理后台隐藏在非常规目录下或增加管理后台的访问限制。

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

CORS 跨域漏洞	低危	跨域资源共享（CORS）是一种浏览器机制，可实现对位于给定域外部的资源的受控访问。它扩展了同源策略（SOP）并增加了灵活性。但是，如果网站的 CORS 策略配置和实施不当，它也可能带来基于跨域的攻击。CORS 并不是针对跨域攻击（例如跨站点请求伪造（CSRF））的保护措施。	浏览器的同源策略约束着不同源的资源交互，但这也带来诸多的不便，例如随着 WEB 应用的发展，有些网站由于自身业务的需求，需要实现一些跨域的功能，让不同域的页面之间能够相互访问各自页面的内容，而浏览器的同源策略会限制这种请求，因此需要采用 CORS 以实现跨域访问，这本身是一种功能。CORS（Cross-Origin Resource Sharing）即跨域资源共享，是用于绕过 SOP（同源策略）来实现跨域资源访问的一种技术，是 HTML5 提供的一种机制。	CORS 漏洞主要是由于配置错误而引起的。所以，预防漏洞变成了一个配置问题。下面介绍了一些针对 CORS 攻击的有效防御措施。
目录穿越	紧急：可直接获取到重要敏感数据（如服务器配置信息、数据库配置信息、密码等） 低危：泄露信息少，利用难度大	目录穿越的目的旨在访问存在在网站根目录外面的文件或目录。通过浏览应用，攻击者可以寻找存储在 Web 服务器上的其他文件的相对路径，从而获取系统配置、数据库账号密码等敏感信息，	同于网站目录浏览，此漏洞不仅仅可遍历系统下 web 中的文件，而且可以浏览或者下载到系统中的文件，攻击人员通过目录遍历攻击可以获取系统文件及服务器的配置文件等等。一般来说，他们利用服务器 API、文件标准权限进行攻击。	1、对用户可控参数地输入进行过滤，禁止用户输入../等恶意字符。 2、文件 ID 使用随机数命名 3、文件路径保存至数据库，前端传入对应 ID，后端进行匹配，防止篡改。

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

		为进一步攻击提供支持。		
水平越权	高危：可查看越权功能点敏感信息或进行相关操作。 中危：可修改的范围有限，不涉及敏感信息。 低危：查看范围有限，不涉及敏感信息。	攻击者在获得同一级别用户帐号后，可以利用一些方式绕过权限检查，访问或者操作到同一级别其他账户信息。	权限类型不变，权限 ID 改变，攻击者尝试访问与他拥有相同权限的用户的资源	在系统中，加入用户身份认证机制或者 tonken 验证，防止可被直接链接就可访问到用户的功能进行操作。
未授权访问	紧急：可未授权访问管理员账号（可读可操作）。 高危：可未授权访问管理员账号（可读不可操作），可未授权访问其他类型账号（可读可操作）。 中危：可未授权访问其他类型账号（可读不可操作，包含敏感信息）。 低危：可未授权访问其他类型账号（可读不可操作，不包含敏感信息）。	攻击者没有获取到登录权限或未授权的情况下，或者不需要输入密码，即可通过直接输入网站控制台主页面地址，或者不允许查看的链接便可进行访问，同时进行操作。	攻击者没有获取到登录权限或未授权的情况下，或者不需要输入密码，即可通过直接输入网站控制台主页面地址，或者不允许查看的链接便可进行访问，同时进行操作	在系统中，加入用户身份认证机制或者 tonken 验证，防止可被直接链接就可访问到用户的功能进行操作。
垂直越权	高危	攻击者在获得低权限用户帐户后，可以利用一些方式绕过权限检查，访问或者操作到原本无权访问的高权限功能。	越权访问，这类漏洞是指应用在检查授权（Authorization）时存在纰漏，使得攻击者在获得低权限用户帐后后，可以利用一些方式绕过权限检查，访问或者操作到原本无权访问的高权限功能。在实际的代码	1、对用户操作进行权限校验，防止通过修改参数进入未授权页面及进行非法操作。 2、在服务端对请求的数据和当前用户身份做校验检查。

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

			安全审查中，这类漏洞往往很难通过工具进行自动化检测，因此在实际应用中危害很大。其与未授权访问有一定差别。	
用户账号重复	高危	系统存在用户账号重复情况，可以导致系统账号信息覆盖等逻辑安全问题。	1、在注册时，同时使用相同的用户名，在同一时间进行同步注册活动，再高并发的情况下，系统提示均已成功。 2、在注册时使用已注册的账号作为注册账号，通过修改返回数据包中生成的 ID 值来进行注册，仍可成功。	在用户注册、新建账号信息时。首先判断账号信息是否存在，若存在则无法新建该账号。
任意用户注册	高危	攻击者可绕过注册界面认证措施失效导致任意用户注册。如：批量用户注册可领取新用户红包进行“薅羊毛”。	未验证邮箱/手机号，目前很多应用为了方便用户记录自己的用户名与密码，都可以使用邮箱跟手机号作为登录用户名，因此很多应用在注册的时候就要求用户填写，一般情况下该应用都会发送激活信息，用户在收到激活信息后才能登录。然而有时候开发人员并不去审核邮箱/手机号是否有效，所以可以利用该缺陷，任意注册账号。我们可以通过抓取数据包，不断的将邮箱/手机号加一加一去爆破，这样如果线程够	对用户提交的注册信息进行校验，如邮箱，手机号等，同时一个账号限制只能注册一次。

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

			多，很可能能撑爆网站的数据库。	
用户名枚举	中危：可通过自动化工具批量枚举。	可通过自动化工具重放数据包，根据返回信息得到系统存在的用户名。	由于错误配置或设计缺陷，当向系统提交有效账户和无效账户时，服务器会有不同的响应。利用响应的不同，攻击者可以获取到系统已经存在的账户，可用于暴力破解，进一步获取账户的登录密码。	添加验证码机制抗重放攻击。
不安全的错误提示	低危	当输入正确的用户名错误的密码时提示密码错误，当输入不存在的用户名时提示用户名不存在。攻击者可根据提示信息进行用户名枚举发现系统存在的用户账号信息。	攻击者根据 Web 应用程序返回的错误提示信息如“用户不存在”和“密码错误”等即可枚举系统中存在的登录用户名，然后针对枚举出来的登录用户名，对其密码进行暴力破解	将系统提示信息统一为用户名或密码错误。
无账户锁定机制	低危	多次错误认证，系统并无账户锁定机制，可造成暴力破解攻击。	记录用户连续输入密码错误的次数，达到某个错误次数以后，比如说是 5 次以后，就锁定用户，暂时不让用户登录。等锁定时限以后，用户又有 5 次重新输入密码的机会。代码实现原理是将用户名和输入错误的密码错误的次数记录到 reids 里，当用户登录成功后，清除该用户	当账户多次认证失败时结合业务情况锁定账户时间，防止攻击者进行恶意锁定攻击。

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

			的登录错误的次数，重新计算。	
认证绕过（漏洞名称可根据具体场景自定义）	高危：场景：绕过除短信验证码之外的如密保问题。	攻击者可绕过某些认证措施造成直接或间接访问某些服务。	由于对登录的账号及口令校验存在逻辑缺陷，或再次使用服务器端返回的相关参数作为最终登录凭证，导致可绕过登录限制，如服务器返回一个 flag 参数作为登录是否成功的标准，但是由于代码最后登录是否成功是通过获取这个 flag 参数来作为最终的验证，导致***者通过修改 flag 参数即可绕过登录的限制！	根据具体绕过方式提出修复建议。
密码重设	高危	攻击者可以通过抓包篡改账号信息，构造密码充值链接等方式。绕过密码充值前的身份认证阶段，达到重置任意账户密码的目的。	重置密码本身没有问题，但是在重置密码中的验证机制不够完善。其产生的原因多种多样，最主要的原因是网站有逻辑上的漏洞，即没有做到用户、账号、验证码三者统一进行验证。	在服务端对请求的数据和当前用户身份做校验检查，若不匹配则拒绝密码重置请求。
系统存在弱口令风险	低危	修改密码处没有强度要求，导致用户可能设置弱口令增加系统风险。	弱口令”指的是：密码设置为“123456”、“666666”、“身份证后六位”、“密码同账号一致”等类似内容，非常容易被黑客暴力破解	修改密码处要求新密码符合以下规则： 1、大小写字母加上数字、特殊字符（3 选 2）。 2、密码长度最低 8 位限制，设置口令使用期限。 3、不允许出现 3 个连续或相同的数字以及字母。

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

密码修改无原密码校验机制	高危	修改密码时缺少原密码认证。若系统存在跨站请求伪造可结合该漏洞欺骗用户点击，攻击者即可修改密码。	后台没有对旧密码进行验证，就直接让输入新密码	在修改密码时增加认证原密码操作。
弱口令	高危	使用弱口令或系统默认口令。可导致任意用户登录获取相应权限。	服务器、中间件、应用等使用了默认口令，导致可被轻易猜解。例如数据库默认空口令，管理后台使用默认帐号密码	用户口令需满足以下要求： 1、大小写字母加上数字、特殊字符。 2、密码长度最低 8 位限制，设置口令使用期限。 3、不允许出现连续或相同的数字以及字母。
短信轰炸	纵向轰炸（高）	攻击者通过网站页面中所提供的发送短信验证码的功能处，通过对其发送数据包的获取后，进行重放，如果服务器短信平台未做校验的情况时，系统会一直去发送短信，这样就造成了短信轰炸的漏洞，该漏洞会导致同一用户被恶意骚扰同时极	攻击者通过网站页面中所提供的发送短信验证码的功能处，通过对其发送数据包的获取后，进行重放，如果服务器短信平台未做校验的情况时，系统会一直去发送短信，这样就造成了短信轰炸的漏洞	1、 合理配置后台短信服务器的功能，对于同一手机号码，发送次数不超过 3-5 次，并且可对发送的时间间隔做限制。 2、 不影响业务的情况下建议在获取短信验证码之前先设置图形验证码同时生成一次性令牌，通过后端校验限制获取验证码的请求次数。

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

		大的造成了系统资源浪费。		
	横向轰炸（高）	攻击者通过网站页面中所提供的发送短信验证码的功能处，通过对其发送数据包的获取后，进行重放，如果服务器短信平台未做校验的情况时，系统会一直去发送短信，这样就造成了短信轰炸的漏洞，该漏洞会导致不同用户被恶意骚扰同时极大的造成了系统资源浪费。	攻击者通过网站页面中所提供的发送短信验证码的功能处，通过对其发送数据包的获取后，进行重放，如果服务器短信平台未做校验的情况时，系统会一直去发送短信，这样就造成了短信轰炸的漏洞	
短信验证码重复利用	中危	发送短信验证码可重复使用。如：登录接口验证码重复利用可导致暴力破解等危害。	由于未设置验证码的失效时间，在进行输入时没有对验证码进行验证，导致验证码只要可使用就可以通过验证，导致可以多次利用进行操作	1、对验证码的安全时效时间进行安全限制，一般限制 60 秒或者 120 秒之间失效。 2、对于同一 IP 在同一时间进行多次的验证码请求频率上做安全防护，限制 1 分钟请求的次数或者是 10 分钟内的请求次数。 3、对于图片验证码的图片进行噪点渲染，防止图片

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

				被 OCR 自动识别。
短信验证码时效性缺陷	中危	验证码时效性缺陷导致验证码长时间未校验后依然可以使用，攻击者结合弱复杂度验证码可以对验证码进行爆破。		1、对验证码的安全时效时间进行安全限制，一般限制 30 秒或者 50 秒之间失效。 2、对于同一 IP 在同一时间进行多次的验证码请求频率上做安全防护，限制 1 分钟请求的次数或者是 10 分钟内的请求次数。 3、对于图片验证码的图片进行噪点渲染，防止图片被 OCR 自动识别。
短信内容可控	高危：短信内容可控且接收人可控 中危：短信内容可控且接收人不可控	短信内容可控且接收人可控的情况下，攻击者可利用该漏洞进行钓鱼欺骗、恶意骚扰。	攻击者在通过修改数据请求包中的数据或 response 中的返回数据，从而达到修改需要发送的内容	1、在不影响业务的前提下，限制短信接收人为当前用户。 2、禁止任意用户编辑短信内容。定制短信内容需要权限审核校验。
短信验证码返回到前端	高危	由于验证码直接返回前端，通过该漏洞攻击者可以注册任意用户，重置已注册用户密码，修改绑定信息等高危操作，对用户造成一定影	在重置密码流程中获取验证时可能服务器会把验证码返回给客户端，造成修改任意用户密码漏洞	禁止将短信验证码回显至前端，验证码只存于服务端中。

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

		响。		
短信验证码机制绕过（漏洞名称可根据具体场景自定义）。	高危：通过其他手段绕过验证码机制以达到登录、修改密码等目的，如万能验证码	可通过前端修改数据包或其他方法绕过短信验证码机制。攻击者绕过短信验证码进而可直接注册、登录、修改密码等功能。造成任意用户注册，重置任意用户密码等危害。	短信验证码可被绕过，执行重置密码、登陆等其他操作。	1、验证码认证成功或失败状态系统后端同步，防止中间人攻击篡改认证失败数据包。 2、当用户验证码校验失败时，及时删除该用户 session，防止利用他人验证码。 3、关键操作每提交一次请求，应发送新的短信验证码，并且不可继续使用旧的验证码。
邮箱轰炸	纵向轰炸（高）	攻击者通过网站页面中所提供的发送邮箱验证的功能处，通过对其发送数据包的获取后，进行重放，如果服邮件服务器未做校验的情况时，系统会一直去发送邮件，这样就造成了邮件轰炸的漏洞，该漏洞会导致同一用户被恶意骚扰同时极大的造成了系统资源浪费。	应用系统未限制邮件的发送次数和频率，造成短时间内大量邮件发送至接收者邮箱，造成大量垃圾邮件。	1、服务端完成一次包含验证码的请求后及时对验证码做失活处理。 2、将每一次请求验证码的返回值进行一次 MD5 运算防止返回相同的验证码。

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

	横向轰炸（高）	攻击者通过网站页面中所提供的发送邮箱验证的功能处，通过对其发送数据包的获取后，进行重放，如果服邮件服务器未做校验的情况时，系统会一直去发送邮件，这样就造成了邮件轰炸的漏洞，该漏洞会导致不同用户被恶意骚扰同时极大的造成了系统资源浪费。	应用系统未限制邮件的发送次数和频率，造成短时间内大量邮件发送至接收者邮箱，造成大量垃圾邮件。	
邮件内容可控	高危：短信内容可控且接收人可控 中危：短信内容可控且接收人不可控	短信内容可控且接收人可控的情况下，攻击者可利用该漏洞进行钓鱼欺骗、恶意骚扰。	攻击者在通过修改数据请求包中的数据或response中的返回数据，从而达到修改需要发送的内容	短信验证码应只以短信方式发送到指定手机号，不再客户端进行发送和返回。
邮件验证码重复利用	中危	发送邮件验证码可重复使用。如：重置密码接口验证码重复利用可导致暴力破解等危害。	由于未设置验证码的失效时间，在进行输入时没有对验证码进行验证，导致验证码只要可使用就可以通过验证，导致可以多次利用进行操作	1、服务端完成一次包含验证的请求后及时删除验证码相应。 2、将每一次请求验证码的返回值进行一次MD5运算防止返回相同的验证码。
前端验证码生	中危	攻击者通过构造特殊payload、	在前端生成验证码时制作了简单的客户端验证，使得修	图形验证码采用随机算法且生成不受任何API接口

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

成机制可控		URL 参数链接导致验证码可控。造成验证码功能失效，可导致暴力破解、任意用户注册等逻辑问题。	改前端 js 代码，从而达到修改前端验证码生成机制，再发送请求时，连同带有修改后的代码参数进行提交，从而使得验证码过于简单，达到攻击者的目的	参数等其他因素影响。
图形验证码前端显示	中危	图形验证码数值在返回包中返回前端(可通过自动化程序输入验证码，导致验证码无效，导致防护失效) 。	图形验证码数值在返回包中返回前端(可通过自动化程序输入验证码，导致验证码无效，导致防护失效)	禁止将验证码返回给客户端。
图形验证码可自动识别	中危	在破解验证码中需要用到的知识一般是 像素，线，面等基本 2 维图形元素的处理和色差分析，简单的图形验证码可经过一些工具进行识别。	在破解验证码中需要用到的知识一般是 像素，线，面等基本 2 维图形元素的处理和色差分析，简单的图形验证码可经过一些工具进行识别	采取一定的干扰措施且不可预测，如字体倾斜，加背景噪点、横线等。
图形验证码机制绕过（漏洞名称可根据具体场景自定义）	中危	可通过自动化图形验证码识别程序进行自动化操作。导致暴力破解等逻辑漏洞。	图形验证码可被绕过，执行暴力破解、短信轰炸等自动化攻击操作。	图形验证码随机生成且图形字符都有粘连部分、不使用规则字符，验证码的各个部分使用不同比例的缩放或者旋转。

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

图形验证码重复利用	中危	图形验证码可重复使用。如：登录接口验证码重复利用可导致暴力破解。	由于未设置验证码的失效时间，在进行输入时没有对验证码进行验证，导致验证码只要可使用就可以通过验证，导致可以多次利用进行操作	1、服务端完成一次包含验证的请求后及时销毁并生成新的验证码。 2、将每一次请求验证码的返回值进行一次 MD5 运算防止返回相同的验证码。
cookie 缺少 http-only 属性	低危 无登录功能或未提供账号的不做测试。	Cookie 信息泄露是 Cookie HttpOnly 配置缺陷引起的，在设置 Cookie 时，可以设置的一个属性，如果 Cookie 没有设置这个属性，该 Cookie 值可以被页面脚本读取。	由于会话 cookie 不包含“HttpOnly”属性，因此注入点的恶意脚本可能访问此 cookie，并窃取它的值。任何存储在会话令牌中的信息都可能被窃取，并在稍后用于身份盗窃或用户伪装。	建议设置 Cookie HttpOnly 安全属性。 jsp 参考代码如下： response.setHeader("SET-COOKIE", "user=" + request.getParameter("cookie") + "; HttpOnly"); PHP 中的设置如下： PHP5.2 以上版本已支持 HttpOnly 参数的设置，同样也支持全局的 HttpOnly 的设置，在 php.ini 中设置 session.cookie_httponly，设置其值为 1 或者 TRUE，来开启全局的 Cookie 的 HttpOnly 属性。 对于 PHP5.1 以前版本以及 PHP4 版本的话，则需要通过 header 函数来设置： <?php header("Set-Cookie: hidden=value; httpOnly"); ?>

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

cookie 缺少 secure 属性	低危 该漏洞仅针对 https 协议，没有登录功能或未提供账号的不做测试。	若加密会话（SSL）中未配置了 Secure 属性。那么任何以明文形式发送到服务器的 Cookie、会话令牌或用户凭证之类的信息都可能被窃取，并在稍后用于身份盗窃或用户伪装。	由于会话 cookie 不包含“secure”属性，所以用户可以通过未加密的 http 协议传输 Cookie,可能造成用户信息被窃听。	1、若系统只支持 HTTPS 协议建议系统直接增加 Secure 安全属性。 2、若系统需要同时兼容 HTTP、HTTPS 协议建议系统根据代码判断后，增加 Secure 安全属性。
会话标识固定	中危	在用户进入登录页面，但还未登录时，即产生了一个 session，用户登录后，session 的 id 未改变。 即系统在登录后没有建立新 session，原来的 session 也没有被销毁。攻击者事先访问系统并建立一个会话，诱使受害者使用此会话登录系统，然后攻击者再使用该会话访问系统即可登录受害	在用户进入登录页面，但还未登录时，就已经产生了一个 session，用户输入信息，登录以后，session 的 id 不会改变，也就是说没有建立新 session，原来的 session 也没有被销毁）。攻击者事先访问系统并建立一个会话，诱使受害者使用此会话登录系统，然后攻击者再使用该会话访问系统即可登录受害者的账户	在用户提供的认证信息（例如用户名和密码）、相应的权限级别发生变化时，服务器端应重新生成 SessionID，并强制失效之前的会话。

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

		者的账户。		
会话无超时失效机制	低危	系统登录后长时间未操作或会话存活时间过长，将可能会导致敏感信息泄露，登录会话被他人操作等危害。	用户退出系统后，服务器端 Session 未失效，攻击者可利用此 Session 向服务器继续发送服务请求。	若系统无会话超时机制，建议系统增加会话超时机制并控制在合理且安全的时间范围内，推荐会话生命周期为 30 分钟。
失效的会话注销	中危	系统登录后抓取数据包，当注销会话后重放该数据包依然能够完成当前数据包请求。可造成信息泄露等危害，存在风险。	用户退出系统后，服务器端 Session 未失效，攻击者可利用此 Session 向服务器继续发送服务请求。	会话状态信息应与服务端进行同步。当用户会话注销后及时将服务端会话信息清除。
会话信息泄露	中危	会话敏感信息以直接或间接方式泄露 如：用户名、密码等敏感信息存储在 Cookie 信息中或 Session、Cookie 等信息直接存在前端源代码、数据包		根据会话信息泄露位置及时清除泄露敏感信息。对于会话信息存储 Cookie 中变更 Cookie 认证方式。

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

		内等。		
反射型跨站脚本攻击	中危	跨站脚本攻击,它指的是恶意攻击者往 Web 页面里插入恶意 html 代码，当用户浏览该页之时，嵌入其中 Web 里面的 html 代码会被执行，从而达到恶意用户的特殊目的，而反射型跨站脚本攻击涉及的功能点多为：URL 参数需要在页面显示的功能点都可能存在反射型跨站脚本攻击，例如站内搜索、查询功能点。	跨站脚本攻击,它指的是恶意攻击者往 Web 页面里插入恶意 html 代码，当用户浏览该页之时，嵌入其中 Web 里面的 html 代码会被执行，从而达到恶意用户的特殊目的，而反射型跨站脚本攻击涉及的功能点多为：URL 参数需要在页面显示的功能点都可能存在反射型跨站脚本攻击，例如站内搜索、查询功能点。	1、输入验证：某个数据被接受为可被显示或存储之前，使用标准输入验证机制，验证所有输入数据的长度、类型、语法以及业务规则。 2、输出编码：数据输出前，确保用户提交的数据已被正确进行 entity 编码，建议对所有字符进行编码而不仅局限于某个子集。 3、明确指定输出的编码方式：不要允许攻击者为你的用户选择编码方式(如 ISO 8859-1 或 UTF 8) 4、注意黑名单验证方式的局限性：仅仅查找或替换一些字符(如"<" ">"或类似"script"的关键字)，很容易被 XSS 变种攻击绕过验证机制。

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

存储型跨站脚本攻击	高危	跨站脚本攻击,它指的是恶意攻击者往 Web 页面里插入恶意 html 代码，当用户浏览该页之时，嵌入其中 Web 里面的 html 代码会被执行，从而达到恶意用户的特殊目的，而存储型跨站脚本攻击涉及的功能点多为：用户输入的文本信息保存到数据库中，并能够在页面展示的功能点，例如用户留言、发送站内消息、个人信息修改等功能点。	跨站脚本攻击,它指的是恶意攻击者往 Web 页面里插入恶意 html 代码，当用户浏览该页之时，嵌入其中 Web 里面的 html 代码会被执行，从而达到恶意用户的特殊目的，而存储型跨站脚本攻击涉及的功能点多为：用户输入的文本信息保存到数据库中，并能够在页面展示的功能点，例如用户留言、发送站内消息、个人信息修改等功能点。	1、输入验证：某个数据被接受为可被显示或存储之前，使用标准输入验证机制，验证所有输入数据的长度、类型、语法以及业务规则。 2、输出编码：数据输出前，确保用户提交的数据已被正确进行 entity 编码，建议对所有字符进行编码而不仅局限于某个子集。 3、明确指定输出的编码方式：不要允许攻击者为你的用户选择编码方式(如 ISO 8859-1 或 UTF 8) 4、注意黑名单验证方式的局限性：仅仅查找或替换一些字符(如"<" ">"或类似"script"的关键字)，很容易被 XSS 变种攻击绕过验证机制。
DOM 型跨站脚本攻击	中危	跨站脚本攻击,它指的是恶意攻击者往 Web 页面里插入恶意 html 代码，当用户浏览该页之时，嵌入其中 Web 里面的 html 代码会被执行，从而达到恶意用户的特殊	跨站脚本攻击,它指的是恶意攻击者往 Web 页面里插入恶意 html 代码，当用户浏览该页之时，嵌入其中 Web 里面的 html 代码会被执行，从而达到恶意用户的特殊目的，而基于 DOM 跨站脚本攻击涉及的功能点：涉及 DOM 对象的页面程序，包括（不限这些）：	1、输入验证：某个数据被接受为可被显示或存储之前，使用标准输入验证机制，验证所有输入数据的长度、类型、语法以及业务规则。 2、输出编码：数据输出前，确保用户提交的数据已被正确进行 entity 编码，建议对所有字符进行编码而

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

		目的，而基于 DOM 跨站脚本攻击涉及的功能点：涉及 DOM 对象的页面程序，包括（不限这些）：document.URL document.URLUnencoded document.location document.referrer window.location	document.URL document.URLUnencoded document.location document.referrer window.location	不仅局限于某个子集。 3、明确指定输出的编码方式：不要允许攻击者为你的用户选择编码方式(如 ISO 8859-1 或 UTF 8) 4、注意黑名单验证方式的局限性：仅仅查找或替换一些字符(如"<" ">"或类似"script"的关键字)，很容易被 XSS 变种攻击绕过验证机制。
跨站请求伪造 CSRF	中危	攻击者使用 CSRF 攻击能够强迫用户向服务器发送请求，导致用户信息被迫修改，甚至可引发蠕虫攻击。如果恶意用户能够知道网站管理后台某项功能的 URL，就可以直接攻击管理员，强迫管理员执行恶意用户定义的操作。	攻击者在用户浏览网页时，利用页面元素（例如 img 的 src），强迫受害者的浏览器向 Web 应用服务器发送一个改变用户信息的 HTTP 请求从而达到篡改用户信息的目的。	1、通过 referer 判断页面来源进行 CSRF 防护，该方式无法防止站内 CSRF 攻击及 referer 字段伪造。 2、重要功能点使用动态验证码进行 CSRF 防护。 3、通过 token 方式进行 CSRF 防护

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

SQL 注入	紧急：利用 SQL 注入可以进行拖库、删库、提权、写马等情况。 高危：只可以获取到数据库名，表名等信息，无法进一步获取到字段内容的情况下。	SQL 注入攻击包括通过输入数据从客户端插入或“注入”SQL 查询到应用程序。一个成功的 SQL 注入攻击可以从数据库中获取敏感数据、修改数据库数据（插入/更新/删除）、执行数据库管理操作（如关闭数据库管理系统）、恢复存在于数据库文件系统中的指定文件内容，在某些情况下能对操作系统发布命令。	攻击者通过 web 应用程序利用 SQL 语句或字符串将非法的数据插入到服务端数据库中，获取数据库的用户管理权限，然后将数据库管理用户权限提升至操作系统管理用户权限，控制服务器操作系统，获取重要的信息和机密文件。	1、使用预编译处理输入参数：要防御 SQL 注入，用户的输入就不能直接嵌套在 SQL 语句当中。使用参数化的语句，用户的输入就被限制于一个参数当中。 2、输入验证：检查用户输入的合法性，以确保输入的内容为正常的数据。 3、错误消息处理：防范 SQL 注入，还要避免出现一些详细的错误消息，恶意攻击者往往会利用这些报错信息来判断后台 SQL 的拼接形式。
框架注入	高危	框架注入是将 frame 或 iframe 标签嵌入到被攻击的网站上，进而修改站点页面。被嵌入的页面包含恶意代码，可能诱惑用户登录，获取合法的登录凭证。 主要危害： [1]恶意篡改	注入攻击指一种攻击手段，黑客通过把 HTML 代码输入一个输入机制(例如缺乏有效验证限制的表格域)来改变网页的动态生成的内容。一个恶意黑客(也被称为破裂者 cracker)可以利用这种攻击方法来非法获取数据或者网络资源。当用户进入一个有命令注入漏洞的网页时，他们的浏览器会通译	一般性的建议：过滤客户端提交的危险字符，客户端提交方式包含 GET、POST、COOKIE、User-Agent、Referer、Accept-Language 等，其中危险字符如下： [1] | [2] & [3] ; [4] $ [5] %

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

		网页内容。 [2]网页挂马。 [3]网站钓鱼攻击	那个代码，而这样就可能会导致恶意命令掌控该用户的电脑和他们的网络。	[6] @ [7] ' [8] " [9] [10] () [11] + [12] CR [13] LF [14] , [15] . [16] script [17] document [18] eval 开发语言的建议： [1]严格控制输入： Asp:request Php:$_GET、$_POST、$_COOKIE、$_SERVER Jsp:request.getParameter、request.getCookies Asp.net:Request.QueryString、Form、Cookies、SeverVaiables 客户端提交的变量一般从以上函数获得，严格限制提交的数据长度、类型、字符集。 [2]严格控制输出： HtmlEncode：对一段指定的字符串应用 HTML 编码。 UrlEncode：对一段指定的字符串 URL 编码。 XmlEncode：将在 XML 中使用的输入字符串编码。

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

				XmlAttributeEncode：将在 XML 属性中使用的输入字符串编码 escape：函数可对字符串进行编码 decodeURIComponent：返回统一资源标识符的一个已编码组件的非编码形式。 encodeURI：将文本字符串编码为一个有效的统一资源标识符(URI)。 以下两种方法可用于防止框架注入漏洞 [1]如果应用程序不要求不同的框架互相通信，就可以通过完全删除框架名称、使用匿名框架防止框架注入。但是，因为应用程序通常都要求框架之间相互通信，因此这种方法并不可行。 [2]使用命名框架，但在每个会话中使用不同的框架，并且使用无法预测的名称。一种可行的方法是在每个基本的框架名称后附加用户的会话令牌，如main_display。

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

链接注入	高危	链接注入是将某个 URL 嵌入到被攻击的网站上，进而修改站点页面。被嵌入的 URL 包含恶意代码，可能窃取正常用户的用户名、密码，也可能窃取或操纵认证会话，以合法用户的身份执行相关操作。下边 PHP 代码为例，做简要的分析。 /* 实例代码 */ $str = $_GET['name']; echo $str; 上述代码中变量$str,接受 GET 方式传递的数据，并未对危险字符做过滤，假如客户端提交“Link_Injecting”,那么将在浏览器内引用“1.htm”。 主要危害： [1]获取其他	改站点内容的行为，其方式为将外部站点的 URL 嵌入其中，或将有易受攻击的站点中的脚本的 URL 嵌入其中。将 URL 嵌入易受攻击的站点中，攻击者便能够以它为平台来启动对其他站点的攻击，以及攻击这个易受攻击的站点本身	一般性的建议： 过滤客户端提交的危险字符，客户端提交方式包含 GET、POST、COOKIE、User-Agent、Referer、Accept-Language 等，其中危险字符如下： [1] | [2] & [3] ; [4] $ [5] % [6] @ [7] ' [8] " [9] [10] () [11] + [12] CR [13] LF [14] , [15] . [16] script [17] document [18] eval 开发语言的建议： [1]严格控制输入： Asp:request Php:$_GET、$_POST、$_COOKIE、$_SERVER Jsp:request.getParameter、request.getCookies Asp.net:Request.QueryString、Form、Cookies、SeverVaiables

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

		用户 Cookie 中的敏感数据。 [2]屏蔽页面特定信息。 [3]伪造页面信息。 [4]拒绝服务攻击。 [5]突破外网内网不同安全设置。		客户端提交的变量一般从以上函数获得，严格限制提交的数据长度、类型、字符集。 [2]严格控制输出： HtmlEncode：对一段指定的字符串应用 HTML 编码。 UrlEncode：对一段指定的字符串 URL 编码。 XmlEncode：将在 XML 中使用的输入字符串编码。 XmlAttributeEncode：将在 XML 属性中使用的输入字符串编码 escape：函数可对字符串进行编码 decodeURIComponent：返回统一资源标识符的一个已编码组件的非编码形式。 encodeURI：将文本字符串编码为一个有效的统一资源标识符(URI)。 以下两种方法可用于防止框架注入漏洞 [1]如果应用程序不要求不同的框架互相通信，就可以通过完全删除框架名称、使用匿名框架防止框架注入。但是，因为应用程序通常都要求框架之间相

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

				互通信，因此这种方法并不可行。 [2]使用命名框架，但在每个会话中使用不同的框架，并且使用无法预测的名称。一种可行的方法是在每个基本的框架名称后附加用户的会话令牌，如 main_display。
Xpath 注入	高危	XPath 注入攻击是指利用 XPath 解析器的松散输入和容错特性，能够在 URL、表单或其它信息上附带恶意的 XPath 查询代码，以获得权限信息的访问权并更改这些信息。	XPath 注入攻击是指利用 XPath 解析器的松散输入和容错特性，能够在 URL、表单或其它信息上附带恶意的 XPath 查询代码，以获得权限信息的访问权并更改这些信息。	XPath 攻击防御可参考如下： 1. 数据提交到服务器上端，在服务端正式处理这批数据之前，对提交数据的合法性进行验证。 2. 检查提交的数据是否包含特殊字符，对特殊字符进行编码转换或替换、删除敏感字符或字符串。 3. 对于系统出现的错误信息，以 IE 错误编码信息替换，屏蔽系统本身的出错信息。 4. 参数化 XPath 查询，将需要构建的 XPath 查询表达式，以变量的形式表示，变量不是可以执行的脚本。如下代码可以通过创建保存查询的外部文件使查询参数化：declare variable $loginID as xs：string external；declare

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

				variable $password as xs：string external；//users/user[@loginID=$loginID and @password=$password]。 5. 通过 MD5、SSL 等加密算法，对于数据敏感信息和在数据传输过程中加密， 即使某些非法用户通过非法手法获取数据包，看到的也是加密后的信息。
XML 外部实体注入	高危	XML 是标准通用标记语言（SGML）的子集，非常适合 Web 传输。XML 提供统一的方法来描述和交换独立于应用程序或供应商的结构化数据。发现目前一些普遍使用 xml 的场景中都存在一种古老的 XML 实体注入漏洞，使得攻击者可能可以任意访问服务器以及应用所在网络的任何资源。	可扩展标记语言 XML 提供统一的方法来描述和交换独立于应用程序或供应商的结构化数据，如果在查询或者插入时，没有对用户的输入进行过滤或者转义，则可以修改 XML 数据格式，改变 XML 节点，造成 xml 注入。	1、严格检查用户输入的字符 2、检查使用的底层 XML 解析库，使用 JAVA 语言提供的禁用外部实体的方法：DocumentBuilderFactory dbf =DocumentBuilderFactory.newInstance();dbf.setExpandEntityReferences(false) 3.、操作 XML 时对格式字符进行转义处理

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

CRLF 注入	中危	在 HTTP 当中 HTTP 的 Header 和 Body 之间就是用两个 crlf 进行分隔的，如果能控制 HTTP 消息头中的字符，注入一些恶意的换行，这样就能注入一些会话 cookie 和 html 代码，所以 CRLF injection 又叫做 HTTP response Splitting，简称 HRS。CRLF 漏洞可以造成 Cookie 会话固定和反射型 XSS(可过 waf)的危害，注入 XSS 的利用方式：连续使用两次%0d%oa 就会造成 header 和 body 之间的分离，就可以在其中插入 xss 代码形成反射型 xss 漏洞。	CRLF 注入又叫 HTTP 响应拆分 / 截断（HTTP Response Splitting）简称 HRS。HRS 漏洞存在的前提是 ：url 当中输入的字符会影响到文件，比如在重定位当中可以尝试使用 %0d%0a 作为 CRLF。一般网站会在 HTTP 头中加上 Location: http://baidu.com 的方式来进行 302 跳转，所以我们能控制的内容就是 Location: 后面的 XXX 网址，对这个地址进行污染。	服务端收到前端过来的参数，在加入 Location 之前，需要过滤 \r 、\n 之类的行结束符，避免输入的数据污染其它 HTTP 首部字段。

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

代码注入	高危	代码注入可以向系统可执行脚本中写入一句话木马，攻击者可以构造 payload 访问被写入文件执行系统命令，则该脚本即成为后门文件。	用户输入的恶意代码被服务器直接解析执行，从而导致攻击者可以对服务器注入任意代码。常见的有命令执行（有回显的情况用的多）、反弹 shell、写入 webshell、注入内存马等风险操作。	对传入参数进行严格控制，过滤特殊字符、重点关注 writeconfig()等写入函数。
远程命令执行	高危	部分 web 程序提供了某些命令执行等操作，那么 Web 底层就会调用系统命令，如果系统没有针对用户输入的命令进行限制、过滤则会造成命令执行漏洞。攻击者可以直接执行系统命令，造成窃取敏感信息，严重的可直接控制服务器。	用户通过浏览器提交执行命令，由于服务器端没有针对执行函数做过滤，导致在没有指定绝对路径的情况下就执行命令，可能会允许攻击者通过改变 $PATH 或程序执行环境的其他方面来执行一个恶意构造的代码。	1、在进入执行命令的函数/方法之前，对参数进行过滤，对敏感字符进行转义。 2、在使用动态函数之前，确保使用的函数是指定的函数之一。
反序列化漏洞	高危	Java 反序列化即逆过程，由字节流还原成对象。ObjectInputStream 类的 readObject()方法用于反序列化。Apache	Java 序列化就是把对象转换成字节流，便于保存在内存、文件、数据库中，Java 中的 ObjectOutputStream 类的 writeObject()方法可以实现序列化。Java 反序列化即逆过程，由字节流还	根据具体反序列化组件出现位置提出修复建议： 如 Weblogic 反序列化修复： 1、升级 JDK 版本。由于 Java 在今年一月份以后更新了反序列化防御接口，可以缓解反序列化漏洞的影

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

		Commons Collections 允许链式的任意的类函数反射调用。攻击者通过允许 Java 序列化协议的端口，把攻击代码上传到服务器上，再由 Apache Commons Collections 里的 TransformedMap 来执行。	原成对象。ObjectInputStream 类的 readObject() 方法用于反序列化。Apache Commons Collections 允许链式的任意的类函数反射调用。攻击者通过允许 Java 序列化协议的端口，把攻击代码上传到服务器上，再由 Apache Commons Collections 里的 TransformedMap 来执行	响。 2、升级 WebLogic、删除不需要的页面，清理不安全的第三方库。
文件包含漏洞	高危	文件包含函数加载的参数没有经过过滤或严格定义，可以被用户控制，包含其他恶意文件，导致了执行非预期代码同时攻击者可以读取系统配置文件获取数据库密码。	文件包含漏洞属于代码注入漏洞，为了减少重复代码的编写，引入了文件包含函数，通过文件包含函数将文件包含进来，直接使用包含文件的代码	1、严格检查变量是否初始化。 2、严格控制文件包含参数是否可控，同时过滤特殊字符。参数中不允许出现../类似的跳转字符。 3、同时系统对于 PHP 伪协议进行过滤和限制。
SSL/TLS 安全性测试	中危	检测系统使用 SSL/TLS 协议是否符合安全配置规范、是否使用 PFS 规范的加密套件、当前域名与所配置		根据检测出 SSL/TLS 中漏洞位置提出修复建议 如系统使用 SSL v2 协议，此协议存在（DROWN）攻击，建议系统使用 TLS v1.2 为主要

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

		证书是否匹配等。		协议，同时推荐系统使用 HTTPS 最佳安全实践。
敏感信息未特殊加密（针对 https 协议）	低危	网站没有对传输的用户名、密码、身份证号、银行卡号等个人敏感信息进行特殊加密，这样认证会话信息等敏感数据在网络中很容易被嗅探到并破解。	敏感信息未经加密进行传输	建议对敏感字段进行特殊加密如 hash+salt 的方式，避免使用 MD5、Base64 等弱编码。
敏感信息明文传输（针对 http 协议）	中危	敏感信息使用明文传输的方式存在嗅探风险，如用户名、密码、身份证号、银行卡号等个人敏感信息，攻击者在局域网中嗅探网络流量，可轻易窃取账号信息。	系统采用 HTTP 访问模式，在页面上的操作全部采用 HTTP 方式明文传输，并且页面中也没有对传输的用户名和密码等敏感信息进行加密后传输，这样认证会话信息等敏感数据在网络中是明文传输，很容易被嗅探到	1、建议系统使用安全加密协议，避免使用明文传输协议如 HTTP 等。 2、建议对敏感字段进行特殊加密如 hash+salt 的方式，避免使用 MD5、Base64 等弱编码。
敏感数据 GET 传输	低危	GET 方法传输表单参数直接显示在 URL 链接中，若登录等位置使用 GET 方式传递表单则账号信息会直接显示在 URL 中，同时系统日志	会话令牌、登陆信息等敏感信息使用 GET 方式进行传输。此时这些敏感信息被附加在 URL 地址后面一起发送到服务器，在这个过程中，攻击者可以很清楚的查看到传输内容，从而被攻击者获取敏感数据。	建议系统敏感数据表单使用 POST 方法进行传递，防止出现敏感信息泄露风险。

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

		中会显示 GET 请求相关参数，从而造成信息泄露风险。		
脆弱的加密方式	低危	弱加密方式可直接使用在线解密工具解密出来，若攻击者窃取到以弱加密传输的密码可将其解密进而获取敏感信息。	在数据加密传输的过程中如果数据包被攻击者获取，且使用弱加密进行传输如 base64 编码，MD5,BASE64 等，在进行解密后即可获取加密后的信息	使用更为安全的加密算法，推荐使用非对称加密算法。若系统使用 MD5 加密算法，同时应注意防范 MD5 的撞库攻击。
未采用加密协议传输（实在没有漏洞的情况下可以提）	低危	系统未采用加密协议传输，如 HTTP 协议为明文传输协议，登录数据若没有进行加密可直接在网络流量中进行嗅探，造成隐私数据泄露。	由于网站在用户提交的敏感数据到服务器的过程中未进行相关加密处理，导致攻击者可以通过中间人攻击（劫持、嗅探）等方式获取到这些未加密的敏感数据。当攻击者获取到这些数据之后，可能利用这些信息以合法用户的身份登录系统，一旦进入到应用系统中那么就可以获取更多的敏感数据，以及有机会发现更多的漏洞。	建议系统使用 HTTPS 协议替代 HTTP 传输协议。
多点登录	低危	攻击者在获取到其他用户的账号密码后，可利用该缺陷在用户已登录且未知的情况下进行登录，操作用户账户。	系统允许多点认证	建议在不影响业务的前提下，禁止多点登录功能或增加登录信息安全提示功能（当登录系统后提示上次登录时间、IP 等安全信息提示）。

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

条件竞争漏洞	高危	当俩个或多个进程试图在同一时刻访问共享内存，或读写数据时，最后的执行结果取决于线程的执行顺序，当服务器端逻辑与数据库读写存在时序问题时则存在条件竞争漏洞。攻击者可多线程并发请求，在数据库信息未及时更新时，多次购买商品、积分兑换。	竞争条件是系统中的一种反常现象，由于现代 Linux 系统中大量使用并发编程，对资源进行共享，如果产生错误的访问模式，便可能产生内存泄露，系统崩溃，数据破坏，甚至安全问题。竞争条件漏洞就是多个进程访问同一资源时产生的时间或者序列的冲突，并利用这个冲突来对系统进行攻击。一个看起来无害的程序如果被恶意攻击者利用，将发生竞争条件漏洞。	在系统处理支付、订单等关键数据时，使用悲观锁或乐观锁保证政务的 ACID 性，并避免数据脏读（一个事务读取了另一个事务未提交的数据）。
暴力破解	中危	暴力破解的基本思想是根据题目的部分条件确定答案的大致范围，并在此范围内对所有可能的情况逐一验证，直到全部情况验证完毕。若某个情况验证符合题目的全部条件，则为本问题的一个解；若全部情况验证后都不符合题目的全部条	暴力破解的产生是由于服务器端没有做限制，导致攻击者可以通过暴力的手段破解所需信息。一般来说知道管理员的账户信息，破解的效率会大大增提升。	1、使用账户锁定机制。 2、返回信息进行把控，则无法根据系统返回信息判断暴力破解是否成功。 3、使用验证码防止使用自动化工具重复提交数据包。

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

		件，则本题无解。常常存在于网站的登录系统中，通过对已知的管理员用户名，进行对其登录口令的大量尝试。		
业务重放	根据系统功能及客户情况进行划分，如：发生在留言板处数据批量测试、批量点赞等场景定级为中危。	在系统某个功能点处存在重放漏洞的话，可以对提交数据进行重放。如：留言板处存在重放漏洞，攻击者可以提交留言并抓包，重放该数据包则可以重复发表留言，导致恶意刷留言等问题。	请求重放漏洞是电商平台业务逻辑漏洞中一种常见的由设计缺陷所引发的漏洞，通常情况下所引发的安全问题表现在商品首次购买成功后，参照订购商品的正常流程请求，进行完全模拟正常订购业务流程的重放操作，可以实现“ 一次购买多次收货 ”等违背正常业务逻辑的结果。	使用 token、加时间戳、随机数、流水号来有效应对抗重放攻击。
任意文件上传	高危：可以通过上传任意文件并 getshell 中危：可以绕过黑名单限制但无法 getshell	文件上传为系统本身的功能需要但是上传文件类型如果没有经过严格过滤措施就会导致攻击者上传恶意脚本、木马病毒。进而使攻击者获得控制服务器权限。	一般情况下文件上传漏洞是指用户上传了一个可执行的脚本文件，并通过此脚本文件获得了执行服务器端命令的能力。文件上传本身是 web 中最为常见的一种功能需求，关键是文件上传之后服务器端的处理、解释文件的过程是否安全。一般的情况有： 1. 上传文件 WEB 脚本语言，服务器的 WEB 容器解释	1、将文件上传目录直接设置为不可执行。 2、文件类型检查：建议使用白名单方式，结合 MIME Type、后缀检查等方式（即只允许允许的文件类型进行上传）；此外对于图片的处理可以使用压缩函数或 resize 函数，处理图片的同时破坏其包含的 HTML 代码。 3、 使用随机数改

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

			并执行了用户上传的脚本，导致代码执行； 2. 上传文件 FLASH 策略文件 crossdomain.xml，以此来控制 Flash 在该域下的行为； 3. 上传文件是病毒、木马文件，攻击者用以诱骗用户或管理员下载执行； 4. 上传文件是钓鱼图片或包含了脚本的图片，某些浏览器会作为脚本执行，可用于实施钓鱼或欺诈	写文件名和文件路径，使得用户不能轻易访问自己上传的文件。
任意文件下载	高危	文件下载为系统本身的功能需要但是下传文件类型、范围如果么有严格控制则会导致任意文件下载。 攻击者可结合目录穿越漏洞下载系统配置文件，导致严重的敏感信息泄露。	任意文件下载/读取漏洞不同于网站目录浏览，此漏洞不仅仅可遍历系统下 web 中的文件，而且可以浏览或者下载到系统中的文件，攻击人员通过目录遍历攻击可以获取系统文件及服务器的配置文件等等。一般来说，他们利用服务器 API、文件标准权限进行攻击。	1、净化数据：对用户传过来的文件名参数进行硬编码或统一编码，对文件类型进行白名单控制，对包含恶意字符或者空字符的参数进行拒绝。 2、限制用户下载文件类型、范围。 3、不允许提供目录浏览服务。
任意文件删除	高危	删除文件请求参数如果没有进行合理控制将会产生任意文件删除，结合系统目录穿越漏洞将会导致删除	在未经授权的情况下可任意删除 web 站点中的文件。	1、过滤系统特殊字符防止进行目录穿越。 2、严格控制删除功能相关参数，防止参数攻击者可控。

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

		系统配置文件。攻击者可恶意删除系统文件，导致服务瘫痪。		
SSRF 服务端请求伪造	高危：通过该漏洞结合内网其他漏洞可造成较大危害如 getshell 定高危。 中危：常规的内网信息探测。	由于服务端提供了从其他服务器应用获取数据的功能且没有对目标地址做过滤与限制。导致攻击者可以伪造服务端发起请求。比如从指定 URL 地址获取网页文本内容，加载指定地址的图片，下载等。	SSRF 漏洞是指是由于服务端提供了从其他服务器应用获取数据的功能且没有对目标地址做过滤与限制，比如从指定 URL 地址获取网页文本内容，加载指定地址的图片，下载等等从而被攻击者利用以达到如下几种攻击目的： 1、对外网、服务器所在内网、本地进行端口扫描，获取一些服务的 banner 信息； 2、 攻击运行在内网或本地的应用程序（比如溢出）； 3、 对内网 Web 应用进行指纹识别，通过访问默认文件实现； 4、 攻击内外网的 Web 应用，主要是使用 get 参数就可以实现的攻击（比如 struts2，sqli 等）； 5、利用 file 协议读取本地文件等	1、过滤内网服务器对公网服务器请求的响应。 2、统一错误提示信息，避免用户可以根据错误信息来判断远端服务器的端口状态 3、若公网服务器的内网 IP 与内网无业务通信，建议将公网服务器对应的内网 IP 列入黑名单，避免应用被用来获取内网数据。 4、内网服务器禁用不必要的协议，仅允许 HTTP 和 HTTPS 请求，防止类似于 file:///、gopher://、ftp:// 等协议引起的安全问题。

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

未验证的 URL 跳转	中危	服务端未对传入的跳转 url 变量进行检查和控制，可能导致可恶意构造任意一个恶意地址，诱导用户跳转到恶意网站。由于是从可信的站点跳转出去的，用户会比较信任，所以跳转漏洞一般用于钓鱼攻击。	借助未验证的 URL 跳转，将应用程序引导到不安全的第三方区域，从而导致的安全问题。	对传入的 URL 做有效性的认证，保证该 URL 来自于信任域。 限制的方式可参考以下两种： 1、限制 Referer（Referer 是 HTTP header 中的字段，当浏览器向 web 服务器发送请求时，一般会带上 Referer，告诉服务器是从哪个页面链接过来的），通过限制 Referer 保证将要跳转 URL 的有效性，避免攻击者生成自己的恶意跳转链接。 2、加入有效性验证 Token，保证所有生成的链接都来自于可信域，通过在生成的链接里加入用户不可控的 Token 对生成的链接进行校验。
订单修改	高危	由于程序逻辑不严谨或业务数据没有在服务端进行校验导致业务数据在传输过程中被攻击者篡改或绕过业务逻辑。进而攻击者可以任意修改订单金额、数量造	在提交订单的时候抓取数据包或者直接修改前端代码，然后对订单的金额任意修改	1. 服务器端在生成交易订单时，商品的价格从数据库中取出，禁止使用客户端发送的商品价格。 2. 服务器端对客户端提交的交易数据（如商品 ID、商品数量、商品价格等）的取值范围进行校验，将商品 ID 和商品价格与数据库中的数据

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

		成“一分钱购买商品”、“业务流程绕过”等逻辑问题。		对比校验，商品数量为大于零的整型数。 3. 服务器端在生成支付订单时，对支付订单中影响支付金额的所有因素（比如商品ID、商品数量、商品价格、订单编号等）进行签名，对客户端提交的支付订单进行校验。
时间限制绕过	高危	由于程序逻辑不严谨或业务数据没有在服务端进行校验导致业务数据在传输过程中被攻击者篡改或绕过业务逻辑。		1、对业务数据进行加密使攻击者无法辨认业务数据。 2、每个业务数据使用时间戳加签名方式进行校验有效应对重放攻击和中间人攻击。 3、业务数据服务端校验，不接受服务端传输过来的值。
次数限制绕过	高危	由于程序逻辑不严谨或业务数据没有在服务端进行校验导致业务数据在传输过程中被攻击者篡改或绕过业务逻辑。		1、对业务数据进行加密使攻击者无法辨认业务数据。 2、每个业务数据使用时间戳加签名方式进行校验有效应对重放攻击和中间人攻击。 3、业务数据服务端校验。
业务流程绕过（漏洞名称可根据	高危	由于程序逻辑不严谨或业务数据没有在服务端进行校验导致业务数据在传输过程	由于程序逻辑不严谨或逻辑太过复杂，导致一些逻辑分支不能正常处理或处理错误	1、对业务数据进行加密使攻击者无法辨认业务数据。 2、每个业务数据使用时间戳加签名方式进行校验

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

实际场景进行命名）		中被攻击者篡改或绕过业务逻辑。		有效应对重放攻击和中间人攻击。 3、业务数据服务端校验。
响应头信息泄露	低危	信息泄露指在网站页面或应用中泄露了敏感信息。通过这些信息，攻击者可进一步入侵服务器。（信息泄露包括不限于网站备份文件泄露、js 文件敏感信息泄露、物理路径泄露、中间件信息泄露、密钥泄露、Robots 文件存放敏感路径、内网 IP 泄露等）	由于服务端未进行限制，泄露了服务器信息	一些应用程序在稍后的响应中以清晰的形式返回提交给应用程序的密码。这种行为增加了攻击者捕获用户密码的风险 在响应包内屏蔽掉此类的信息。
测试页面、示例文件未删除	中危：如 tomcat session forexample 低危：若测试页面泄露大量敏感信息或可进一步利用可定级为中或高危，标准参考“敏感信息泄露”。	应用中存在遗留的过时文件、备份页面、渗透测试遗留文件、开发文件残留的测试文件等。	应用中存在遗留的过时文件、备份页面、渗透测试遗留文件、开发文件残留的测试文件等	1、 网站管理员严格检查 web 中可访问的路径下是否存在备份文件，常见备份文件后缀为.jsp.bak、.bak、.sql、.txt、等等。如果有这些文件，直接将该备份文件进行转移到其他目录或者直接删除即可。 2、 严格控制可网站可访问目录下的文件敏感度的存放问题，不要将

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

				敏感文件置于该目录。
安装文件未删除	根据泄露文件敏感程度进行定级，若安装文件未删除导致的系统重装可高危。	在服务器中存放应用安装包文件，攻击者如果拿到安装包的信息，就可能会知道当前服务器所安装的软件，来进行进一步的攻击。	在服务器中存放应用安装包文件，攻击者如果拿到安装包的信息，就可能会知道当前服务器所安装的软件，来进行进一步的攻击修复建	1、 网站管理员严格检查 web 中可访问的路径下是否存在备份文件，常见备份文件后缀为.jsp.bak、.bak、.sql、.txt、等等。如果有这些文件，直接将该备份文件进行转移到其他目录或者直接删除即可。 2、 严格控制可网站可访问目录下的文件敏感度的存放问题，不要将敏感文件置于该目录。
备份文件泄露	根据泄露备份文件敏感程度进行定级若备份文件中含有大量的系统源码可为高危。	备份文件泄露，在 web 服务中，常常不局限于网站的源代码泄露，网站的数据库备份文件，以及上传的敏感文件，或者一切正常备份，原则不允许访问的文件可被通过访问 web 路径进行下载得到，造成其信息泄露。有效的帮助	备份文件泄露，在 web 服务中，常常不局限于网站的源代码泄露，网站的数据库备份文件，以及上传的敏感文件，或者一切正常备份，原则不允许访问的文件可被通过访问 web 路径进行下载得到，造成其信息泄露。有效的帮助攻击者理解网站应用逻辑，为展开其他类型的攻击提供有利信息，降低攻击的难度，可以进一步获取其他敏感数据。	1、 网站管理员严格检查 web 中可访问的路径下是否存在备份文件，常见备份文件后缀为.jsp.bak、.bak、.sql、.txt、等等。如果有这些文件，直接将该备份文件进行转移到其他目录或者直接删除即可。 2、 严格控制可网站可访问目录下的文件敏感度的存放问题，不要将敏感文件置于该目录。

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

		攻击者理解网站应用逻辑，为展开其他类型的攻击提供有利信息，降低攻击的难度，可以进一步获取其他敏感数据。		
SVN 文件信息泄露	高危	在服务器上布署代码时。如果是使用 svn checkout 功能来更新代码，而没有配置好目录访问权限，则会存在此漏洞。黑客利用此漏洞，可以下载整套网站的源代码。使用 svn checkout 后，项目目录下会生成隐藏的.svn 文件夹（Linux 上用 ls 命令看不到，要用 ls -al 命令）。svn1.6 及以前版本会在项目的每个文件夹下都生成一个.svn 文件夹，里面包含了所有文	在服务器上布署代码时。如果是使用 svn checkout 功能来更新代码，而没有配置好目录访问权限，则会存在此漏洞。黑客利用此漏洞，可以下载整套网站的源代码。使用 svn checkout 后，项目目录下会生成隐藏的.svn 文件夹（Linux 上用 ls 命令看不到，要用 ls -al 命令）。svn1.6 及以前版本会在项目的每个文件夹下都生成一个.svn 文件夹，里面包含了所有文件的备份，文件名为 .svn/text-base/文件名.svn-base	1、不要使用 svn checkout 和 svn up 更新服务器上的代码，使用 svn export（导出）功能代替。 2、服务器软件（Nginx、apache、tomcat、IIS 等）设置目录权限，禁止访问.svn 目录。

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

		件的备份，文件名为 .svn/text-base/文件名.svn-base。		
webpack 源码泄露	中危	webpack 是一个 JavaScript 应用程序的静态资源打包器（module bundler）。它会递归构建一个依赖关系图（dependency graph），其中包含应用程序需要的每个模块，然后将所有这些模块打包成一个或多个 bundle。其中可能包含了 API、加密算法、管理员邮箱、内部功能等等。	webpack 是一个 JavaScript 应用程序的静态资源打包器（module bundler）。它会递归构建一个依赖关系图（dependency graph），其中包含应用程序需要的每个模块，然后将所有这些模块打包成一个或多个 bundle。大部分 Vue 等项目应用会使用 webpack 进行打包，如果没有正确配置，就会导致项目源码泄露，可能泄露的各种信息如 API、加密算法、管理员邮箱、内部功能等等	正常通过 webpack 来打包 vue 项目，放到线上的项目是可以通过 F12 控制台的 source 来直接获取到前端项目源码的。如果项目有需求不能泄露源码，或者你不想让别人看到你的源码，可以直接在项目路径下修改 config/index.js 中 build 对象 productionSourceMap: false。
.git 源码泄露	高危	在运行 git init 初始化代码库的时候，会在当前目录下面产生一个.git 的隐藏文	开发者因 Git 版本控制器使用不当造成源码泄露	删除指定 GIT 生成的各种文件，如”/ .git/index”等。

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

		件，用来记录代码的变更记录等等。在发布代码的时候，把.git 这个目录没有删除，直接发布了，通过这个文件可以用来恢复源代码。		
Robots 配置文件泄露	低危	搜索引擎可以通过 robots 文件可以获知哪些页面可以爬取，哪些页面不可以爬取。 Robots 协议是网站国际互联网界通行的道德规范，其目的是保护网站数据和敏感信息、确保用户个人信息和隐私不被侵犯，如果 robots.txt 文件编辑的太过详细，反而会泄露网站的敏感目录或者文件，比如网站后台路径，从而得知其使用的系统类型，从而有针对性地进行利	根据攻击者可通过发现 robots.txt 文件，收集网站的敏感目录或文件，从而有针对性的进行利用。	根据实际情况，进行如下对应的修复： 1、 User-agent: * 这里的*代表的所有的搜索引擎种类，*是一个通配符。 2、 Disallow: / 这里定义是禁止爬寻站点所有的内容。 3、 Disallow: /admin/ 这里定义是禁止爬寻 admin 目录下面的目录。 4、 Disallow: /ABC/ 这里定义是禁止爬寻 ABC 目录下面的目录。 5、 Disallow: /cgi-bin/*.htm 禁止访问/cgi-bin/目录下的所有以".htm"为后缀的 URL(包含子目录)。 6、 Disallow: /*?* 禁止访问网站中所有包含问号 (?) 的网址。 7、 Disallow:

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

		用。		/.jpg$ 禁止抓取网页所有的.jpg 格式的图片。 8、Disallow:/ab/adc.html 禁止爬取 ab 文件夹下面的 adc.html 文件。 9、 Allow: /cgi-bin/ 这里定义是允许爬寻 cgi-bin 目录下面的目录。 10、Allow: /tmp 这里定义是允许爬寻 tmp 的整个目录 11、Allow: .htm$ 仅允许访问以".htm"为后缀的 URL。 12、Allow: .gif$ 允许抓取网页和 gif 格式图片。 13、Sitemap: 网站地图 告诉爬虫这个页面是网站地图。
WEB .XML 配置文件泄露	低危，若遇到文件存在敏感信息参考敏感信息泄露定级标准。	直接在域名后面加上 WEB-INF/web.xml，据 web.xml 配置文件路径或通常开发时常用框架命名习惯，可找到其他配置文件或类文件路径。	直接在域名后面加上 WEB-INF/web.xml，据 web.xml 配置文件路径或通常开发时常用框架命名习惯，可找到其他配置文件或类文件路径。	设置目录权限，禁止访问且在配置文件中对敏感信息进行加密。
物理路径泄露	低危	攻击者可能通过泄露的物理路径发	应用中泄露出应用在主机中的绝对地址路径	1、媒体链接和超链接采用相对路径的表达方式；

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

		起进一步攻击。		2、报错信息中不对外输出网站物理路径等敏感信息。
中间件信息泄露	低危	通常在 HTTP 报文的响应头中存在的标志、版本号等信息均属于中间件的版本信息泄露漏洞。	应用报错时的缺省页面中包含中间件版本等信息。	如不必要建议将中间件版本信息进行隐藏或自定义系统错误页面统一返回报错至报错页面。
应用程序调试版本信息泄露	低危	Web 服务器未能正确处理异常请求导致 Web 服务器版本信息泄露，攻击者收集到服务器信息后可进行进一步针对性攻击。	错误页面 Web 应用服务器版本泄露	如不必要建议系统统一报错信息提示页面或规范系统调试功能禁止将系统报错调试信息返回前端。
密码返回前端	高危	服务器端将密码信息返回在响应数据包中或者在登录、验证等页面的隐藏域中存在密码信息。	服务器端将密码信息返回在响应数据包中或者在登录、验证等页面的隐藏域中存在密码信息。	用户名及密码尽可能不在客户端存储，若有必要，如 cookie 中暂存，应以加密方式存储。
js 文件敏感信息泄露	低危：若 js 中泄露大量敏感信息可为中、高危。	一些粗心的开发者将各式敏感信息存储在 JavaScript 脚本中，因为 JS 的特性，攻击者能够对这些信息尽收眼底，从而致	在前端 js 文件中，泄露了敏感信息，如账户、密码、文件路径等（包含账号密码、个人信息如：身份证号码、银行卡号）	如不必要建议及时将敏感信息清除。 同时禁止在代码中存储敏感数据：禁止在代码中存储如数据库连接字符串、口令和密钥之类的敏感数据，这样容易导致泄密。用于加密密

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

		使对 WEB 服务和用户隐私形成不一样程度的威胁。		钥的密钥可以硬编码在代码中。
敏感信息泄露	高危：如大量的（账号密码、密钥、证书、会话标识、License、授权凭据、隐私数据（包括但不限姓名、身份证号、银行卡号、家庭住址、病历、 保单信息）等高敏感度的信息。 中危：如存在他人的少量的手机号、姓名（50 条以下）等低敏感度的信息。 低危：如存在自身手机号、姓名等低敏感度的信息。	信息泄露指在网站页面或应用中泄露了敏感信息。通过这些信息，攻击者可进一步入侵服务器。（信息泄露包括不限于网站备份文件泄露、js 文件敏感信息泄露、物理路径泄露、中间件信息泄露、密钥泄露、Robots 文件存放敏感路径、内网 IP 泄露等）。	在数据传输过程或应用配置文件中泄露了敏感信息（包含账号密码、个人信息如：身份证号码、银行卡号等）	在应用配置文件中应去除敏感信息（包含账号密码、个人信息如：身份证号码、银行卡号等），若业务所需请在不影响业务的情况下进行后端脱敏处理。
敏感信息未模糊化	低危	敏感信息（包含账号密码、个人信息如：身份证号码、银行卡号等）在终端上展示时未进行模糊处理。	敏感信息（包含账号密码、个人信息如：身份证号码、银行卡号等）在终端上展示时未进行模糊处理。	建议在不影响业务的前提下必要，敏感信息在终端上展示时应做模糊处理，并在应用后端进行敏感字段脱敏处理，如部分内容以*方式传输及显示。
密钥泄露	低危	攻击者通过没用被有效隐藏的密钥可以发起进一步攻击。		1、如不必要建议及时将系统敏感信息清除。 2、 禁止密钥或帐号的口令以明文形式存储在数据

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

				库或者文件中：密钥或帐号的口令必须经过加密存储。例外情况，如果 Web 容器的配置文件中只能以明文方式配置连接数据库的用户名和口令，那么就不用强制遵循该规则，将该配置文件的属性改为只有属主可读写。
目录浏览（遍历）	默认中危：若存在敏感信息对照敏感信息的定级标准。	目录浏览漏洞是由于网站存在配置缺陷，存在目录可浏览漏洞，这会导致网站很多隐私文件与目录泄露，比如数据库备份文件、配置文件等，攻击者利用该信息可以更容易得到网站权限，导致网站被黑。	同于网站目录浏览，此漏洞不仅仅可遍历系统下 web 中的文件，而且可以浏览或者下载到系统中的文件，攻击人员通过目录遍历攻击可以获取系统文件及服务器的配置文件等等。一般来说，他们利用服务器 API、文件标准权限进行攻击。	目前存在该漏洞的常见中间件为 apache 和 IIS,以下列出其相关的修复方式： 1、 IIS 中关闭目录浏览功能：在 IIS 的网站属性中，勾去“目录浏览”选项，重启 IIS。 2、 Apache 中关闭目录浏览功能：打开 Apache 配置文件 httpd.conf，查找“Options Indexes FollowSymLinks”，修改为“ Options -Indexes”(减号表示取消，保存退出，重启 Apache。 3、 Nginx 中默认不会开启目录浏览功能，若您发现当前已开启该功能，可以编辑 nginx.conf 文件，删除如下两行：autoindex on;autoindex_exact_size on;重启

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

				Nginx。
内部 IP 地址泄露	低危	信息泄露指在网站页面或应用中泄露了敏感信息。通过这些信息，攻击者可进一步入侵服务器。（信息泄露包括不限于网站备份文件泄露、js 文件敏感信息泄露、物理路径泄露、中间件信息泄露、密钥泄露、Robots 文件存放敏感路径、内网 IP 泄露等）。	网站的内部 IP 地址，常常被攻击者通过信息收集，得到其内网的 IP 地址，对于渗透攻击，打下良好基础，如内网 Ip 地址段，IP 路由等等	如不必要建议及时将内网 IP 信息隐藏或使用域名进行替换。
服务器路径泄露	低危	检测到在服务器的响应内容中可能存在系统目录路径信息，如 /home,/var 或者 c:\等信息，这一般是由于目标 web 应用没	应用中泄露了网站根目录或敏感文件绝对路径等	如果是正常页面中包含路径信息，如果不需要该路径信息，***该信息。 如果是错误信息中包含路径信息，需要屏蔽应用程序错误信息。

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

		有处理好应用错误信息导致的目录路径信息泄露。 如果***者获取到这些信息，可以了解目标服务器目录结构，给***者带来便利，如上传文件到服务器的其他目录。		
IIS 短文件名	低危	此漏洞实际是由 HTTP 请求中旧 DOS 8.3 名称约定（SFN）的代字符（~）波浪号引起的。它允许远程攻击者在 Web 根目录下公开文件和文件夹名称（不应该可被访问）。攻击者可以找到通常无法从外部直接访问的重要文件，并获取有关应用程序基础结构的信息。	攻击者可以利用“~”字符猜解或遍历服务器中的文件名，或对 IIS 服务器中的.Net Framework 进行拒绝服务攻击。	1、CMD 关闭 NTFS 8.3 文件格式的支持 2、修改注册表禁用短文件名功能 3、关闭 Web 服务扩展- ASP.NET 4、升级 netFramework 至 4.0 以上版本

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

Apache tomacat 文件包含漏洞	高危	Apache 与 Tomcat 都是 Apache 开源组织开发的用于处理 HTTP 服务的项目，两者都是免费的，都可以做为独立的 Web 服务器运行。Apache Tomcat 服务器存在文件包含漏洞，攻击者可利用该漏洞读取或包含 Tomcat 上所有 webapp 目录下的任意文件，如：webapp 配置文件或源代码等。	该漏洞是由于 Tomcat AJP 协议存在缺陷而导致，攻击者利用该漏洞可通过构造特定参数，读取服务器 webapp 目录下的任意文件 （例如 webapp 配置文件，源代码等），经检验只能读取此目录下文件，不可遍历 。	1、 临时禁用 AJP 协议端口，在 conf/server.xml 配置文件中注释掉 2、 配置 ajp 配置中的 secretRequired 和 secret 属性来限制认证 3、 官方下载最新版下载地址：https://tomcat.apache.org/download-70.cgi https://tomcat.apache.org/download-80.cgi https://tomcat.apache.org/download-90.cgi 或 Github 下载：https://github.com/apache/tomcat/releases
Web Logic Server 远程代码执行漏洞	紧急	通过该漏洞，攻击者可以在未授权的情况下远程执行代码。攻击者只需要发送精心构造的 T3 协议数据，就可以获取目标服务器的权限。攻击者可利用该漏洞控制组件，影响数据的可用	攻击者利用 RMI 绕过 weblogic 黑名单限制，将加载的内容利用 readObject 解析，造成反序列化漏洞，该漏洞主要由于 T3 协议触发，所有开放 weblogic 控制台 7001 端口，默认开启 T3 服务，攻击者发送构造好的 T3 协议数据，获取目标服务器的权限。	1、通过 Nginx/Apache 配置反向代理的方式访问 Weblogic 应用，限制 Weblogic T3 的直接访问，此漏洞也将不能直接被利用。 2、强烈建议受影响的用户尽快升级更新 Oracle2018-04-18 日发布的安全补丁； 用户使用正版软件许可账号，可在

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

		性、保密性和完整性。		https://support.oracle.com 处下载 Oracle 官方补丁。
Nginx 整数溢出漏洞	高危	Nginx 是由俄罗斯的程序设计师 Igor Sysoev 所开发的一款轻量级 Web 服务器/反向代理服务器及电子邮件（IMAP/POP3）代理服务器。range filter module 是其中的一个范围过滤器模块。Nginx 0.5.6 版本至 1.13.2 版本中的 range filter 模块存在整数溢出漏洞。攻击者可利用该漏洞获取敏感信息。	在 Nginx 的 range filter 中存在整数溢出漏洞，可以通过带有特殊构造的 range 的 HTTP 头的恶意请求引发这个整数溢出漏洞，并导致信息泄露。	将 Nginx 升级到最新版本。 目前厂商已发布升级补丁以修复漏洞，补丁获取链接： http://mailman.nginx.org/pipermail/nginx-announce/2017/000200.html
Nginx 解析漏洞	高危	在旧版本的 Nginx 中，存在一个利用空字节注入的漏洞。利用这个漏洞，在任何使用 PHP_FastCgi 技术的服务器上，攻	nginx 在解析文件名的时候，遇到空字节会产生解析错误比如原本是 png 文件会当做 php 文件解析。	升级 Nginx 版本至最新版本，建议使用 WAF 防护。

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

		击者可以以 PHP 执行任何具有公共访问权限的文件。在有漏洞的 Nginx 版本中，URI 中的空字节是默认允许的（定义：ngx_http_request.h 头文件中的变量 zero_in_uri）。不是所有的模块在遇到有空字节的 URI 时都会拒绝执行，比如 FastCgi 模块就不会拒绝。 攻击过程:攻击者访问 http://site.com/test.jpg%00.php，达到以 PHP 来解析 test.jpg 的目的。如果攻击者能够控制装有低版本 nginx 的服务器上的文件内容(例如利用图片上传的方式)，就能够随心所欲的执行任意 PHP 代码，达到控		

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

		制网站服务器的目的。 影响版本： nginx 0.5.* nginx 0.6.* nginx 0.7 <= 0.7.65 nginx 0.8 <= 0.8.37		
IIS 解析漏洞	高危	漏洞影响 IIS7 及 IIS7.5 在使 FastCGI 方式调用 php 时，在 php.ini 里设置 cgi.fix_pathinfo=1 使得访问任意文件 URL 时，在 URL 后面添加“/x.php”等字符时，该文件被 iis 当 php 文件代码解析。	IIS 6.0 在处理含有特殊符号的文件路径时会出现逻辑错误，从而造成文件解析漏洞	升级 IIS 版本至最新版本。
HTTPS.SYS 远程代码执行	高危	Http.sys 是 Microsoft Windows 处理 HTTP 请求的内核驱动程序。HTTP.sys 会错误解析某些特殊构造的 HTTP 请求，导致远程代码执行漏洞。成功利用此漏洞后，攻击者可在 System 帐	Http.sys 是 Microsoft Windows 处理 HTTP 请求的内核驱动程序。HTTP.sys 会错误解析某些特殊构造的 HTTP 请求，导致远程代码执行漏洞。成功利用此漏洞后，攻击者可在 System 帐户上下文中执行任意代码。由于此漏洞存在于内核驱动程序中，攻击者也可以远程导致操作系统蓝屏。此次受影响	微软官方网站下载 ms15-034 的补丁包 下载地址： https://docs.microsoft.com/zh-cn/security-updates/Securitybulletins/2015/ms15-034

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

		户上下文中执行任意代码。由于此漏洞存在于内核驱动程序中，攻击者也可以远程导致操作系统蓝屏。此次受影响的系统中，Windows7、Windows8、WindowsServer 2008 R2 和 WindowsServer 2012 所带的 HTTP.sys 驱动均存在一个远程代码执行漏洞，远程攻击者可以通过 IIS7(或更高版本)服务将恶意的 HTTP 请求传递给 HTTP.sys 驱动，通过发送恶意的 HTTP 请求导致远程代码执行或操作系统蓝屏。	的系统中，Windows7、Windows8、WindowsServer 2008 R2 和 WindowsServer 2012 所带的 HTTP.sys 驱动均存在一个远程代码执行漏洞，远程攻击者可以通过 IIS7(或更高版本)服务将恶意的 HTTP 请求传递给 HTTP.sys 驱动，通过发送恶意的 HTTP 请求导致远程代码执行或操作系统蓝屏。	

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

JBOSS 远程代码执行	紧急	该漏洞位于 JBoss 的 HttpInvoker 组件中的 ReadOnlyAccessFilter 过滤器中，其 doFilter 方法在没有进行任何安全检查和限制的情况下尝试将来自客户端的序列化数据流进行反序列化，导致攻击者可以通过精心设计的序列化数据无需用户验证在系统上执行任意命令，获得服务器的控制权。	Jboss 文件下的 httpInvoker 组件中的 Readonly Accessfilter 过滤器中的 dofilter 没有限制来自客户端的序列化数据而进行反序列化。	建议及时更新 JBOSS 的版本到最新，如果暂时不能更新，则提供以下方案进行修复： 1、如果不需要 http-invoker.sar 组件，可直接删除 2、添加如下代码至 http-invoker.sar 下 web.xml 的 security-constraint 标签中，对 http invoker 组件进行访问控制。
Ueditor 远程文件抓取漏洞	高危	Ueditor 是百度开发的一个网站编辑器，目前已经不对其进行后续开发和更新，该漏洞只存在于该编辑器的.net 版本。其他的 php,jsp,asp 版本不受此 UEditor 的漏洞的影响，.net 存在任意文件上传，绕过文	在抓取远程数据源的时候未对文件后缀名做验证导致任意文件写入漏洞，黑客利用此漏洞可以在服务器上执行任意指令	1.目前临时的漏洞修复是建议，把文件上传目录设置无脚本执行权限，uploadvideo、uploadimage、catchimage、uploadscrawl、uploadfile、等等目录都设置上无脚本权限。 2.在百度 UEditor 官方没有出补丁前，设置图片目录为只读，禁止写入。 3.检查文件上传路径下是否有近期

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

		件格式的限制，在获取远程资源的时候并没有对远程文件的格式进行严格的过滤与判断。		上传的畸形图片；检查是否存在 asp，aspx 等类型危险文件。如果发现异常文件，请判断后及时删除。 4.修改程序的源代码，对 crawlerhandler 源文件进行文件上传格式的严格过滤与判断。 image、uploadscrawl、uploadfile、等等目录都设置上无脚本权限。 2.在百度 UEditor 官方没有出补丁前，设置图片目录为只读，禁止写入。 3.检查文件上传路径下是否有近期上传的畸形图片；检查是否存在 asp，aspx 等类型危险文件。如果发现异常文件，请判断后及时删除。 4.修改程序的源代码，对 crawlerhandler 源文件进行文件上传格式的严格过滤与判断。
jQuery 版本漏洞	低危	jQuery 是美国 John Resig 程序员的一套开源、跨浏览器的 JavaScript 库。该库简	据 NVD 描述：在大于或等于 1.2 且在 3.5.0 之前的 jQuery 版本中，即使执行了消毒（sanitize）处理，也仍会执行将来自不受信任来源的 HTML 传递给	临时解决方案： 暂时隐藏 jQuery 版本信息，避免被攻击者识别出版本号:注释版本信息以及正文内版本信息。 为应用系统制

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

		化了 HTML 与 JavaScript 之间的操作，并具有模块化、插件扩展等特点。jQuery 3.5.0 之前版本中存在跨站脚本漏洞，该漏洞源于 WEB 应用缺少对客户端数据的正确验证。攻击者可利用该漏洞执行客户端代码。	jQuery 的 DOM 操作方法（即 html()、.append() 等），从而导致 xss 漏洞。	定统一的、影响全局的危险字符黑名单，发现输入中存在危险字符时直接返回固定的错误页面。 正式解决方案： 升级 jQuery 至最新版本。
Shiro 远程代码执行	紧急：可以远程执行命令 低危：获取到了 defualt key 但是无法进一步利用	Shiro 对 rememberMe 的 cookie 做了加密处理，shiro 在 cookieRememberMeManaer 类中将 cookierememberMe 字段内容分别进行序列化、AES 加密、Base64 编码操作。但是，AES 加密的密钥 Key 被硬编码在代码里，意味着每个人通过源代码都能漏洞描述拿	攻击者通过使用有效的 rememberMe cookie 作为 Padding Oracle 攻击的前缀，然后构造 rememberMe 来执行 Java 反序列化攻击，最终可导致远程代码执行。	目前厂商已经发布了升级补丁以修复此安全问题，补丁获取链接：http://shiro.apache.org/download.html。

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

		到 AES 加密的密钥。因此，攻击者构造一个恶意的对象，并且对其序列化，AES 加密，base64 编码后，作为 cookie 的 rememberMe 字段发送。Shiro 将 rememberMe 进行解密并且反序列化，最终造成远程代码执行漏洞。		

Thinkphp 远程代码	紧急：可以远程执行命令	由于 ThinkPHP5 框架对控制器名没有进行足够的安全检测，导致在没有开启强制路由的情况下，攻击者构造特定的恶意请求，可以直接获取服务器权限。	由于框架对控制器名没有进行足够的检测导致在没有开启强制路由的情况下 getshell	1、升级 ThinkPHP 至安全版本
				2、在 think\App 类的 module 方法的获取控制器的代码后面加上
				if (!preg_match('/^[A-Za-z](\w|\.)*$/', $controller)) {
				throw new HttpException(404, 'controller not exists:' . $controller);
				}

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

fastjson 反序列化	紧急：可以远程执行命令	Fastjson 是一个 Java 语言编写的高性能功能完善的 JSON 库。它采用一种“假定有序快速匹配”的算法，把 JSON Parse 的性能提升到极致，是目前 Java 语言中最快的 JSON 库。Fastjson 接口简单易用，已经被广泛使用在缓存序列化、协议交互、Web 输出、Android 客户端等多种应用场景。fastjson<=1.2.68 版本能够通过期望类的某些子类绕过 AutoType 功能，进而造成反序列化远程代码执行漏洞。	攻击者准备 rmi 服务和 web 服务，将 rmi 绝对路径注入到 lookup 方法中，受害者 JNDI 接口会指向攻击者控制 rmi 服务器，JNDI 接口向攻击者控制 web 服务器远程加载恶意代码，执行构造函数形成 RCE。	升级至安全版本较低版本升级至最新版本 1.2.69 可能会出现兼容性问题，建议升级至特定 版本的 sec10 bugfix 版本，请参考以下链接尽快修复：https://repo1.maven.org/maven2/com/alibaba/fastjson/
Struts 2 远程代码执行	紧急：可以远程执行命令	struts2 是一个基于 MVC 设计模式的 Web 应用框架，它本质上相当于一个 servlet，	用户提交表单时，后端会将 OGNL 表达式%{value}进行解析	建议将 struts2 升级至最新版本。

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

		在 MVC 设计模式中，Struts2 作为控制器(Controller)来建立模型与视图的数据交互。不安全的配置行为等多种问题导致攻击者可以针对 struts2 框架进行远程代码执行，从而获取服务器权限。		
log4j 2.X 远程代码执行	紧急：可以远程执行命令	Log4j-2 中存在 JNDI 注入漏洞，当程序将用户输入的数据被日志记录时，即可触发此漏洞，此次漏洞是用于 Log4j2 提供的 lookup 功能造成的，该功能允许开发者通过一些协议去读取相应环境中的配置。但并未对输入进行严格的判断，从而造成攻击者可以在目标服务器上执行任意代码。	当 Java 应用程序将攻击者输入的数据，记入日志时（一般我们开发过程中，会使用 Log4J 记录重要的日志），Log4J 发现需要向 JNDI 发起请求，而攻击者将输入的数据指向自己构造的攻击服务器上的 LDAP 服务，这个服务在返回数据中植入了恶意代码（可执行脚本），服务端收到 LDAP 的响应数据并去执行，导致被攻击。	建议将 log4j 2 升级到最新版本。

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

工作漏洞收录规则-非金融版

漏洞名称	漏洞定级及说明	漏洞描述	漏洞原理	修复建议
启用不安全的HTTP方法	高危：PUT、DELETE方法可利用情况下。 中危：TRACE方法可利用的情况下（如导致XSS漏洞）。 低危：PUT、DELETE方法不可利用情况下（返回200但是没有实际执行）。	目标服务器启用了不安全的传输方法，如PUT、DELETE、TRACE等，这些方法表示可能在服务器上使用了WebDAV，由于dav方法允许客户端操纵服务器上的文件，如上传、修改、删除相关文件等危险操作，如果没有合理配置dav，有可能允许未授权的用户对其进行利用，修改服务器上的文件。	检查原始测试响应的“Allow”头，并验证是否包含下列一个或多个不需要的选项：DELTE,SEARCE,COPY，MOVE，PROPFIND，PROPPATCH，MKCOL，LOCK，UNLOCK，PUT。	1、在不影响业务的前提下，禁用不必要的HTTP方法（如PUT、DELETE）。 2、如果服务器不使用 WebDAV 可直接禁用，或为允许webdav的目录配置严格的访问权限，如认证方法，认证需要的用户名，密码。
点击劫持	低危	点击劫持是一种视觉上的欺骗手段，攻击者使用一个透明的、不可见的iframe，覆盖在一个网页上，然后诱使用户在该网页上进行操作，此时用户在不知情的	点击劫持是视觉欺骗，用户只看到了底层页面，与页面进行交互时却是与上层页面在交互。这是由于透明的iframe造成的，通过控制iframe的位置，导致上层页面的按钮等覆盖到下层上。	X-FRAME-OPTIONS是微软提出的一个http头，专门用来防御利用iframe嵌套的点击劫持攻击，并且在IE8、Firefox3.6、Chrome4以上的版本均能很好的支持。 这个头有三个值： DENY：拒绝任何域加载 SAMEORIGIN：允许同源域下加载 ALLOW-FROM：可以定义允许frame加载的页面地址。

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

		情况下点击了透明的 iframe 页面。通过调整 iframe 页面的位置，可以诱使用户恰好点击在 iframe 页面的一些功能性按钮上，攻击者常常配合社工手段完成攻击。		
后台页面公网暴露	低危	应用存在未限制公网访问的后台，攻击者可能通过登录网站管理后台篡改页面，或利用上传功能上传 webshell，导致服务器被控制。	后台管理界面（包括不限于：可操作管理多个账户，具有账号权限功能增删改权限的用户界面；可发布公告等内容管理的用户界面；可查询应用日志系统日志账户；可更改应用系统界面内容配置账户；）暴露在互联网上。	建议在不影响业务的前提下，将管理后台隐藏在非常规目录下或增加管理后台的访问限制。
CORS 跨域漏洞	低危	跨域资源共享（CORS）是一种浏览器机制，可实现对位于给定域外部的资源的受控访问。它扩展了同源策略（SOP）并增加了灵活性。但是，如果网站的 CORS 策略配置和实施不当，它也可能带来基于跨域的攻击。CORS 并不	浏览器的同源策略约束着不同源的资源交互，但这也带来诸多的不便，例如随着 WEB 应用的发展，有些网站由于自身业务的需求，需要实现一些跨域的功能，让不同域的页面之间能够相互访问各自页面的内容，而浏览器的同源策略会限制这种请求，因此需要采用 CORS 以实现跨域访问，这本身是一种功能。CORS（Cross-Origin Resource Sharing）	CORS 漏洞主要是由于配置错误而引起的。所以，预防漏洞变成了一个配置问题。下面介绍了一些针对 CORS 攻击的有效防御措施。

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

		是针对跨域攻击（例如跨站点请求伪造（CSRF））的保护措施。	即跨域资源共享，是用于绕过 SOP（同源策略）来实现跨域资源访问的一种技术，是 HTML5 提供的一种机制。	
目录穿越	高危：可直接获取到重要敏感数据（如服务器配置信息、数据库配置信息、密码等）。	目录穿越的目的旨在访问存在在网站根目录外面的文件或目录。通过浏览应用，攻击者可以寻找存储在 Web 服务器上的其他文件的相对路径，从而获取系统配置、数据库账号密码等敏感信息，为进一步攻击提供支持。	同于网站目录浏览，此漏洞不仅仅可遍历系统下 web 中的文件，而且可以浏览或者下载到系统中的文件，攻击人员通过目录遍历攻击可以获取系统文件及服务器的配置文件等等。一般来说，他们利用服务器 API、文件标准权限进行攻击。	1、对用户可控参数地输入进行过滤，禁止用户输入../等恶意字符。 2、文件 ID 使用随机数命名 3、文件路径保存至数据库，前端传入对应 ID，后端进行匹配，防止篡改。
水平越权	高危：可查看越权功能点敏感信息或进行相关操作。 中危：可修改的范围有限，不涉及敏感信息。 低危：查看范围有限，不涉及敏感信息。	攻击者在获得同一级别用户帐号后，可以利用一些方式绕过权限检查，访问或者操作到同一级别其他账户信息。	权限类型不变，权限 ID 改变，攻击者尝试访问与他拥有相同权限的用户的资源	在系统中，加入用户身份认证机制或者 token 验证
未授权访问	高危：可未授权访问管理员账号（可读可操作）。 中危：可未授权访问其他类型账号（可读不可操作，包含敏感信息）。 低危：可未授权访问其他类型账号	攻击者没有获取到登录权限或未授权的情况下，或者不需要输入密码，即可通过直接输入网站控制台主页面	攻击者没有获取到登录权限或未授权的情况下，或者不需要输入密码，即可通过直接输入网站控制台主页面地址，或者不允许查看的链接便可进行访问，同时进行操作	在系统中，加入用户身份认证机制或者 token 验证

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

	（可读不可操作，不包含敏感信息）。	地址，或者不允许查看的链接便可进行访问，同时进行操作。		
垂直越权	高危	攻击者在获得低权限用户帐户后，可以利用一些方式绕过权限检查，访问或者操作到原本无权访问的高权限功能。	越权访问，这类漏洞是指应用在检查授权（Authorization）时存在纰漏，使得攻击者在获得低权限用户帐后后，可以利用一些方式绕过权限检查，访问或者操作到原本无权访问的高权限功能。在实际的代码安全审查中，这类漏洞往往很难通过工具进行自动化检测，因此在实际应用中危害很大。其与未授权访问有一定差别。	1、对用户操作进行权限校验，防止通过修改参数进入未授权页面及进行非法操作。 2、在服务端对请求的数据和当前用户身份做校验检查。
用户账号重复	高危	系统存在用户账号重复情况，可以导致系统账号信息覆盖等逻辑安全问题。	1、在注册时，同时使用相同的用户名，在同一时间进行同步注册活动，再高并发的情况下，系统提示均已成功。 2、在注册时使用已注册的账号作为注册账号，通过修改返回数据包中生成的 ID 值来进行注册，仍可成功。	在用户注册、新建账号信息时。首先判断账号信息是否存在，若存在则无法新建该账号。
任意用户注册	高危	攻击者可绕过注册界面认证措施失效导致任意用户注册。如：批量用户注册可领取新用户红包进行“薅羊毛”。	未验证邮箱/手机号，目前很多应用为了方便用户记录自己的用户名与密码，都可以使用邮箱跟手机号作为登录用户名，因此很多应用在注册的时候就要求用户填写，一般情况下该应用都会发送激活信息，用户在收到激活信息后	对用户提交的注册信息进行校验，如邮箱，手机号等，同时一个账号限制只能注册一次。

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

			才能登录。然而有时候开发人员并不去审核邮箱/手机号是否有效，所以可以利用该缺陷，任意注册账号。我们可以通过抓取数据包，不断的将邮箱/手机号加一加一去爆破，这样如果线程够多，很可能能撑爆网站的数据库。	
用户名枚举	中危：可通过自动化工具批量枚举。	可通过自动化工具重放数据包，根据返回信息得到系统存在的用户名。	由于错误配置或设计缺陷，当向系统提交有效账户和无效账户时，服务器会有不同的响应。利用响应的不同，攻击者可以获取到系统已经存在的账户，可用于暴力破解，进一步获取账户的登录密码。	添加验证码机制抗重放攻击。
不安全的错误提示	低危	当输入正确的用户名错误的密码时提示密码错误，当输入不存在的用户名时提示用户名不存在。攻击者可根据提示信息进行用户名枚举发现系统存在的用户账号信息。	攻击者根据 Web 应用程序返回的错误提示信息如“用户不存在”和“密码错误”等即可枚举系统中存在的登录用户名，然后针对枚举出来的登录用户名，对其密码进行暴力破解	将系统提示信息统一为用户名或密码错误。
无账户锁定机制	低危	多次错误认证，系统并无账户锁定机制，可造成暴力破解攻击。	记录用户连续输入密码错误的次数，达到某个错误次数以后，比如说是 5 次以后，就锁定用户，暂时不让用户登录。等锁定时限以后，用户又有 5 次重新输入密码的机会。代码实现原理	当账户多次认证失败时结合业务情况锁定账户时间，防止攻击者进行恶意锁定攻击。

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

			是将用户名和输入错误的密码错误的次数记录到 reids 里，当用户登录成功后，清除该用户的登录错误的次数，重新计算。	
认证绕过（漏洞名称可根据具体场景自定义）	高危：场景：绕过除短信验证码之外的如密保问题。	攻击者可绕过某些认证措施造成直接或间接访问某些服务。	由于对登录的账号及口令校验存在逻辑缺陷，或再次使用服务器端返回的相关参数作为最终登录凭证，导致可绕过登录限制，如服务器返回一个 flag 参数作为登录是否成功的标准，但是由于代码最后登录是否成功是通过获取这个 flag 参数来作为最终的验证，导致***者通过修改 flag 参数即可绕过登录的限制！	根据具体绕过方式提出修复建议。
密码重设	高危	攻击者可以通过抓包篡改账号信息，构造密码充值链接等方式。绕过密码充值前的身份认证阶段，达到重置任意账户密码的目的。	重置密码本身没有问题，但是在重置密码中的验证机制不够完善。其产生的原因多种多样，最主要的原因是网站有逻辑上的漏洞，即没有做到用户、账号、验证码三者统一进行验证。	在服务端对请求的数据和当前用户身份做校验检查，若不匹配则拒绝密码重置请求。
系统存在弱口令风险	低危	修改密码处没有强度要求，导致用户可能设置弱口令增加系统风险。	弱口令”指的是：密码设置为“123456”、“666666”、“身份证后六位”、“密码同账号一致”等类似内容，非常容易被黑客暴力破解	修改密码处要求新密码符合以下规则： 1、大小写字母加上数字、特殊字符（3 选 2）。 2、密码长度最低 8 位限制，设置口令使用期限。 3、不允许出现 3 个连续或相同的数字以及字母。

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

密码修改无原密码校验机制	高危	修改密码时缺少原密码认证。若系统存在跨站请求伪造可结合该漏洞欺骗用户点击，攻击者即可修改密码。	后台没有对旧密码进行验证，就直接让输入新密码	在修改密码时增加认证原密码操作。
弱口令	高危	使用弱口令或系统默认口令。可导致任意用户登录获取相应权限。	服务器、中间件、应用等使用了默认口令，导致可被轻易猜解。例如数据库默认空口令，管理后台使用默认帐号密码	用户口令需满足以下要求： 1、大小写字母加上数字、特殊字符。 2、密码长度最低 8 位限制，设置口令使用期限。 3、不允许出现连续或相同的数字以及字母。
短信轰炸	高危	攻击者通过网站页面中所提供的发送短信验证码的功能处，通过对其发送数据包的获取后，进行重放，如果服务器短信平台未做校验的情况下，系统会一直发送短信，这样就造成了短信轰炸的漏洞，该漏洞会导致用户被恶意骚扰同时极大的造成了系统资源浪费。	攻击者通过网站页面中所提供的发送短信验证码的功能处，通过对其发送数据包的获取后，进行重放，如果服务器短信平台未做校验的情况时，系统会一直去发送短信，这样就造成了短信轰炸的漏洞	1、合理配置后台短信服务器的功能，对于同一手机号码，发送次数不超过 3-5 次，并且可对发送的时间间隔做限制。 2、页面前端代码编写时，加入禁止针对同一手机号进行的次数大于 N 次的发送，或者在页面中加入验证码功能，并且限制发送的时间间隔。 3、数据包内增加时间戳机制，防止数据包重放攻击。
短信验证码重复利用	中危	发送短信验证码可重复使用。如：登录接口验证码重复利用可导致暴力	由于未设置验证码的失效时间，在进行输入时没有对验证码进行验证，导致验证码只要可使用就可以通过验证，导致可以多	1、服务端完成一次包含验证的请求后及时删除验证码相应。 2、将每一次请求验证码的返回值进行一次 MD5 运算防止返回相同的验证码。

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

		破解等危害。	次利用进行操作	
短信验证码时效性缺陷	中危	验证码时效性缺陷导致验证码长时间未校验后依然可以使用，攻击者结合弱复杂度验证码可以对验证码进行爆破。		1、对验证码的安全时效时间进行安全限制，一般限制 30 秒或者 50 秒之间失效。 2、对于同一 IP 在同一时间进行多次的验证码请求频率上做安全防护，限制 1 分钟请求的次数或者是 10 分钟内的请求次数。 3、对于图片验证码的图片进行噪点渲染，防止图片被 OCR 自动识别。
短信内容可控	高危：短信内容可控且接收人可控 中危：短信内容可控且接收人不可控	短信内容可控且接收人可控的情况下，攻击者可利用该漏洞进行钓鱼欺骗、恶意骚扰。	攻击者在通过修改数据请求包中的数据或 response 中的返回数据，从而达到修改需要发送的内容	1、在不影响业务的前提下，限制短信接收人为当前用户。 2、禁止任意用户编辑短信内容。定制短信内容需要权限审核校验。
短信验证码返回到前端	高危	由于验证码直接返回前端，通过该漏洞攻击者可以注册任意用户，重置已注册用户密码，修改绑定信息等高危操作，对用户造成一定影响。	在重置密码流程中获取验证时可能服务器会把验证码返回给客户端，造成修改任意用户密码漏洞	禁止将短信验证码回显至前端，验证码只存于服务端中。
短信验证码机制绕过（漏洞名称可根据具体场景自定	高危：通过其他手段绕过验证码机制以达到登录、修改密码等目的，如万能验证码	可通过前端修改数据包或其他方法绕过短信验证码机制。攻击者绕过短信验证码进而可直接注册、登录、修改密码等功能。造成任意	短信验证码可被绕过，执行重置密码、登陆等其他操作。	1、验证码认证成功或失败状态系统后端同步，防止中间人攻击篡改认证失败数据包。 2、当用户验证码校验失败时，及时删除该用户 session，防止利用他人验证码。 3、关键操作每提交一次请求，应发送新的短信验证码，并且不可继续使用旧的验证码。

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

义）。		用户注册，重置任意用户密码等危害。		
邮件轰炸	高危	应用系统未限制邮件的发送次数和频率，造成短时间内大量邮件发送至接收者邮箱，造成大量垃圾邮件，甚至导致邮件阻塞，无法正常接收邮件。	应用系统未限制邮件的发送次数和频率，造成短时间内大量邮件发送至接收者邮箱，造成大量垃圾邮件。	1、合理配置后台邮件服务器的安全策略，对于同一邮箱，发送次数不超过 3-5 次，并且可对发送的时间间隔做限制。 2、页面前端代码编写时，加入禁止针对同一邮箱进行的次数大于 N 次的发送，或者在页面中加入验证码功能，并且限制发送的时间间隔。
邮件内容可控	高危：短信内容可控且接收人可控 中危：短信内容可控且接收人不可控	短信内容可控且接收人可控的情况下，攻击者可利用该漏洞进行钓鱼欺骗、恶意骚扰。	攻击者在通过修改数据请求包中的数据或 response 中的返回数据，从而达到修改需要发送的内容	短信验证码应只以短信方式发送到指定手机号，不再客户端进行发送和返回。
邮件验证码重复利用	中危	发送邮件验证码可重复使用。如：重置密码接口验证码重复利用可导致暴力破解等危害。	由于未设置验证码的失效时间，在进行输入时没有对验证码进行验证，导致验证码只要可使用就可以通过验证，导致可以多次利用进行操作	1、服务端完成一次包含验证的请求后及时删除验证码相应。 2、将每一次请求验证码的返回值进行一次 MD5 运算防止返回相同的验证码。
前端验证码生成机制可控	中危	攻击者通过构造特殊 payload、URL 参数链接导致验证码可控。造成验证码功能失效，可导致暴力破解、任意用户注册等逻辑问题。	在前端生成验证码时制作了简单的客户端验证，使得修改前端 js 代码，从而达到修改前端验证码生成机制，再发送请求时，连同带有修改后的代码参数进行提交，从而使得验证码过于简单，达到攻击者的目的	图形验证码采用随机算法且生成不受任何 API 接口参数等其他因素影响。

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

图形验证码前端显示	中危	图形验证码数值在返回包中返回前端(可通过自动化程序输入验证码，导致验证码无效，导致防护失效) 。	图形验证码数值在返回包中返回前端(可通过自动化程序输入验证码，导致验证码无效，导致防护失效)	禁止将验证码返回给客户端。
图形验证码可自动识别	中危	在破解验证码中需要用到的知识一般是 像素，线，面等基本 2 维图形元素的处理和色差分析，简单的图形验证码可经过一些工具进行识别。	在破解验证码中需要用到的知识一般是像素，线，面等基本 2 维图形元素的处理和色差分析，简单的图形验证码可经过一些工具进行识别	采取一定的干扰措施且不可预测，如字体倾斜，加背景噪点、横线等。
图形验证码机制绕过（漏洞名称可根据具体场景自定义）	中危	可通过自动化图形验证码识别程序进行自动化操作。导致暴力破解等逻辑漏洞。	图形验证码可被绕过，执行暴力破解、短信轰炸等自动化攻击操作。	图形验证码随机生成且图形字符都有粘连部分、不使用规则字符，验证码的各个部分使用不同比例的缩放或者旋转。
图形验证码重复利用	中危	图形验证码可重复使用。如：登录接口验证码重复利用可导致暴力破解。	由于未设置验证码的失效时间，在进行输入时没有对验证码进行验证，导致验证码只要可使用就可以通过验证，导致可以多次利用进行操作	1、服务端完成一次包含验证的请求后及时销毁并生成新的验证码。 2、将每一次请求验证码的返回值进行一次 MD5 运算防止返回相同的验证码。

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

cookie 缺少 http-only 属性	低危：无登录功能或未提供账号的不做测试。	Cookie 信息泄露是 Cookie HttpOnly 配置缺陷引起的，在设置 Cookie 时，可以设置的一个属性，如果 Cookie 没有设置这个属性，该 Cookie 值可以被页面脚本读取。	由于会话 cookie 不包含“HttpOnly”属性，因此注入点的恶意脚本可能访问此 cookie，并窃取它的值。任何存储在会话令牌中的信息都可能被窃取，并在稍后用于身份盗窃或用户伪装。	建议设置 Cookie HttpOnly 安全属性。 jsp 参考代码如下： response.setHeader("SET-COOKIE", "user=" + request.getParameter("cookie") + "; HttpOnly"); PHP 中的设置如下： PHP5.2 以上版本已支持 HttpOnly 参数的设置，同样也支持全局的 HttpOnly 的设置，在 php.ini 中设置 session.cookie_httponly，设置其值为 1 或者 TRUE，来开启全局的 Cookie 的 HttpOnly 属性。 对于 PHP5.1 以前版本以及 PHP4 版本的话，则需要通过 header 函数来设置： <?php header("Set-Cookie: hidden=value; httpOnly"); ?>
cookie 缺少 secure 属性	低危：该漏洞仅针对 https 协议，没有登录功能或未提供账号的不做测试。	若加密会话（SSL）中未配置了 Secure 属性。那么任何以明文形式发送到服务器的 Cookie、会话令牌或用户凭证之类的信息都可能被窃取，并在稍后用于身份盗窃或用户伪装。	由于会话 cookie 不包含“secure”属性，所以用户可以通过未加密的 http 协议传输 Cookie,可能造成用户信息被窃听。	1、若系统只支持 HTTPS 协议建议系统直接增加 Secure 安全属性。 2、若系统需要同时兼容 HTTP、HTTPS 协议建议系统根据代码判断后，增加 Secure 安全属性。
会话标识固定	中危	在用户进入登录页面，但还未登录时，即产生了一个 session，用户登录后，session 的 id 未改变。即系统在登	在用户进入登录页面，但还未登录时，就已经产生了一个 session,用户输入信息，登录以后，session 的 id 不会改变，也就是说没有建立新 session，原来的 session 也没有被	在用户提供的认证信息（例如用户名和密码）、相应的权限级别发生变化时，服务器端应重新生成 SessionID，并强制失效之前的会话。

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

		录后没有建立新 session，原来的 session 也没有被销毁。攻击者事先访问系统并建立一个会话，诱使受害者使用此会话登录系统，然后攻击者再使用该会话访问系统即可登录受害者的账户。	销毁）。攻击者事先访问系统并建立一个会话，诱使受害者使用此会话登录系统，然后攻击者再使用该会话访问系统即可登录受害者的账户	
会话无超时失效机制	低危	系统登录后长时间未操作或会话存活时间过长，将可能会导致敏感信息泄露，登录会话被他人操作等危害。	用户退出系统后，服务器端 Session 未失效，攻击者可利用此 Session 向服务器继续发送服务请求。	若系统无会话超时机制，建议系统增加会话超时机制并控制在合理且安全的时间范围内，推荐会话生命周期为 30 分钟。
失效的会话注销	中危	系统登录后抓取数据包，当注销会话后重放该数据包依然能够完成当前数据包请求。可造成信息泄露等危害，存在风险。	用户退出系统后，服务器端 Session 未失效，攻击者可利用此 Session 向服务器继续发送服务请求。	会话状态信息应与服务端进行同步。当用户会话注销后及时将服务端会话信息清除。
会话信息泄露	中危	会话敏感信息以直接或间接方式泄露 如：用户名、密码等敏感信息存储在		根据会话信息泄露位置及时清除泄露敏感信息。对于会话信息存储 Cookie 中变更 Cookie 认证方式。

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

		Cookie 信息中或 Session、Cookie 等信息直接存在前端源代码、数据包内等。		
反射型跨站脚本攻击	中危	跨站脚本攻击,它指的是恶意攻击者往 Web 页面里插入恶意 html 代码，当用户浏览该页之时，嵌入其中 Web 里面的 html 代码会被执行，从而达到恶意用户的特殊目的，而反射型跨站脚本攻击涉及的功能点多为：URL 参数需要在页面显示的功能点都可能存在反射型跨站脚本攻击，例如站内搜索、查询功能点。	跨站脚本攻击,它指的是恶意攻击者往 Web 页面里插入恶意 html 代码，当用户浏览该页之时，嵌入其中 Web 里面的 html 代码会被执行，从而达到恶意用户的特殊目的，而反射型跨站脚本攻击涉及的功能点多为：URL 参数需要在页面显示的功能点都可能存在反射型跨站脚本攻击，例如站内搜索、查询功能点。	1、输入验证：某个数据被接受为可被显示或存储之前，使用标准输入验证机制，验证所有输入数据的长度、类型、语法以及业务规则。 2、输出编码：数据输出前，确保用户提交的数据已被正确进行 entity 编码，建议对所有字符进行编码而不仅局限于某个子集。 3、明确指定输出的编码方式：不要允许攻击者为你的用户选择编码方式(如 ISO 8859-1 或 UTF 8) 4、注意黑名单验证方式的局限性：仅仅查找或替换一些字符(如"<" ">"或类似"script"的关键字)，很容易被 XSS 变种攻击绕过验证机制。
存储型跨站脚本攻击	高危	跨站脚本攻击,它指的是恶意攻击者往 Web 页面里插入恶意 html 代码，当用户浏览该页之时，嵌入其中 Web 里面的 html 代码会被执行，从而达到恶意	跨站脚本攻击,它指的是恶意攻击者往 Web 页面里插入恶意 html 代码，当用户浏览该页之时，嵌入其中 Web 里面的 html 代码会被执行，从而达到恶意用户的特殊目的，而存储型跨站脚本攻击涉及的功能点多为：用户输入的文本信息保存到数据	1、输入验证：某个数据被接受为可被显示或存储之前，使用标准输入验证机制，验证所有输入数据的长度、类型、语法以及业务规则。 2、输出编码：数据输出前，确保用户提交的数据已被正确进行 entity 编码，建议对所有字符进行编码而不仅局限于某个子集。 3、明确指定输出的编码方式：不要允许攻击者为你的用户选择编码方式(如 ISO 8859-1 或 UTF 8) 4、注意黑名单验证方式的局限性：

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

		用户的特殊目的，而存储型跨站脚本攻击涉及的功能点多为：用户输入的文本信息保存到数据库中，并能够在页面展示的功能点，例如用户留言、发送站内消息、个人信息修改等功能点。	库中，并能够在页面展示的功能点，例如用户留言、发送站内消息、个人信息修改等功能点。	仅仅查找或替换一些字符(如"<" ">"或类似"script"的关键字)，很容易被 XSS 变种攻击绕过验证机制。
DOM 型跨站脚本攻击	中危	跨站脚本攻击,它指的是恶意攻击者往 Web 页面里插入恶意 html 代码，当用户浏览该页之时，嵌入其中 Web 里面的 html 代码会被执行，从而达到恶意用户的特殊目的，而基于 DOM 跨站脚本攻击涉及的功能点：涉及 DOM 对象的页面程序，包括（不限这些）：document.URL document.URLUnencoded document.location document.referrer window.loca	跨站脚本攻击,它指的是恶意攻击者往 Web 页面里插入恶意 html 代码，当用户浏览该页之时，嵌入其中 Web 里面的 html 代码会被执行，从而达到恶意用户的特殊目的，而基于 DOM 跨站脚本攻击涉及的功能点：涉及 DOM 对象的页面程序,包括(不限这些）：document.URL document.URLUnencoded document.location document.referrer window.location	1、输入验证：某个数据被接受为可被显示或存储之前，使用标准输入验证机制，验证所有输入数据的长度、类型、语法以及业务规则。 2、输出编码：数据输出前，确保用户提交的数据已被正确进行 entity 编码，建议对所有字符进行编码而不仅局限于某个子集。 3、明确指定输出的编码方式：不要允许攻击者为你的用户选择编码方式(如 ISO 8859-1 或 UTF 8) 4、注意黑名单验证方式的局限性：仅仅查找或替换一些字符(如"<" ">"或类似"script"的关键字)，很容易被 XSS 变种攻击绕过验证机制。

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

		tion		
跨站请求伪造 CSRF	中危	攻击者使用 CSRF 攻击能够强迫用户向服务器发送请求，导致用户信息被迫修改，甚至可引发蠕虫攻击。如果恶意用户能够知道网站管理后台某项功能的 URL，就可以直接攻击管理员，强迫管理员执行恶意用户定义的操作。	攻击者在用户浏览网页时，利用页面元素（例如 img 的 src），强迫受害者的浏览器向 Web 应用服务器发送一个改变用户信息的 HTTP 请求从而达到篡改用户信息的目的。	1、通过 referer 判断页面来源进行 CSRF 防护，该方式无法防止站内 CSRF 攻击及 referer 字段伪造。 2、重要功能点使用动态验证码进行 CSRF 防护。 3、通过 token 方式进行 CSRF 防护
SQL 注入	高危：利用 SQL 注入可以进行拖库、删库、提权、写马等情况。 中危：只可以获取到数据库名，表名等信息，无法进一步获取到字段内容的情况下。	SQL 注入攻击包括通过输入数据从客户端插入或“注入”SQL 查询到应用程序。一个成功的 SQL 注入攻击可以从数据库中获取敏感数据、修改数据库数据（插入/更新/删除）、执行数据库管理操作（如关闭数据库	攻击者通过 web 应用程序利用 SQL 语句或字符串将非法的数据插入到服务端数据库中，获取数据库的用户管理权限，然后将数据库管理用户权限提升至操作系统管理用户权限，控制服务器操作系统，获取重要的信息和机密文件。	1、使用预编译处理输入参数：要防御 SQL 注入，用户的输入就不能直接嵌套在 SQL 语句当中。使用参数化的语句，用户的输入就被限制于一个参数当中。 2、输入验证：检查用户输入的合法性，以确保输入的内容为正常的数据。 3、错误消息处理：防范 SQL 注入，还要避免出现一些详细的错误消息，恶意攻击者往往会利用这些报错信息来判断后台 SQL 的拼接形式。

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

		管理系统）、恢复存在于数据库文件系统中的指定文件内容，在某些情况下能对操作系统发布命令。		
框架注入	高危	框架注入是将 frame 或 iframe 标签嵌入到被攻击的网站上，进而修改站点页面。被嵌入的页面包含恶意代码，可能诱惑用户登录，获取合法的登录凭证。 主要危害： [1]恶意篡改网页内容。 [2]网页挂马。 [3]网站钓鱼攻击	注入攻击指一种攻击手段，黑客通过把 HTML 代码输入一个输入机制(例如缺乏有效验证限制的表格域)来改变网页的动态生成的内容。一个恶意黑客(也被称为破裂者 cracker)可以利用这种攻击方法来非法获取数据或者网络资源。当用户进入一个有命令注入漏洞的网页时，他们的浏览器会通译那个代码，而这样就可能会导致恶意命令掌控该用户的电脑和他们的网络。	一般性的建议： 过滤客户端提交的危险字符，客户端提交方式包含 GET、POST、COOKIE、User-Agent、Referer、Accept-Language 等，其中危险字符如下： [1] | [2] & [3] ; [4] $ [5] % [6] @ [7] ’ [8] ″ [9] [10] () [11] + [12] CR [13] LF [14] , [15] . [16] script [17] document [18] eval 开发语言的建议： [1]严格控制输入： Asp:request Php:$_GET、$_POST、$_COOKIE、$_SERVER Jsp:request.getParameter、request.getCookies Asp.net:Request.QueryString、Form、Cookies、SeverVaiables 客户端提交的变量一般从以上函数获得，严格限制提交的数据长度、类

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

				型、字符集。 [2]严格控制输出： HtmlEncode：对一段指定的字符串应用 HTML 编码。 UrlEncode：对一段指定的字符串 URL 编码。 XmlEncode：将在 XML 中使用的输入字符串编码。 XmlAttributeEncode：将在 XML 属性中使用的输入字符串编码 escape：函数可对字符串进行编码 decodeURIComponent：返回统一资源标识符的一个已编码组件的非编码形式。 encodeURI：将文本字符串编码为一个有效的统一资源标识符 (URI)。 以下两种方法可用于防止框架注入漏洞 [1]如果应用程序不要求不同的框架互相通信，就可以通过完全删除框架名称、使用匿名框架防止框架注入。但是，因为应用程序通常都要求框架之间相互通信，因此这种方法并不可行。 [2]使用命名框架，但在每个会话中使用不同的框架，并且使用无法预测的名称。一种可行的方法是在每个基本的框架名称后附加用户的会话令牌，如 main_display。
链接注入	高危	链接注入是将某个 URL 嵌入到被攻击的网站上，进而修改站点页面。被嵌入的 URL 包含恶意代码，可能窃取正常用户的用户名、密码，也可能窃取或操纵认证会话，以合法用户的身份执行相	改站点内容的行为，其方式为将外部站点的 URL 嵌入其中，或将有易受攻击的站点中的脚本的 URL 嵌入其中。将 URL 嵌入易受攻击的站点中，攻击者便能够以它为平台来启动对其他站点的攻击，以及攻击这个易受攻击的站点本身	一般性的建议： 过滤客户端提交的危险字符，客户端提交方式包含 GET、POST、COOKIE、User-Agent、Referer、Accept-Language 等，其中危险字符如下： [1] | [2] & [3] ; [4] $ [5] % [6] @ [7] ’ [8] ″ [9]

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

		关操作。下边PHP 代码为例，做简要的分析。 /* 实例代码 */ $str = $_GET['name']; echo $str; 上述代码中变量$str,接受GET 方式传递的数据，并未对危险字符做过滤，假如客户端提交“Link_Injecting”，那么将在浏览器内引用“1.htm”。 主要危害： [1]获取其他用户 Cookie 中的敏感数据。 [2]屏蔽页面特定信息。 [3]伪造页面信息。 [4]拒绝服务攻击。 [5]突破外网内网不同安全设置。		[10] () [11] + [12] CR [13] LF [14] , [15] . [16] script [17] document [18] eval 开发语言的建议： [1]严格控制输入： Asp:request Php:$_GET、$_POST、$_COOKIE、$_SERVER Jsp:request.getParameter、request.getCookies Asp.net:Request.QueryString、Form、Cookies、SeverVaiables 客户端提交的变量一般从以上函数获得，严格限制提交的数据长度、类型、字符集。 [2]严格控制输出： HtmlEncode：对一段指定的字符串应用 HTML 编码。 UrlEncode：对一段指定的字符串 URL 编码。 XmlEncode：将在 XML 中使用的输入字符串编码。 XmlAttributeEncode：将在 XML 属性中使用的输入字符串编码 escape：函数可对字符串进行编码 decodeURIComponent：返回统一资源标识符的一个已编码组件的非编码形式。 encodeURI：将文本字符串编码为一个有效的统一资源标识符 (URI)。 以下两种方法可用于防止框架注入漏洞 [1]如果应用程序不要求不同的框架互相通信，就可以通过完全删除框架名称、使用匿名框架防止框架注入。但是，因为应用程序通常都要求框架之间相互通信，因此这种方法并不可行。

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

				[2]使用命名框架，但在每个会话中使用不同的框架，并且使用无法预测的名称。一种可行的方法是在每个基本的框架名称后附加用户的会话令牌，如 main_display。
Xpath 注入	高	XPath 注入攻击是指利用 XPath 解析器的松散输入和容错特性，能够在 URL、表单或其它信息上附带恶意的 XPath 查询代码，以获得权限信息的访问权并更改这些信息。	XPath 注入攻击是指利用 XPath 解析器的松散输入和容错特性，能够在 URL、表单或其它信息上附带恶意的 XPath 查询代码，以获得权限信息的访问权并更改这些信息。	XPath 攻击防御可参考如下： 1. 数据提交到服务器上端，在服务端正式处理这批数据之前，对提交数据的合法性进行验证。 2. 检查提交的数据是否包含特殊字符，对特殊字符进行编码转换或替换、删除敏感字符或字符串。 3. 对于系统出现的错误信息，以 IE 错误编码信息替换，屏蔽系统本身的出错信息。 4. 参数化 XPath 查询，将需要构建的 XPath 查询表达式，以变量的形式表示，变量不是可以执行的脚本。如下代码可以通过创建保存查询的外部文件使查询参数化：declare variable $loginID as xs：string external； declare variable $password as xs：string external；//users/user[@loginID=$loginID and @password= $password]。 5. 通过 MD5、SSL 等加密算法， 对于数据敏感信息和在数据传输过程中加密， 即使某些非法用户通过非法手法获取数据包，看到的也是加密后的信息。
XML 外部实体注入	高危	XML 是标准通用标记语言（SGML）的子集，非常适合 Web 传输。XML 提供统一的方法来描述和交换独立于应用程序或供应商的结构化数据。发现目前一些普遍	可扩展标记语言 XML 提供统一的方法来描述和交换独立于应用程序或供应商的结构化数据，如果在查询或者插入时，没有对用户的输入进行过滤或者转义，则可以修改 XML 数据格式，改变 XML 节点，造成 xml 注入。	1、严格检查用户输入的字符 2、检查使用的底层 XML 解析库，使用 JAVA 语言提供的禁用外部实体的方法：DocumentBuilderFactory dbf =DocumentBuilderFactory.newInstance();dbf.setExpandEntityReferences(false) 3.、操作 XML 时对格式字符进行转义处理

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

		使用 xml 的场景中都存在一种古老的 XML 实体注入漏洞，使得攻击者可能可以任意访问服务器以及应用所在网络的任何资源。		
CRLF 注入	中危	在 HTTP 当中 HTTP 的 Header 和 Body 之间就是用两个 crlf 进行分隔的，如果能控制 HTTP 消息头中的字符，注入一些恶意的换行，这样就能注入一些会话 cookie 和 html 代码，所以 CRLF injection 又叫做 HTTP response Splitting，简称 HRS。CRLF 漏洞可以造成 Cookie 会话固定和反射型 XSS(可过 waf)的危害，注入 XSS 的利用方式：连续使用两次%0d%0a 就会造成 header 和	CRLF 注入又叫 HTTP 响应拆分 / 截断（HTTP Response Splitting）简称 HRS。HRS 漏洞存在的前提是 ：url 当中输入的字符会影响到文件，比如在重定位当中可以尝试使用 %0d%0a 作为 CRLF。一般网站会在 HTTP 头中加上 Location: http://baidu.com 的方式来进行 302 跳转，所以我们能控制的内容就是 Location: 后面的 XXX 网址，对这个地址进行污染。	服务端收到前端过来的参数，在加入 Location 之前，需要过滤 \r 、\n 之类的行结束符，避免输入的数据污染其它 HTTP 首部字段。

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

		body 之间的分离，就可以在其中插入 xss 代码形成反射型 xss 漏洞。		
代码注入	高危	代码注入可以向系统可执行脚本中写入一句话木马，攻击者可以构造 payload 访问被写入文件执行系统命令，则该脚本即成为后门文件。	用户输入的恶意代码被服务器直接解析执行，从而导致攻击者可以对服务器注入任意代码。常见的有命令执行（有回显的情况用的多）、反弹 shell、写入 webshell、注入内存马等风险操作。	对传入参数进行严格控制，过滤特殊字符、重点关注 writeconfig()等写入函数。
远程命令执行	高危	部分 web 程序提供了某些命令执行等操作，那么 Web 底层就会调用系统命令，如果系统没有针对用户输入的命令进行限制、过滤则会造成命令执行漏洞。攻击者可以直接执行系统命令，造成窃取敏感信息，严重的可直接控制服务器。	用户通过浏览器提交执行命令，由于服务器端没有针对执行函数做过滤，导致在没有指定绝对路径的情况下就执行命令，可能会允许攻击者通过改变 $PATH 或程序执行环境的其他方面来执行一个恶意构造的代码。	1、在进入执行命令的函数/方法之前，对参数进行过滤，对敏感字符进行转义。 2、在使用动态函数之前，确保使用的函数是指定的函数之一。
反序列化漏洞	高危	Java 反序列化即逆过程，由字节流还原成对象。ObjectInputStream 类的 readObject(	Java 序列化就是把对象转换成字节流，便于保存在内存、文件、数据库中，Java 中的 ObjectOutputStream 类的 writeObject()	根据具体反序列化组件出现位置提出修复建议： 如 Weblogic 反序列化修复： 1、升级 JDK 版本。由于 Java 在今年一月份以后更新了反序列化防御接口，可以缓解反序列化漏洞的影响。 2、升级 WebLogic、删除不需要的页

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

		)方法用于反序列化。Apache Commons Collections 允许链式的任意的类函数反射调用。攻击者通过允许 Java 序列化协议的端口，把攻击代码上传到服务器上，再由 Apache Commons Collections 里的 Transformed Map 来执行。	方法可以实现序列化。Java 反序列化即逆过程，由字节流还原成对象。ObjectInputStream 类的 readObject()方法用于反序列化。Apache Commons Collections 允许链式的任意的类函数反射调用。攻击者通过允许 Java 序列化协议的端口，把攻击代码上传到服务器上，再由 Apache Commons Collections 里的 TransformedMap 来执行	面，清理不安全的第三方库。
文件包含漏洞	高危	文件包含函数加载的参数没有经过过滤或严格定义，可以被用户控制，包含其他恶意文件，导致了执行非预期代码同时攻击者可以读取系统配置文件获取数据库密码。	文件包含漏洞属于代码注入漏洞，为了减少重复代码的编写，引入了文件包含函数，通过文件包含函数将文件包含进来，直接使用包含文件的代码	1、严格检查变量是否初始化。 2、严格控制文件包含参数是否可控，同时过滤特殊字符。参数中不允许出现../类似的跳转字符。 3、同时系统对于 PHP 伪协议进行过滤和限制。
SSL/TLS 安全性测试	中危	检测系统使用 SSL/TLS 协议是否符合安全配置规范、是否使用 PFS 规范的加密套件、当前域名与所配置证书是否匹配等。		根据检测出 SSL/TLS 中漏洞位置提出修复建议 如系统使用 SSL v2 协议，此协议存在（DROWN）攻击，建议系统使用 TLS v1.2 为主要协议，同时推荐系统使用 HTTPS 最佳安全实践。

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

敏感信息未特殊加密（针对 https 协议）	低危	网站没有对传输的用户名、密码、身份证号、银行卡号等个人敏感信息进行特殊加密，这样认证会话信息等敏感数据在网络中很容易被嗅探到并破解。	敏感信息未经加密进行传输	建议对敏感字段进行特殊加密如 hash+salt 的方式，避免使用 MD5、Base64 等弱编码。
敏感信息明文传输（针对 http 协议）	中危	敏感信息使用明文传输的方式存在嗅探风险，如用户名、密码、身份证号、银行卡号等个人敏感信息，攻击者在局域网中嗅探网络流量，可轻易窃取账号信息。	系统采用 HTTP 访问模式，在页面上的操作全部采用 HTTP 方式明文传输，并且页面中也没有对传输的用户名和密码等敏感信息进行加密后传输，这样认证会话信息等敏感数据在网络中是明文传输，很容易被嗅探到	1、建议系统使用安全加密协议，避免使用明文传输协议如 HTTP 等。 2、建议对敏感字段进行特殊加密如 hash+salt 的方式，避免使用 MD5、Base64 等弱编码。
敏感数据 GET 传输	低危	GET 方法传输表单参数直接显示在 URL 链接中，若登录等位置使用 GET 方式传递表单则账号信息会直接显示在 URL 中，同时系统日志中会显示 GET 请求相关参数，从而造成信息泄露风险。	会话令牌、登陆信息等敏感信息使用 GET 方式进行传输。此时这些敏感信息被附加在 URL 地址后面一起发送到服务器，在这个过程中，攻击者可以很清楚的查看到传输内容，从而被攻击者获取敏感数据。	建议系统敏感数据表单使用 POST 方法进行传递，防止出现敏感信息泄露风险。
脆弱的加密方	低危	弱加密方式可直接使用在线解密工	在数据加密传输的过程中如果数据包被攻击者获取，且使用弱	使用更为安全的加密算法，推荐使用非对称加密算法。若系统使用 MD5 加密算法，同时应注意防范 MD5 的撞库

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

式		具解密出来，若攻击者窃取到以弱加密传输的密码可将其解密进而获取敏感信息。	加密进行传输如 base64 编码，MD5,BASE64 等，在进行解密后即可获取加密后的信息	攻击。
未采用加密协议传输（实在没有漏洞的情况下可以提）	低危	系统未采用加密协议传输，如 HTTP 协议为明文传输协议，登录数据若没有进行加密可直接在网络流量中进行嗅探，造成隐私数据泄露。	由于网站在用户提交的敏感数据到服务器的过程中未进行相关加密处理，导致攻击者可以通过中间人攻击（劫持、嗅探）等方式获取到这些未加密的敏感数据。当攻击者获取到这些数据之后，可能利用这些信息以合法用户的身份登录系统，一旦进入到应用系统中那么就可以获取更多的敏感数据，以及有机会发现更多的漏洞。	建议系统使用 HTTPS 协议替代 HTTP 传输协议。
多点登录	低危	攻击者在获取到其他用户的账号密码后，可利用该缺陷在用户已登录且未知的情况下进行登录，操作用户账户。	系统允许多点认证	建议在不影响业务的前提下，禁止多点登录功能或增加登录信息安全提示功能（当登录系统后提示上次登录时间、IP 等安全信息提示）。
条件竞争漏洞	高危	当俩个或多个进程试图在同一时刻访问共享内存，或读写数据时，最后的执行结果取决于线程的执行顺序，当服务器端逻辑与数据库	竞争条件是系统中的一种反常现象，由于现代 Linux 系统中大量使用并发编程，对资源进行共享，如果产生错误的访问模式，便可能产生内存泄露，系统崩溃，数据破坏，甚至安全问题。竞争条件漏洞就是多个进程访问同一	在系统处理支付、订单等关键数据时，使用悲观锁或乐观锁保证政务的 ACID 性，并避免数据脏读（一个事务读取了另一个事务未提交的数据）。

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

		读写存在时序问题时则存在条件竞争漏洞。攻击者可多线程并发请求，在数据库信息未及时更新时，多次购买商品、积分兑换。	资源时产生的时间或者序列的冲突，并利用这个冲突来对系统进行攻击。一个看起来无害的程序如果被恶意攻击者利用，将发生竞争条件漏洞。	
暴力破解	中危	暴力破解的基本思想是根据题目的部分条件确定答案的大致范围，并在此范围内对所有可能的情况逐一验证，直到全部情况验证完毕。若某个情况验证符合题目的全部条件，则为本问题的一个解；若全部情况验证后都不符合题目的全部条件，则本题无解。常常存在于网站的登录系统中，通过对已知的管理员用户名，进行对其登录口令的大量尝试。	暴力破解的产生是由于服务器端没有做限制，导致攻击者可以通过暴力的手段破解所需信息。一般来说知道管理员的账户信息，破解的效率会大大增提升。	1、使用账户锁定机制。 2、返回信息进行把控，则无法根据系统返回信息判断暴力破解是否成功。 3、使用验证码防止使用自动化工具重复提交数据包。

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

业务重放	根据系统功能及客户情况进行划分，如：发生在留言板处数据批量测试、批量点赞等场景定级为中危。	在系统某个功能点处存在重放漏洞的话，可以对提交数据进行重放。如：留言板处存在重放漏洞，攻击者可以提交留言并抓包，重放该数据包则可以重复发表留言，导致恶意刷留言等问题。	请求重放漏洞是电商平台业务逻辑漏洞中一种常见的由设计缺陷所引发的漏洞，通常情况下所引发的安全问题表现在商品首次购买成功后，参照订购商品的正常流程请求，进行完全模拟正常订购业务流程的重放操作，可以实现“ 一次购买多次收货 ” 等违背正常业务逻辑的结果。	使用加时间戳、随机数、流水号来有效应对抗重放攻击。
任意文件上传	高危：可以通过上传任意文件并getshell 中危：可以绕过黑名单限制但无法getshell	文件上传为系统本身的功能需要但是上传文件类型如果没有经过严格过滤措施就会导致攻击者上传恶意脚本、木马病毒。进而使攻击者获得控制服务器权限。	一般情况下文件上传漏洞是指用户上传了一个可执行的脚本文件，并通过此脚本文件获得了执行服务器端命令的能力。文件上传本身是 web 中最为常见的一种功能需求，关键是文件上传之后服务器端的处理、解释文件的过程是否安全。一般的情况有： 1. 上传文件 WEB 脚本语言，服务器的 WEB 容器解释并执行了用户上传的脚本，导致代码执行； 2. 上传文件 FLASH 策略文件 crossdomain.xml，以此来控制 Flash 在该域下的行为； 3. 上传文件是病毒、木马文件，攻击者用以诱骗用户或管理员下载执行； 4. 上传文件是钓鱼	1、将文件上传目录直接设置为不可执行。 2、文件类型检查：建议使用白名单方式，结合 MIME Type、后缀检查等方式（即只允许允许的文件类型进行上传）；此外对于图片的处理可以使用压缩函数或 resize 函数，处理图片的同时破坏其包含的 HTML 代码。 3、 使用随机数改写文件名和文件路径，使得用户不能轻易访问自己上传的文件。

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

			图片或包含了脚本的图片，某些浏览器会作为脚本执行，可用于实施钓鱼或欺诈	
任意文件下载	高危	文件下载为系统本身的功能需要但是下传文件类型、范围如果么有严格控制则会导致任意文件下载。 攻击者可结合目录穿越漏洞下载系统配置文件，导致严重的敏感信息泄露。	任意文件下载/读取漏洞不同于网站目录浏览，此漏洞不仅仅可遍历系统下 web 中的文件，而且可以浏览或者下载到系统中的文件，攻击人员通过目录遍历攻击可以获取系统文件及服务器的配置文件等等。 一般来说，他们利用服务器 API、文件标准权限进行攻击。	1、净化数据：对用户传过来的文件名参数进行硬编码或统一编码，对文件类型进行白名单控制，对包含恶意字符或者空字符的参数进行拒绝。 2、限制用户下载文件类型、范围。 3、不允许提供目录浏览服务。
任意文件删除	高危	删除文件请求参数如果没有进行合理控制将会产生任意文件删除，结合系统目录穿越漏洞将会导致删除系统配置文件。 攻击者可恶意删除系统文件，导致服务瘫痪。	在未经授权的情况下可任意删除 web 站点中的文件。	1、过滤系统特殊字符防止进行目录穿越。 2、严格控制删除功能相关参数，防止参数攻击者可控。

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

SSRF 服务端请求伪造	高危：通过该漏洞结合内网其他漏洞可造成较大危害如 getshell 定高危。 中危：常规的内网信息探测。	由于服务端提供了从其他服务器应用获取数据的功能且没有对目标地址做过滤与限制。导致攻击者可以伪造服务端发起请求。比如从指定 URL 地址获取网页文本内容，加载指定地址的图片，下载等。	SSRF 漏洞是指是由于服务端提供了从其他服务器应用获取数据的功能且没有对目标地址做过滤与限制，比如从指定 URL 地址获取网页文本内容，加载指定地址的图片，下载等等从而被攻击者利用以达到如下几种攻击目的： 1、对外网、服务器所在内网、本地进行端口扫描，获取一些服务的 banner 信息； 2、 攻击运行在内网或本地的应用程序（比如溢出）； 3、 对内网 Web 应用进行指纹识别，通过访问默认文件实现； 4、 攻击内外网的 Web 应用，主要是使用 get 参数就可以实现的攻击（比如 struts2，sqli 等）； 5、利用 file 协议读取本地文件等	1、过滤内网服务器对公网服务器请求的响应。 2、统一错误提示信息，避免用户可以根据错误信息来判断远端服务器的端口状态 3、若公网服务器的内网 IP 与内网无业务通信，建议将公网服务器对应的内网 IP 列入黑名单，避免应用被用来获取内网数据。 4、内网服务器禁用不必要的协议，仅允许 HTTP 和 HTTPS 请求，防止类似于 file:///、gopher://、ftp:// 等协议引起的安全问题。
未验证的 URL 跳转	中危	服务端未对传入的跳转 url 变量进行检查和控制，可能导致可恶意构造任意一个恶意地址，诱导用户跳转到恶意网站。由于是从可信的站点跳转出去的，用户会比较信任，所以跳转漏洞一般用于钓	借助未验证的 URL 跳转，将应用程序引导到不安全的第三方区域，从而导致的安全问题。	对传入的 URL 做有效性的认证，保证该 URL 来自于信任域。 限制的方式可参考以下两种： 1、限制 Referer（Referer 是 HTTP header 中的字段，当浏览器向 web 服务器发送请求时，一般会带上 Referer，告诉服务器是从哪个页面链接过来的），通过限制 Referer 保证将要跳转 URL 的有效性，避免攻击者生成自己的恶意跳转链接。 2、加入有效性验证 Token，保证所有生成的链接都来自于可信域，通过在生成的链接里加入用户不可控的 Token 对生成的链接进行校验。

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

		鱼攻击。		
订单修改	高危	由于程序逻辑不严谨或业务数据没有在服务端进行校验导致业务数据在传输过程中被攻击者篡改或绕过业务逻辑。进而攻击者可以任意修改订单金额、数量造成“一分钱购买商品”、“业务流程绕过”等逻辑问题。	在提交订单的时候抓取数据包或者直接修改前端代码，然后对订单的金额任意修改	1. 服务器端在生成交易订单时，商品的价格从数据库中取出，禁止使用客户端发送的商品价格。 2. 服务器端对客户端提交的交易数据（如商品 ID、商品数量、商品价格等）的取值范围进行校验，将商品 ID 和商品价格与数据库中的数据对比校验，商品数量为大于零的整型数。 3. 服务器端在生成支付订单时，对支付订单中影响支付金额的所有因素（比如商品 ID、商品数量、商品价格、订单编号等）进行签名，对客户端提交的支付订单进行校验。
时间限制绕过	高危	由于程序逻辑不严谨或业务数据没有在服务端进行校验导致业务数据在传输过程中被攻击者篡改或绕过业务逻辑。		1、对业务数据进行加密使攻击者无法辨认业务数据。 2、每个业务数据使用时间戳加签名方式进行校验有效应对重放攻击和中间人攻击。 3、业务数据服务端校验，不接受服务端传输过来的值。
次数限制绕过	高危	由于程序逻辑不严谨或业务数据没有在服务端进行校验导致业务数据在传输过程中被攻击者篡改或绕过业务逻辑。		1、对业务数据进行加密使攻击者无法辨认业务数据。 2、每个业务数据使用时间戳加签名方式进行校验有效应对重放攻击和中间人攻击。 3、业务数据服务端校验。

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

业务流程绕过（漏洞名称可根据实际场景进行命名）	高危	由于程序逻辑不严谨或业务数据没有在服务端进行校验导致业务数据在传输过程中被攻击者篡改或绕过业务逻辑。	由于程序逻辑不严谨或逻辑太过复杂，导致一些逻辑分支不能正常处理或处理错误	1、对业务数据进行加密使攻击者无法辨认业务数据。 2、每个业务数据使用时间戳加签名方式进行校验有效应对重放攻击和中间人攻击。 3、业务数据服务端校验。
响应头信息泄露	低危	信息泄露指在网站页面或应用中泄露了敏感信息。通过这些信息，攻击者可进一步入侵服务器。（信息泄露包括不限于网站备份文件泄露、js 文件敏感信息泄露、物理路径泄露、中间件信息泄露、密钥泄露、Robots 文件存放敏感路径、内网 IP 泄露等）	由于服务端未进行限制，泄露了服务器信息	一些应用程序在稍后的响应中以清晰的形式返回提交给应用程序的密码。这种行为增加了攻击者捕获用户密码的风险 在响应包内屏蔽掉此类的信息。
测试页面、示例文件未删除	中危：如 tomcat session forexample 低危：若测试页面泄露大量敏感信息或可进一步利用可定级为中或高危，标准参考“敏感信息泄露”。	应用中存在遗留的过时文件、备份页面、渗透测试遗留文件、开发文件残留的测试文件等。	应用中存在遗留的过时文件、备份页面、渗透测试遗留文件、开发文件残留的测试文件等	1、 网站管理员严格检查 web 中可访问的路径下是否存在备份文件，常见备份文件后缀为.jsp.bak、.bak、.sql、.txt、等等。如果有这些文件，直接将该备份文件进行转移到其他目录或者直接删除即可。 2、 对敏感文件设置可访问权限或路径，避免泄露

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

安装文件未删除	根据泄露文件敏感程度进行定级，若安装文件未删除导致的系统重装可高危。	在服务器中存放应用安装包文件，攻击者如果拿到安装包的信息，就可能会知道当前服务器所安装的软件，来进行进一步的攻击。	在服务器中存放应用安装包文件，攻击者如果拿到安装包的信息，就可能会知道当前服务器所安装的软件，来进行进一步的攻击 修复建	1、 网站管理员严格检查 web 中可访问的路径下是否存在备份文件，常见备份文件后缀 为.jsp.bak、.bak、.sql、.txt、等等。如果有这些文件，直接将该备份文件进行转移到其他目录或者直接删除即可。 2、 严格控制可网站可访问目录下的文件敏感度的存放问题，不要将敏感文件置于该目录。
备份文件泄露	根据泄露备份文件敏感程度进行定级若备份文件中含有大量的系统源码可为高危。	备份文件泄露，在 web 服务中，常常不局限于网站的源代码泄露，网站的数据库备份文件，以及上传的敏感文件，或者一切正常备份，原则不允许访问的文件可被通过访问 web 路径进行下载得到，造成其信息泄露。有效的帮助攻击者理解网站应用逻辑，为展开其他类型的攻击提供有利信息，降低攻击的难度，可以进一步获取其他敏感数据。	备份文件泄露，在 web 服务中，常常不局限于网站的源代码泄露，网站的数据库备份文件，以及上传的敏感文件，或者一切正常备份，原则不允许访问的文件可被通过访问 web 路径进行下载得到，造成其信息泄露。有效的帮助攻击者理解网站应用逻辑，为展开其他类型的攻击提供有利信息，降低攻击的难度，可以进一步获取其他敏感数据。	1、 网站管理员严格检查 web 中可访问的路径下是否存在备份文件，常见备份文件后缀 为.jsp.bak、.bak、.sql、.txt、等等。如果有这些文件，直接将该备份文件进行转移到其他目录或者直接删除即可。 2、 严格控制可网站可访问目录下的文件敏感度的存放问题，不要将敏感文件置于该目录。
SVN 文件信息泄露	高危	在服务器上布署代码时。如果是使用 svn checkout 功能来更新	在服务器上布署代码时。如果是使用 svn checkout 功能来更新代码，而没有配置好目录访问权限，则	1、不要使用 svn checkout 和 svn up 更新服务器上的代码，使用 svn export（导出）功能代替。 2、服务器软件（Nginx、apache、tomcat、IIS 等）设置目录权限，禁

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

		代码，而没有配置好目录访问权限，则会存在此漏洞。黑客利用此漏洞，可以下载整套网站的源代码。使用 svn checkout 后，项目目录下会生成隐藏的.svn 文件夹（Linux 上用 ls 命令看不到，要用 ls -al 命令）。svn1.6 及以前版本会在项目的每个文件夹下都生成一个.svn 文件夹，里面包含了所有文件的备份，文件名为 .svn/text-base/文件名.svn-base。	会存在此漏洞。黑客利用此漏洞，可以下载整套网站的源代码。使用 svn checkout 后，项目目录下会生成隐藏的.svn 文件夹（Linux 上用 ls 命令看不到，要用 ls -al 命令）。svn1.6 及以前版本会在项目的每个文件夹下都生成一个.svn 文件夹，里面包含了所有文件的备份，文件名为 .svn/text-base/文件名.svn-base	止访问.svn 目录。
webpack 源码泄露	中危	webpack 是一个 JavaScript 应用程序的静态资源打包器（module bundler）。它会递归构建一个依赖关系图（dependency graph），其	webpack 是一个 JavaScript 应用程序的静态资源打包器（module bundler）。它会递归构建一个依赖关系图（dependency graph），其中包含应用程序需要的每个模块，然后将所有这些模块打包成一个或多个 bundle。大部分	正常通过 webpack 来打包 vue 项目，放到线上的项目是可以通过 F12 控制台的 source 来直接获取到前端项目源码的。如果项目有需求不能泄露源码，或者你不想让别人看到你的源码，可以直接在项目路径下修改 config/index.js 中 build 对象 productionSourceMap: false。

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

		中包含应用程序需要的每个模块，然后将所有这些模块打包成一个或多个 bundle。其中可能包含了 API、加密算法、管理员邮箱、内部功能等等。	Vue 等项目应用会使用 webpack 进行打包，如果没有正确配置，就会导致项目源码泄露，可能泄露的各种信息如 API、加密算法、管理员邮箱、内部功能等等	
.git 源码泄露	高危	在运行 git init 初始化代码库的时候，会在当前目录下面产生一个.git 的隐藏文件，用来记录代码的变更记录等等。在发布代码的时候，把.git 这个目录没有删除，直接发布了，通过这个文件可以用来恢复源代码。	开发者因 Git 版本控制器使用不当造成源码泄露	删除指定 GIT 生成的各种文件，如”/ .git/index”等。
Robots 配置文件泄露	低危	搜索引擎可以通过 robots 文件可以获知哪些页面可以爬取，哪些页面不可以爬取。Robots 协议是网站国际互联网界通行的道德规范，其目的是保护网站数据和敏感	根据攻击者可通过发现 robots.txt 文件，收集网站的敏感目录或文件，从而有针对性的进行利用。	根据实际情况，进行如下对应的修复： 1、 User-agent: * 这里的*代表的所有的搜索引擎种类，*是一个通配符。 2、 Disallow: / 这里定义是禁止爬寻站点所有的内容。 3、 Disallow: /admin/ 这里定义是禁止爬寻 admin 目录下面的目录。 4、 Disallow: /ABC/ 这里定义是禁止爬寻 ABC 目录下面的目录。 5、 Disallow: /cgi-bin/*.htm 禁止访问/cgi-bin/目录下的所有以".htm"为后缀的 URL(包含子目录)。

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

		信息、确保用户个人信息和隐私不被侵犯，如果 robots.txt 文件编辑的太过详细，反而会泄露网站的敏感目录或者文件，比如网站后台路径，从而得知其使用的系统类型，从而有针对性地进行利用。		6、 Disallow: /*?* 禁止访问网站中所有包含问号 (?) 的网址。 7、 Disallow: /.jpg$ 禁止抓取网页所有的.jpg 格式的图片。 8、 Disallow:/ab/adc.html 禁止爬取 ab 文件夹下面的 adc.html 文件。 9、 Allow: /cgi-bin/ 这里定义是允许爬寻 cgi-bin 目录下面的目录。 10、Allow: /tmp 这里定义是允许爬寻 tmp 的整个目录 11、Allow: .htm$ 仅允许访问以".htm"为后缀的 URL。 12、Allow: .gif$ 允许抓取网页和 gif 格式图片。 13、Sitemap: 网站地图 告诉爬虫这个页面是网站地图。
WEB.XML 配置文件泄露	低危，若遇到文件存在敏感信息参考敏感信息泄露定级标准。	直接在域名后面加上 WEB-INF/web.xml，据 web.xml 配置文件路径或通常开发时常用框架命名习惯，可找到其他配置文件或类文件路径。	直接在域名后面加上 WEB-INF/web.xml，据 web.xml 配置文件路径或通常开发时常用框架命名习惯，可找到其他配置文件或类文件路径。	设置目录权限，禁止访问且在配置文件中对敏感信息进行加密。
物理路径泄露	低危	攻击者可能通过泄露的物理路径发起进一步攻击。	应用中泄露出应用在主机中的绝对地址路径	1、媒体链接和超链接采用相对路径的表达方式； 2、报错信息中不对外输出网站物理路径等敏感信息。
中间件信息泄露	低危	通常在 HTTP 报文的响应头中存在的标志、版本号等信息均属于中间件的版本信息泄露漏洞。	应用报错时的缺省页面中包含中间件版本等信息。	如不必要建议将中间件版本信息进行隐藏或自定义系统错误页面统一返回报错至报错页面。
应用程序	低危	Web 服务器未能正确处理	错误页面 Web 应用服务器版本泄露	如不必要建议系统统一报错信息提示页面或规范系统调试功能禁止将

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

调试版本信息泄露		异常请求导致Web服务器版本信息泄露，攻击者收集到服务器信息后可进行进一步针对性攻击。		系统报错调试信息返回前端。
密码返回前端	高危	服务器端将密码信息返回在响应数据包中或者在登录、验证等页面的隐藏域中存在密码信息。	服务器端将密码信息返回在响应数据包中或者在登录、验证等页面的隐藏域中存在密码信息。	用户名及密码尽可能不在客户端存储，若有必要，如cookie中暂存，应以加密方式存储。
js文件敏感信息泄露	低危:若js中泄露大量敏感信息可为中、高危。	一些粗心的开发者将各式敏感信息存储在JavaScript脚本中，因为JS的特性，攻击者能够对这些信息尽收眼底，从而致使对WEB服务和用户隐私形成不一样程度的威胁。前端	在前端js文件中，泄露了敏感信息，如账户、密码、文件路径等（包含账号密码、个人信息如：身份证号码、银行卡号）	如不必要建议及时将敏感信息清除。同时禁止在代码中存储敏感数据：禁止在代码中存储如数据库连接字符串、口令和密钥之类的敏感数据，这样容易导致泄密。用于加密密钥的密钥可以硬编码在代码中。
敏感信息泄露	高危:如大量的(账号密码、密钥、证书、会话标识、License、授权凭据、隐私数据（包括但不限姓名、身份证号、银行卡号、家庭住址、病历、保单信息）等高敏感度的信息。 中危：如存在他人的少量的手机号、姓名（50条以下）	信息泄露指在网站页面或应用中泄露了敏感信息。通过这些信息，攻击者可进一步入侵服务器。（信息泄露包括不限于网站备份文件泄露、js文件敏感信息	在数据传输过程或应用配置文件中泄露了敏感信息（包含账号密码、个人信息如：身份证号码、银行卡号等）	在应用配置文件中应去除敏感信息（包含账号密码、个人信息如：身份证号码、银行卡号等），若业务所需请在不影响业务的情况下进行后端脱敏处理。

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

	等低敏感度的信息。 低危：如存在自身手机号、姓名等低敏感度的信息。	泄露、物理路径泄露、中间件信息泄露、密钥泄露、Robots 文件存放敏感路径、内网 IP 泄露等）。		
敏感信息未模糊化	低危	敏感信息（包含账号密码、个人信息如：身份证号码、银行卡号等）在终端上展示时未进行模糊处理。	敏感信息（包含账号密码、个人信息如：身份证号码、银行卡号等）在终端上展示时未进行模糊处理。	建议在不影响业务的前提下必要，敏感信息在终端上展示时应做模糊处理，并在应用后端进行敏感字段脱敏处理，如部分内容以*方式传输及显示。
密钥泄露	低危	攻击者通过没用被有效隐藏的密钥可以发起进一步攻击。		1、如不必要建议及时将系统敏感信息清除。 2、 禁止密钥或帐号的口令以明文形式存储在数据库或者文件中：密钥或帐号的口令必须经过加密存储。例外情况，如果 Web 容器的配置文件中只能以明文方式配置连接数据库的用户名和口令，那么就不用强制遵循该规则，将该配置文件的属性改为只有属主可读写。
目录浏览（遍历）	默认中危：若存在敏感信息对照敏感信息的定级标准。	目录浏览漏洞是由于网站存在配置缺陷，存在目录可浏览漏洞，这会导致网站很多隐私文件与目录泄露，比如数据库备份文件、配置文件等，攻击者利用该信息可以更容易得到网站权限，导致网站被黑。	同于网站目录浏览，此漏洞不仅仅可遍历系统下 web 中的文件，而且可以浏览或者下载到系统中的文件，攻击人员通过目录遍历攻击可以获取系统文件及服务器的配置文件等等。一般来说，他们利用服务器 API、文件标准权限进行攻击。	目前存在该漏洞的常见中间件为 apache 和 IIS,以下列出其相关的修复方式： 1、 IIS 中关闭目录浏览功能：在 IIS 的网站属性中，勾去“目录浏览”选项，重启 IIS。 2、 Apache 中关闭目录浏览功能：打开 Apache 配置文件 httpd.conf，查找“Options Indexes FollowSymLinks”,修改为“ Options -Indexes”(减号表示取消，保存退出，重启 Apache。 3、 Nginx 中默认不会开启目录浏览功能，若您发现当前已开启该功能，可以编辑 nginx.conf 文件，删除如下两行：autoindex on;autoindex_exact_size on;重启 Nginx。

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

内部IP地址泄露	低危	信息泄露指在网站页面或应用中泄露了敏感信息。通过这些信息，攻击者可进一步入侵服务器。（信息泄露包括不限于网站备份文件泄露、js文件敏感信息泄露、物理路径泄露、中间件信息泄露、密钥泄露、Robots文件存放敏感路径、内网IP泄露等）。	网站的内部IP地址，常常被攻击者通过信息收集，得到其内网的IP地址，对于渗透攻击，打下良好基础，如内网Ip地址段，IP路由等等	如不必要建议及时将内网IP信息隐藏或使用域名进行替换。
服务器路径泄露	低危	检测到在服务器的响应内容中可能存在系统目录路径信息，如/home,/var或者c:\等信息，这一般是由于目标web应用没有处理好应用错误信息导致的目录路径信息泄露。如果***者获取到这些信息，可以了解目标服务器目录结构，给***者带来便利，如上传文件到服务器	应用中泄露了网站根目录或敏感文件绝对路径等	如果是正常页面中包含路径信息，如果不需要该路径信息，***该信息。如果是错误信息中包含路径信息，需要屏蔽应用程序错误信息。

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

		的其他目录。		
IIS 短文件名	低危	此漏洞实际是由 HTTP 请求中旧 DOS 8.3 名称约定（SFN）的代字符（~）波浪号引起的。它允许远程攻击者在 Web 根目录下公开文件和文件夹名称（不应该可被访问）。攻击者可以找到通常无法从外部直接访问的重要文件，并获取有关应用程序基础结构的信息。	攻击者可以利用“~”字符猜解或遍历服务器中的文件名，或对 IIS 服务器中的.Net Framework 进行拒绝服务攻击。	1、CMD 关闭 NTFS 8.3 文件格式的支持 2、修改注册表禁用短文件名功能 3、关闭 Web 服务扩展- ASP.NET 4、升级 netFramework 至 4.0 以上版本
Apache tomcat 文件包含漏洞	高危	Apache 与 Tomcat 都是 Apache 开源组织开发的用于处理 HTTP 服务的项目，两者都是免费的，都可以做为独立的 Web 服务器运行。Apache Tomcat 服务器存在文件包含漏洞，攻击者可利用该漏洞读取	该漏洞是由于 Tomcat AJP 协议存在缺陷而导致，攻击者利用该漏洞可通过构造特定参数，读取服务器 webapp 目录下的任意文件 （例如 webapp 配置文件，源代码等），经检验只能读取此目录下文件，不可遍历 。	1、 临时禁用 AJP 协议端口，在 conf/server.xml 配置文件中注释掉 2、 配置 ajp 配置中的 secretRequired 和 secret 属性来限制认证 3、 官方下载最新版下载地址： https://tomcat.apache.org/download-70.cgi https://tomcat.apache.org/download-80.cgi https://tomcat.apache.org/download-90.cgi 或 Github 下载： https://github.com/apache/tomcat/releases

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

		或包含 Tomcat 上所有 webapp 目录下的任意文件，如：webapp 配置文件或源代码等。		
WebLogic Server 远程代码执行漏洞	高危	通过该漏洞，攻击者可以在未授权的情况下远程执行代码。攻击者只需要发送精心构造的 T3 协议数据，就可以获取目标服务器的权限。攻击者可利用该漏洞控制组件，影响数据的可用性、保密性和完整性。	攻击者利用 RMI 绕过 weblogic 黑名单限制，将加载的内容利用 readObject 解析，造成反序列化漏洞，该漏洞主要由于 T3 协议触发，所有开放 weblogic 控制台 7001 端口，默认开启 T3 服务，攻击者发送构造好的 T3 协议数据，获取目标服务器的权限。	1、通过 Nginx/Apache 配置反向代理的方式访问 Weblogic 应用，限制 Weblogic T3 的直接访问，此漏洞也将不能直接被利用。 2、强烈建议受影响的用户尽快升级更新 Oracle2018-04-18 日发布的安全补丁； 用户使用正版软件许可账号，可在 https://support.oracle.com 处下载 Oracle 官方补丁。
Nginx 整数溢出漏洞	高危	Nginx 是由俄罗斯的程序设计师 Igor Sysoev 所开发的一款轻量级 Web 服务器/反向代理服务器及电子邮件（IMAP/POP3）代理服务器。range filter module 是其中的一个范围过滤器模块。 Nginx 0.5.6 版本至	在 Nginx 的 range filter 中存在整数溢出漏洞，可以通过带有特殊构造的 range 的 HTTP 头的恶意请求引发这个整数溢出漏洞，并导致信息泄露。	将 Nginx 升级到最新版本。 目前厂商已发布升级补丁以修复漏洞，补丁获取链接： http://mailman.nginx.org/pipermail/nginx-announce/2017/000200.html

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

		1.13.2 版本中的 range filter 模块存在整数溢出漏洞。攻击者可利用该漏洞获取敏感信息。		
Nginx 解析漏洞	高危	在旧版本的 Nginx 中，存在一个利用空字节注入的漏洞。利用这个漏洞，在任何使用 PHP_FastCgi 技术的服务器上，攻击者可以以 PHP 执行任何具有公共访问权限的文件。在有漏洞的 Nginx 版本中，URI 中的空字节是默认允许的（定义：ngx_http_request.h 头文件中的变量 zero_in_uri）。不是所有的模块在遇到有空字节的 URI 时都会拒绝执行，比如 FastCgi 模块就不会拒绝。 攻击过程:攻击者访问 http://site.com/test.j	nginx 在解析文件名的时候，遇到空字节会产生解析错误比如原本是 png 文件会当做 php 文件解析。	升级 Nginx 版本至最新版本，建议使用 WAF 防护。

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

		pg%00.php，达到以 PHP 来解析 test.jpg 的目的。如果攻击者能够控制装有低版本 nginx 的服务器上的文件内容(例如利用图片上传的方式)，就能够随心所欲的执行任意 PHP 代码，达到控制网站服务器的目的。 影响版本： nginx 0.5.* nginx 0.6.* nginx 0.7 <= 0.7.65 nginx 0.8 <= 0.8.37		
IIS 解析漏洞	高危	漏洞影响 IIS7 及 IIS7.5 在使 FastCGI 方式调用 php 时，在 php.ini 里设置 cgi.fix_pathinfo=1 使得访问任意文件 URL 时，在 URL 后面添加“/x.php”等字符时，该文件被 iis 当 php 文件代码解析。	IIS 6.0 在处理含有特殊符号的文件路径时会出现逻辑错误，从而造成文件解析漏洞	升级 IIS 版本至最新版本。

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

HTTP.SYS 远程代码执行	高危	Http.sys 是 Microsoft Windows 处理 HTTP 请求的内核驱动程序。HTTP.sys 会错误解析某些特殊构造的 HTTP 请求，导致远程代码执行漏洞。成功利用此漏洞后，攻击者可在 System 帐户上下文中执行任意代码。由于此漏洞存在于内核驱动程序中，攻击者也可以远程导致操作系统蓝屏。此次受影响的系统中，Windows7、Windows8、WindowsServer 2008 R2 和 WindowsServer 2012 所带的 HTTP.sys 驱动均存在一个远程代码执行漏洞，远程攻击者可以通过 IIS7(或更高版本)服务将恶意的 HTTP 请求传递给 HTTP.sys 驱动，通过发送恶意的 HTTP	Http.sys 是 Microsoft Windows 处理 HTTP 请求的内核驱动程序。HTTP.sys 会错误解析某些特殊构造的 HTTP 请求，导致远程代码执行漏洞。成功利用此漏洞后，攻击者可在 System 帐户上下文中执行任意代码。由于此漏洞存在于内核驱动程序中，攻击者也可以远程导致操作系统蓝屏。此次受影响的系统中，Windows7、Windows8、WindowsServer 2008 R2 和 WindowsServer 2012 所带的 HTTP.sys 驱动均存在一个远程代码执行漏洞，远程攻击者可以通过 IIS7(或更高版本)服务将恶意的 HTTP 请求传递给 HTTP.sys 驱动，通过发送恶意的 HTTP 请求导致远程代码执行或操作系统蓝屏。	方法 1：微软官方网站下载 ms15-034 的补丁包 下载地址： https://docs.microsoft.com/zh-cn/security-updates/Securitybulletins/2015/ms15-034

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

		请求导致远程代码执行或操作系统蓝屏。		
JBOSS 远程代码执行	高危	该漏洞位于 JBoss 的 HttpInvoker 组件中的 ReadOnlyAccessFilter 过滤器中，其 doFilter 方法在没有进行任何安全检查和限制的情况下尝试将来自客户端的序列化数据流进行反序列化，导致攻击者可以通过精心设计的序列化数据无需用户验证在系统上执行任意命令，获得服务器的控制权。	Jboss 文件下的 httplnvoker 组件中的 Readonly Accessfilter 过滤器中的 dofilter 没有限制来自客户端的序列化数据而进行反序列化。	建议及时更新 JBOSS 的版本到最新，如果暂时不能更新，则提供以下方案进行修复： 1、如果不需要 http-invoker.sar 组件，可直接删除 2、添加如下代码至 http-invoker.sar 下 web.xml 的 security-constraint 标签中，对 http invoker 组件进行访问控制。
Ueditor 远程文件抓取漏洞	高危	Ueditor 是百度开发的一个网站编辑器，目前已经不对其进行后续开发和更新，该漏洞只存在于该编辑器的.net 版本。其他的 php,jsp,asp	在抓取远程数据源的时候未对文件后缀名做验证导致任意文件写入漏洞，黑客利用此漏洞可以在服务器上执行任意指令	1.目前临时的漏洞修复是建议，把文件上传目录设置无脚本执行权限，uploadvideo、uploadimage、catchimage、uploadscrawl、uploadfile、等等目录都设置上无脚本权限。 2.在百度 UEditor 官方没有出补丁前，设置图片目录为只读，禁止写入。 3.检查文件上传路径下是否有近期上传的畸形图片；检查是否存在 asp，aspx 等类型危险文件。如果发现异常文件，请判断后及时删除。

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

		版本不受此 UEditor 的漏洞的影响，.net 存在任意文件上传，绕过文件格式的限制，在获取远程资源的时候并没有对远程文件的格式进行严格的过滤与判断。		4.修改程序的源代码，对 crawlerhandler 源文件进行文件上传格式的严格过滤与判断。 image、uploadscrawl、uploadfile、等等目录都设置上无脚本权限。 2.在百度 UEditor 官方没有出补丁前，设置图片目录为只读，禁止写入。 3.检查文件上传路径下是否有近期上传的畸形图片；检查是否存在 asp，aspx 等类型危险文件。如果发现异常文件，请判断后及时删除。 4.修改程序的源代码，对 crawlerhandler 源文件进行文件上传格式的严格过滤与判断。
jQuery 版本漏洞	低危	jQuery 是美国 John Resig 程序员的一套开源、跨浏览器的 JavaScript 库。该库简化了 HTML 与 JavaScript 之间的操作，并具有模块化、插件扩展等特点。 jQuery 3.5.0 之前版本中存在跨站脚本漏洞，该漏洞源于 WEB 应用缺少对客户端数据的正确验证。攻击者可利用该漏洞执行客户端代码。	据 NVD 描述：在大于或等于 1.2 且在 3.5.0 之前的 jQuery 版本中，即使执行了消毒（sanitize）处理，也仍会执行将来自不受信任来源的 HTML 传递给 jQuery 的 DOM 操作方法（即 html()、.append() 等），从而导致 xss 漏洞。	临时解决方案： 暂时隐藏 jQuery 版本信息，避免被攻击者识别出版本号:注释版本信息以及正文内版本信息。 为应用系统制定统一的、影响全局的危险字符黑名单，发现输入中存在危险字符时直接返回固定的错误页面。 正式解决方案： 升级 jQuery 至最新版本。
Shiro 远程代码执行	高危：可以远程执行命令 低危：获取到了 defualt key 但是无法进一步利用	Shiro 对 rememberMe 的 cookie 做了加密处理，shiro 在 cookieRemem	攻击者通过使用有效的 rememberMe cookie 作为 Padding Oracle 攻击的前缀，然后构造 rememberMe 来执行	目前厂商已经发布了升级补丁以修复此安全问题，补丁获取链接：http://shiro.apache.org/download.html。

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

		berMeManaer 类中将 cookierememberMe 字段内容分别进行序列化、AES 加密、Base64 编码操作。但是，AES 加密的密钥 Key 被硬编码在代码里，意味着每个人通过源代码都能漏洞描述拿到 AES 加密的密钥。因此，攻击者构造一个恶意的对象，并且对其序列化，AES 加密，base64 编码后，作为 cookie 的 rememberMe 字段发送。Shiro 将 rememberMe 进行解密并且反序列化，最终造成远程代码执行漏洞。	Java 反序列化攻击，最终可导致远程代码执行。	

Thinkphp 远程代码	高危	由于 ThinkPHP5 框架对控制器名没有进行足够的安全检测，导致在没有开启强制路由的情况下，攻击者构造特定的	由于框架对控制器名没有进行足够的检测导致在没有开启强制路由的情况下 getshell	1、升级 ThinkPHP 至安全版本
				2、在 think\App 类的 module 方法的获取控制器的代码后面加上
				if (!preg_match('/^[A-Za-z](\w|\.)*$/', $controller)) {
				throw new HttpException(404, 'controller not exists:' . $controller);
				}

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

		恶意请求，可以直接获取服务器权限。		
fastjson 反序列化	高危	Fastjson 是一个 Java 语言编写的高性能功能完善的 JSON 库。它采用一种“假定有序快速匹配”的算法，把 JSON Parse 的性能提升到极致，是目前 Java 语言中最快的 JSON 库。Fastjson 接口简单易用，已经被广泛使用在缓存序列化、协议交互、Web 输出、Android 客户端等多种应用场景。fastjson<=1.2.68 版本能够通过期望类的某些子类绕过 AutoType 功能，进而造成反序列化远程代码执行漏洞。	攻击者准备 rmi 服务和 web 服务，将 rmi 绝对路径注入到 lookup 方法中，受害者 JNDI 接口会指向攻击者控制 rmi 服务器，JNDI 接口向攻击者控制 web 服务器远程加载恶意代码，执行构造函数形成 RCE。	升级至安全版本 较低版本升级至最新版本 1.2.69 可能会出现兼容性问题，建议升级至特定 版本的 sec10 bugfix 版本，请参考以下链接尽快修复：https://repo1.maven.org/maven2/com/alibaba/fastjson/
Struts 2 远程代码执行	高危	struts2 是一个基于 MVC 设计模式的 Web 应用框架，它本质上相当于一个	用户提交表单时，后端会将 OGNL 表达式%{value}进行解析	建议将 struts2 升级至最新版本。

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

		servlet，在 MVC 设计模式中，Struts2 作为控制器(Controller)来建立模型与视图的数据交互。不安全的配置行为等多种问题导致攻击者可以针对 struts2 框架进行远程代码执行，从而获取服务器权限。		
log4j 2.X 远程代码执行	高危	Log4j-2 中存在 JNDI 注入漏洞，当程序将用户输入的数据被日志记录时，即可触发此漏洞，此次漏洞是用于 Log4j2 提供的 lookup 功能造成的，该功能允许开发者通过一些协议去读取相应环境中的配置。但并未对输入进行严格的判断，从而造成攻击者可以在目标服务器上执行任意代码。	当 Java 应用程序将攻击者输入的数据，记入日志时（一般我们开发过程中，会使用 Log4J 记录重要的日志），Log4J 发现需要向 JNDI 发起请求，而攻击者将输入的数据指向自己构造的攻击服务器上的 LDAP 服务，这个服务在返回数据中植入了恶意代码（可执行脚本），服务端收到 LDAP 的响应数据并去执行，导致被攻击。	建议将 log4j 2 升级到最新版本。

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

漏洞收录规则-SRC 版（每家 SRC 都不一样）

顺丰 SRC

【严重】

1) 直接导致业务系统不可用的漏洞。包括但不限于通过远程拒绝服务漏洞直接导致线上核心应用、系统、服务器等无法继续提供服务的漏洞。

2) 直接批量获取业务系统大量高价值信息的漏洞。包括但不限于 SQL 注入、接口等引起的公司员工个人信息（姓名、电话、地址、证件、部门岗位等）大量（数据三元素组合十万条以上）明文泄露和用户数据（姓名、电话、地址、证件等）大量（数据三元素组合一百万条以上，数据二元素组合一千万条以上）明文泄露的漏洞。

3) 直接导致业务运营大量资金损失的逻辑设计缺陷和流程缺陷，需满足可直接提现且无利用限制并且影响金额超过 10 万元。包括但不限于任意账号资金修改、支付系统支付交易流程的漏洞。

4) 直接获取业务系统管理权限的漏洞。包括但不限于：命令注入、远程命令执行、上传获取 WebShell、SQL 注入等获取核心系统权限、缓冲区溢出的漏洞。

5）顺丰核心 B 端/C 端用户、员工账号系统的任意用户登录/任意密码修改。

【高危】

1) 直接批量获取业务系统批量高价值信息泄露的漏洞。包括但不限于源代码压缩包泄漏、越权或者直接获取公司员工（姓名、电话、地址、证件、部门岗位等）批量（数据三元素组合一万条以上，数据二元素十万条以上）明文泄露和用户数据（姓名、电话、地址、证件等）的批量（数据三元素组合十万条以上，数据二元素组合百万条以上）明文泄露的漏洞。

2) 业务系统管理后台弱口令、未授权访问管理平台并使用管理员功能等核心交互的漏洞。包括但不限于绕过认证直接获取管理后台权限、任意账号登录和密码修改。

3) 间接导致业务运营资金损失的逻辑设计缺陷和流程缺陷。包括不限于用户账号的积分资产修改、活动期间撸羊毛可造成大量资金损失的漏洞。

4) 大范围影响客户端的漏洞。包括不限于可造成自动传播的且能获取认证凭证的存储型 XSS 漏洞、远程任意命令执行漏洞、DoS 漏洞等。

5) 访问任意系统文件的漏洞。包括但不限于任意文件读取/下载/删除。

6) 子域名劫持、网页篡改，触发会跳转到非法网站的漏洞或情报。

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

7) 可完全回显、直接获取内网敏感信息的 SSRF 漏洞，须验证该漏洞能够访问内部网络，但禁止利用该漏洞对内网服务进行扫描。

【中危】

1) 普通信息泄露的漏洞。包括但不限于未涉及敏感数据的 SQL 注入、影响数据量有限或者敏感程度有限的越权、源代码等信息泄露。

2) 需要用户交互或其他前置条件才能获取用户身份信息的漏洞。包括但不限于包含用户、网站敏感数据的 JSON Hijacking、重要业务敏感操作（如支付类操作、修改个人账号敏感信息类操作）的 CSRF、一般业务存储型 XSS。

3) 普通的逻辑缺陷和越权漏洞。包括但不限于越权增删改查用户/业务数据，非核心交互功能但会影响到用户/业务正常使用的越权。

4) 可攻击管理后台的 XSS 类攻击（需提供前台攻击位置，定位风险）漏洞。

5) 在业务预期外，单用户可批量获取大额现金优惠券（6 折及以下），获取数量大于 20 张。

6) 仅图片回显、部分回显的 SSRF 漏洞。

7) 非核心业务收费功能绕过付费，业务上第三方应用多次免费使用、绕过付费、绕过限制使用高级版功能等。如：非核心业务的延长产品试用期漏洞、基础版用户越权使用高级版用户功能等。

8）需点击链接进行交互的 OAuth 登录或绑定劫持。

9）顺丰相关小程序密钥泄露，若未能证明该密钥可利用较大危害的 API，最高评级【中危】

10）可实时批量爬取大量在途的顺丰运单号、时间以及未具体到详细地址但返回收寄件人地区的。如绕过滑块验证码、或存在接口可批量进行运单路由信息。

【低危】

1) 轻微信息泄漏漏洞，包括但不仅限于路径信息泄漏、SVN 信息泄漏、phpinfo、URL 任意跳转等。

2) 账号体系（包括但不仅限于顺丰会员账号体系）的撞库，爆破等问题。

3) 存在安全隐患，但利用难度较大的漏洞。

4) 可访问内网，但无回显、无法获取信息或服务权限的 SSRF 漏洞。

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

5) 可造成的实际危害较小的越权或流程缺陷。

6) 只有在特定条件下才可以触发的漏洞。如只有在特定非常用浏览器下才可以触发的存储型 XSS。

7）仅影响同组织内用户非重要功能的漏洞。如：同组织内越权漏洞、存储型 XSS 等

8）无任何限制短信轰炸漏洞。针对单用户短信超 20 条每分钟。

【忽略】

1) 实际业务安全性无影响的 Bug，包括但不仅限于业务系统功能缺陷、网页乱码、样式混乱、静态文件目录遍历、应用兼容性等问题。

2) 无法利用/无实际危害的漏洞。包括但不限于无实际危害的越权、不可利用的 Self XSS（无法分享给其他账号访问未收到后台记录）、pdf 格式的 XSS 静态文件目录遍历、401 认证钓鱼、内网 IP/ 域名泄露、无敏感信息（如用户昵称、用户个人公开的信息、已脱敏的敏感信息等）的 JSON Hijacking 、横向短信轰炸、用户名枚举、swagger 类接口文档泄露和 Spring Actutor 健康检查模块信息泄露但不可进一步利用的漏洞等。

3) 非顺丰业务的安全漏洞，如：仿冒顺丰域名业务的网站（如发现确认仿冒后给予感谢分）。

4) 无法重现的漏洞，包括但不仅限于经审核人员多次确认无法重现的漏洞、无实际危害证明的扫描器结果等。

5) 内部已知、正在处理的漏洞，包括但不限于：在其他平台公开的第三方软件漏洞，其他白帽子或内部已发现的漏洞。

6) 测试环境(域名包含 sit、test、uat、stg 等)安全问题，专项活动除外。

7) 可批量获取优惠额度较小的优惠券（6 折以上），且优惠券不可转让或变现。

8) 部分风险过低或难以利用的漏洞。包括但不限于 PDF XSS、并发请求不重要的功能（如阅读量、点赞量、无法获利的积分等）、无法进一步利用的 API Key 泄露、本地拒绝服务漏洞、基于理论未提供实际危害证明的漏洞。

9) 蜜罐系统漏洞不计分。

10) 根据邮政行标 YZ/T 0131-2013《快件跟踪查询信息服务规范》，一线快件处理人员的姓名、电话、处理场所（指快件所在的快件处理场所的名称）为规定需公开的投递信息，不属于敏感数据。

11）无敏感操作的 CSRF。包括但不限于重要业务的非敏感功能，非重要业务的

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

普通个人资料修改等

12）通过社会工程学获取的敏感用户/业务数据、重要系统登录等方式不在漏洞收录范围内。

13）针对内部正在开展的对于某系统、某类型漏洞的专项整改计划暂不收取，具体详情以审核人员回复为准。

360SRC

Web\服务端

【严重】

1、直接获取核心服务器权限的漏洞，包括但不限于上传 Webshell、任意代码执行、远程命令执行等。

2、直接导致严重的信息泄露漏洞，包括但不限于重要数据库的 SQL 注入、系统权限控制不严格等导致的敏感数据泄露漏洞等。

3、直接导致严重影响的逻辑漏洞，包括但不限于核心账户体系的账密校验逻辑等。

【高危】

1、重要业务敏感数据信息泄露漏洞，包括但不限于重要用户信息、订单信息、数据文件信息等。

2、重要业务的逻辑漏洞，包括但不限于权限绕过等。

3、不需交互的重点业务漏洞，包括但不限于文件遍历、任意文件包含、任意文件读取等。

4、包含重要业务敏感信息的非授权访问，包括但不仅限于绕过认证直接访问管理后台、后台弱密码、可直接获取大量内网敏感信息的 SSRF 等。

【中危】

1、不需交互对用户产生危害的安全漏洞，包括但不限于一般页面存储型 XSS 等。

2、普通信息泄露漏洞，包括但不限于用户信息泄露和业务敏感信息泄露等。

3、普通的逻辑设计缺陷和流程缺陷，包括但不限于越权查看非核心系统的订单信息等。

4、其他造成中度影响的漏洞，例如：没有敏感信息的 SQL 注入、无回显 SSRF

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

漏洞等。

【低危】

1、在特殊条件下才能获取用户信息的安全漏洞，包括但不限于反射 XSS 等。

2、轻微信息泄露，包括但不限于服务器物理路径、边缘系统文件、本地日志等。

3、其他造成低危害的漏洞，例如：管理后台开放、解析漏洞、存在可被暴力破解接口等。

【忽略】

1、无关安全的 bug。包括但不限于网页乱码、网页无法打开、某功能无法用。

2、无法利用的“漏洞”。包括但不限于没有实际危害的“扫描”报告、Self-XSS、无敏感信息的 JSONHijacking、无敏感操作的 CSRF、无意义的源码泄漏、内网 IP 地址/域名泄漏、401 基础认证钓鱼、程序路径信任问题、无敏感信息的信息泄漏（如无敏感信息的/metrics，/.htaccess，/DS_store，/ swagger-ui 等）。

3、非 360 业务漏洞，测试系统的无效漏洞。

Web\服务端

【严重】

1、直接获取核心服务器权限的漏洞，包括但不限于上传 Webshell、任意代码执行、远程命令执行等。

2、直接导致严重的信息泄露漏洞，包括但不限于重要数据库的 SQL 注入、系统权限控制不严格等导致的敏感数据泄露漏洞等。

3、直接导致严重影响的逻辑漏洞，包括但不限于核心账户体系的账密校验逻辑等。

【高危】

1、重要业务敏感数据信息泄露漏洞，包括但不限于重要用户信息、订单信息、数据文件信息等。

2、重要业务的逻辑漏洞，包括但不限于权限绕过等。

3、不需交互的重点业务漏洞，包括但不限于文件遍历、任意文件包含、任意文件读取等。

4、包含重要业务敏感信息的非授权访问，包括但不仅限于绕过认证直接访问管

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

理后台、后台弱密码、可直接获取大量内网敏感信息的 SSRF 等。

【中危】

1、不需交互对用户产生危害的安全漏洞，包括但不限于一般页面存储型 XSS 等。

2、普通信息泄露漏洞，包括但不限于用户信息泄露和业务敏感信息泄露等。

3、普通的逻辑设计缺陷和流程缺陷，包括但不限于越权查看非核心系统的订单信息等。

4、其他造成中度影响的漏洞，例如：没有敏感信息的 SQL 注入、无回显 SSRF 漏洞等。

【低危】

1、在特殊条件下才能获取用户信息的安全漏洞，包括但不限于反射 XSS 等。

2、轻微信息泄露，包括但不限于服务器物理路径、边缘系统文件、本地日志等。

3、其他造成低危害的漏洞，例如：管理后台开放、解析漏洞、存在可被暴力破解接口等。

【忽略】

1、无关安全的 bug。包括但不限于网页乱码、网页无法打开、某功能无法用。

2、无法利用的“漏洞”。包括但不限于没有实际危害的“扫描”报告、Self-XSS、无敏感信息的 JSONHijacking、无敏感操作的 CSRF、无意义的源码泄漏、内网 IP 地址/域名泄漏、401 基础认证钓鱼、程序路径信任问题、无敏感信息的信息泄漏（如无敏感信息的/metrics，/.htaccess，/DS_store，/ swagger-ui 等）。

3、非 360 业务漏洞，测试系统的无效漏洞。

PC 客户端漏洞

PC 客户端产品包括 360 安全卫士、360 杀毒、360 手机卫士等核心产品，其他客户端产品视情况降低评级。长期不更新或较低版本的产品不列入奖励范畴，若危害较大可酌情给予奖励。

【严重】

包括但不限于远程任意命令执行、可利用的远程缓冲区溢出以及其它因逻辑问题导致的远程代码执行漏洞。

【高危】

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

主动防御绕过，即执行高危动作后未出现拦截。高危动作包括但不限于修改启动项、替换系统命令、设置定时任务、破坏或删除卫士功能、致程序崩溃防御失效的操作等。

备注：主动防御绕过需在联网且开启晶核的模式下；高危动作不包括正常文件读取、截屏等行为。

【中危】

1、本地任意代码执行。

包括但不限于本地可利用的堆栈溢出、本地提权、 文件关联的 DLL 劫持以及其它逻辑问题导致的本地代码执行漏洞。

备注：不包括以下几种情况：

加载不存在的 DLL 文件、加载正常 DLL 未校验合法性、需要管理员权限操作手工拷贝 DLL、需要用户大量交互以及基于 KnownDLLs 缺陷所导致的 DLL 劫持等。

2、会影响用户正常使用场景的拒绝服务攻击。包括但不限于远程应用拒绝服务攻击、组件权限导致的本地拒绝服务漏洞等。

3、其他功能缺陷。包括但不限于客户端敏感信息明文存储传输、下载恶意文件未提示及其他类似问题。

【低危】

安全扫描的绕过，即静态免杀样本，或其他危害较低的软件缺陷。

智能硬件漏洞

智能硬件产品范围：360 路由器，360 智能摄像机，360 儿童手表，360 行车记录仪等。

【严重】

无条件远程代码执行等漏洞以及未授权远程终端控制漏洞。以路由器为例：在远端 Internet 环境下，在设备未授权状态下直接与路由器 WAN 口通信，触发漏洞并获取路由器内部系统 root 权限，实现远程代码执行。

【高危】

包括但不限于有条件的远程代码执行、无条件局域网代码执行、远程设备通用密码方案破解。例如在不知道路由器管理密码的情况下，通过利用路由器 LAN 口

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

的漏洞取得 root 权限并执行任意代码。

【中危】

包括有条件局域网代码执行、远程拒绝服务（非耗光系统资源）、物理接触导致的设备通用密码方案破解等。

【低危】

包括局域网内拒绝服务（非耗光系统资源）、通过物理接触打断 uboot、物理调试接口开放等。

【忽略】

对于只可以使设备功能异常，或泄露一些配置文件（无隐私信息）的设备逻辑问题，只属于程序设计的 bug，不按漏洞进行奖励,对于有价值的反馈，会进行公开致谢。

隐私安全

隐私漏洞收录产品仅限如下列表 APP：360 手机卫士、360 账号卫士、360 手机助手、360 移动浏览器、360 儿童卫士、360 安全云盘、360 家庭防火墙、360 摄像机 APP、360 智慧生活、360 扫地机器人。

【高危】

1. 问题影响重大，与所在市场国家地区相关法律法规严重冲突；

2. 行业内罕见问题，发现方式新颖需要一定技术深度才能发现。

【中危】

1. 问题影响一般，未及时修复可能导致用户投诉、监管机构通报等影响；

2. 问题属于监管机构已经明确的检查项目，需要一般技术手段可发现。

【低危】

1. 问题影响小，未及时修复可能产生的影响不明确；
2. 一般情况下，该类问题不需要技术手段就可以发现。

威胁情报

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

威胁情报评分标准将结合实际影响、情报完整性和业务重要程度进行综合评定。具体原则如下：

1、威胁情报需包括情报具体内容、情报的数据真实性证明和情报来源等关键信息。未能主动证明真实性的情报将被忽略。各个内容是否全部包含为评分的必要条件。

2、原则上威胁情报奖励不高于对应漏洞奖励。

3、收录内容包括：服务器被入侵且提供了入侵行为特征等关键线索

4、核心业务数据库被下载，并提供数据库名或文件等关键线索；支付业务逻辑漏洞利用、业务流程绕过等关键线索；蠕虫传播、流量劫持等提供源链接、网络数据包样本等关键线索；用户身份信息大规模被窃取且提供了攻击代码等相关线索；对有针对性的秒杀、刷积分、活动刷钱套现等事件提供关键线索；360 相关钓鱼网站实际控制人员的信息提供关键线索；对泄露公司内部数据、用户数据等行为提供关键线索等。

5、质量评判：标题准确概括情报内容（加分）、情报内容准确详细（加分），数据证明清晰、逻辑完整（加分），原始情报来源可溯源（必要）。若缺乏可溯源，评价将在一定范围内降级。

漏洞收录规则-金融众测版/银行类 SRC

平安 SRC

严重

1、可获取系统权限的漏洞，包括但不限于任意代码执行、任意命令执行、SQL 注入获取核心系统权限、上传 Webshell 并可执行等；

2、严重的逻辑设计缺陷，包括但不限于账户、支付方面的安全问题，如任意账号登录、任意账号密码修改、任意账号资金消费、可带来巨大经济损失的支付问题；

3、严重级别的敏感信息泄露。包括但不限于核心 DB（资金、身份、交易相关）利用难度低的 SQL 注入，ID 连续可批量获取大量用户三种及以上敏感字段数据的接口引发的信息泄露等。（用户敏感信息字段如个人生物识别信息、个人身份信息、个人金融财产信息、个人保单信息、个人通信信息、个人位置信息、个人医疗健康信息，员工敏感信息字段如员工身份证号、员工手机号、员工薪酬相关、员工联系地址及家庭联系人）

高危

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

1、可获取系统权限的漏洞，包括但不限于任意代码执行、任意命令执行、SQL 注入获取核心系统权限、上传 Webshell 并可执行等；

2、系统严重的逻辑设计缺陷，包括但不限于账户、支付方面的安全问题，如任意账号登录、任意账号密码修改、任意账号资金消费、可带来巨大经济损失的支付问题；

3、高风险的信息泄露漏洞，包括但不限于未授权/越权能够批量获取用户、员工三种及以上敏感字段（字段名称同严重），非核心 DB 的 SQL 注入，核心功能的源代码泄露（含算法，重要业务逻辑等）

4、越权执行敏感操作，包括但不限于绕过认证直接访问管理后台可操作、重要功能处可增删改任意用户敏感信息或状态的交互越权行为等；

5、大范围影响用户的其他漏洞。包括但不仅限于可造成自动传播的重要页面的存储型 XSS 和涉及交易、资金、密码的漏洞；

6、能直接访问平安内网且可获取回显的 SSRF 漏洞；

7、访问任意系统文件的漏洞，包括但不限于任意文件包含、任意文件读取、任意文件删除等。

fcmit.cc

中危

1、普通信息泄露，包括但不限于包含服务器或数据库敏感信息的源代码压缩包下载、springboot 未授权访问敏感端点信息、访问任意 Web 文件或敏感文件的漏洞等；

2、普通的逻辑缺陷和越权，包括但不限于一般功能的未授权/越权行为和设计缺陷、域名劫持、可未授权/越权访问少量用户敏感信息、以及对经济价值影响较小的漏洞；

3、需交互才能获取用户身份信息的漏洞，包括但不限于 json hijacking、可造成严重危害的存储型 XSS；

4、弱验证机制引发的漏洞，包括但不限于帐户相关暴力破解并且可成功登录等漏洞（验证码类爆破需完整证明）；

5、能直接访问平安内网但无回显的 SSRF 漏洞；

6、重要功能的 CSRF，包括但不限于可交互修改他人密码且可登录、可结合其他类型漏洞进行利用并造成实际危害等。

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

低危

1、可被利用于钓鱼攻击的漏洞，包括但不限于 URL 重定向漏洞等；

2、轻微信息泄露：包括但不限于服务器敏感信息的日志文件下载、客户端明文存储密码、 SVN 文件泄露、LOG 文件泄露、一般配置文件、进入系统后无敏感信息或操作、包含服务器或数据库敏感信息的 demo 代码等；

3、提供 PoC 但难以利用的安全隐患。包括但不限于不能引起较大危害的存储型 XSS、反射型 XSS（包括反射型 DOM-XSS，Flash 型 XSS）、需要用户点击的 WebView 组件漏洞等；

4、无法获得数据的 SQL 注入漏洞；

5、存在越权，但利用难度较大的漏洞，包括但不限于参数无规律且无法通过其他途径获取的越权漏洞等，如需要通过手机号或姓名等越权且未提供获取途径；不涉及用户信息的越权问题等；

6、短信轰炸、邮箱轰炸（除@pingan.com.cn 外，其他域名邮箱需进一步判定）、姓名、身份证、验证接口、爆破等资源消耗类漏洞，需证明大于 30 条/分钟；

7、低风险逻辑问题，包含但不限于绕过实名提交信息、绕过认证使用默认功能等；

8、登录后台不涉及敏感内容，包含但不限于弱口令、默认口令、测试账号、未认证使用管理功能等。

无危害

1、不涉及安全问题的 BUG，包括但不限于产品功能缺陷、页面乱码、样式混编、静态文件目录遍历、应用兼容性等问题；

2、无法利用的漏洞，包括但不限于 self-xss、非敏感操作或利用条件苛刻的 CSRF、用户弱口令、无敏感信息的 json hijacking、无意义的源码泄露、内网 ip 地址/域名泄露、后台信息泄漏、路径信息泄露、TFS 信息泄露、网站路径泄露、不能解析的任意文件上传、没有实际意义的扫描器漏洞报告、无敏感信息的 svn 文件/phpinfo/logcat、无意义的 CORS 劫持漏洞等；swagger 类接口文档泄露和 Spring Actutor 非敏感端点、Jaeger UI 等不可进一步利用的漏洞。用户枚举、用户昵称、内存信息、中间件版本、jquery 版本、复杂交互的 URL 重定向等；

3、不能重现的漏洞、不涉及敏感信息的信息泄露、不能直接体现漏洞的其他问题，包括但不仅限于 PSRC 工作人员确认无法重现的漏洞、纯属用户猜测的问题、敏感信息已脱敏、脱敏的数据无法通过其他途径获取；

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

4、运营预期之内或无法造成资金损失的问题，包括但不限于使用多个账号领取小额奖励的正常业务活动；

5、 无实际意义的漏洞。包括但不限于无意义的打印，没有实际意义的扫描器漏洞报告(如：硬编码、无混淆，Activity 组件劫持、未加固/脱壳反编译、Janus 签名绕过等)、评估后无实质性危害的问题、图形验证码使用工具识别（如 OCR）、腾讯高德 API-Key 泄露；

6、实际业务需要配置的有风险的权限但是无法利用的漏洞；

7、低影响的本地 DoS 攻击；

8、无利用价值的 Crash 等；

9、需要通过爆破攻破高难度字段，如包含 6 位及以上字符的验证码、密码和认证信息等；

10、测试环境未开启登录认证，包括但不限于短信验证、密码验证、令牌认证等漏洞。

漏洞收录规则-非金融众测版

某大型平台收录标准

（1）高危漏洞

1、可获取系统设备管理员、数据库管理员权限的漏洞，包括但

不限于 RCE、Getshell 等。

2、可导致严重信息泄露的漏洞，包括但不限于 1 万条以上（含

1 万条）的多维度敏感数据（商业秘密、用户身份信息等）信息泄露。

3、发现恶意人员（非测试人员）、公开网站、黑灰产渠道、暗

网等关于上述严重恶意行为线索、痕迹或者情报的。

4、其他经内部专家判定可造成严重后果的漏洞或情报。

5、可获取系统应用、中间件管理员权限的漏洞，包括但不限于

纵向越权、敏感管理后台登录等。

6、可获得任意普通用户身份进行敏感操作的漏洞，包括横向越

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

权、任意用户登录、任意账号密码重置、任意用户删除等。

7、可进行敏感操作的漏洞，包括但不限于可篡改系统首页、任意文件读取、任意文件删除、任意文件写入等。

8、远程缓冲区溢出及其它逻辑问题导致的可获取客户端权限的漏洞。

9、可获取其他任意用户的 Cookie 或者管理员 Cookie 或者其他具有传播性的各种 XSS（需获取 Cookie 并且登录）。

6、高风险的信息泄露漏洞，包括但不限于可直接盗取用户身份信息的 SQL 注入漏洞、全站源代码泄露、大量（1000 条以上）普通信息泄露等。

10、可造成经济上损失的漏洞，各种支付绕过、涉及金钱的操作等。

11、发现恶意人员（非测试人员）、公开网站、黑灰产渠道、暗网等关于上述高危恶意行为线索、痕迹或者情报的。

12、其他经内部专家判定可造成重大后果的漏洞或情报。

（2）中危漏洞

1、需受害者交互或其他前置条件才能进一步利用的漏洞。包括但不限于包含敏感数据的 JSON 劫持、jsonp 劫持、存储型 XSS、反射型 XSS、DOM-XSS、XML 注入、一些敏感操作（如：支付、发布信息、修改敏感信息等的操作）的 CSRF。

2、能直接访问内网且但无回显的 SSRF 漏洞（需证明可以访问内网，但不得对内网服务进行扫描）。

3、普通设计缺陷，包括但不限于登录窗口可爆破(需提供成功案例)、普通用户弱口令等问题。

4、普通的影响范围有限的逻辑缺陷和越权，包括但不限于少量

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

特定页面的越权修改、越权删除、未授权访问等。

5、任意文件上传（例如上传 html 导致存储 XSS，上传文件格式

未限制等）。

6、本地任意代码执行。包括但不限于本地可利用的堆栈溢出、

UAF、本地提权、DLL 劫持等。

7、普通的信息泄露。包括但不限于数据量有限或者敏感程度有

限的源代码或系统日志等信息泄露。本地保存的敏感认证密钥信息

泄露，需能做出有效利用。

8、发现恶意人员（非测试人员）、公开网站、黑灰产渠道、暗网等关于上述中危恶意行为线索、痕迹或者情报的。

9、其他经内部专家判定可造成一般后果的漏洞或情报。

业务系统场景模拟测试带挖

先想想多看看多点击-功能探讨

业务逻辑=常规+特定系统功能

业务逻辑：**得理解系统的功能点，也就是它的业务逻辑点，才能更好的挖掘!**

一个看书软件 看一个小广告 免费看十分钟【触发条件是需要看书 10 分钟才能触发】

作为一个白帽子 挖一个看书的 APP 你会花十分钟甚至 30 分钟去看书嘛（有些小说需要付费 那就越权不付费看小说）

作为用户 你的目的就是为了不看广告

双重身份 白帽子+用户 跳过广告 看小说

大家去挖 SRC 的时候

第一身份不要是白帽子 而是作为一个用户 去深刻理解它系统的功能点

1、体验系统

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

2、找身份

3、依据不同的身份，去造成业务逻辑的破坏

招聘网站（第一个就是选择身份【用户+HR】 第二个 当前身份下的核心业务【用户：简历（编写、上传、发送）、其它用户】【HR：（注册公司 成为 HR 找个方面想过嘛）】）

核心：简历——编辑——投

1、多次投递，突破简历上限，增加曝光度：（一个人只允许选择一个职位投递投递一次）

1、单岗位 多次投递 2、多岗位 多次投递





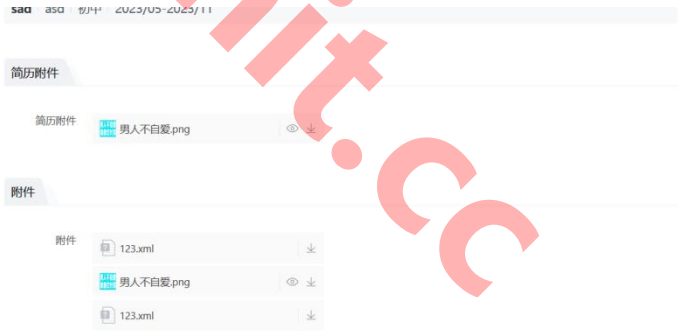
2、查看他人投递：查看所有岗位的所有简历

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc



3、编辑简历，文件上传，造成 XSS：





fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

路径寻找，提交的数据包，预览的数据包，泄露访问路径，成功导致 XSS

4、越权：越权编辑、越权保存（含有敏感数据的一定要尝试越权）

5、文件遍历：



6、简历编辑，XSS 尝试（这种简历有各种框）

常见渗透场景-渗透探讨

最容易出货的四大类

信息泄露/XSS/业务逻辑/越权

各种漏洞类型的测试思路及易出货的场景：

弱口令

漏洞原理：弱口令指用户设置的密码因过于简单（如“123456”“admin”）、使用默认密码或与用户名强相关（如用户名“test”密码“test123”），导致被暴力破解或猜测成功。该漏洞本质是认证机制的安全性缺失，攻击者可通过弱口令直接获取系统权限。

测试思路：密码爆破

易出货的场景：登录框

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc



fcmit.cc

SQL 注入

漏洞原理：用户输入未被正确过滤，导致恶意代码被解析执行

测试思路：
输入验证测试：在输入框（如搜索栏、登录表单）中插入特殊字符（单引号'、分号;、括号()），观察系统响应是否异常（如 SQL 报错、命令执行结果）。
工具辅助测试：使用 Burp Suite 的 Intruder 模块批量发送注入 Payload，或用 sqlmap 自动化检测 SQL 注入。
盲注场景测试：通过条件语句（如 IF(1=1, SLEEP(5), 1)）判断系统是否存在无回显的注入漏洞。

易出货的场景：

1、使用工具捡洞，第一节课黑熊师傅有介绍到，或使用 Xia 注
2、排序注入出货率较高，各种表单排序
3、数据包返回报错”SQL 注入语句”

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

```
    }
    .copyrighta{
      color:#000;
      text-decoration:none;
    }
  </style>
</head>
<body>
  <div class="error">
    <p class="face">
      :(
    </p>
    <h1>
      1064:You have an error in your SQL syntax; check the manual
       that corresponds to your MySQL server version for the
      right syntax to use near ''admin'' ) LIMIT 1' at line 1
      [ SQL语句 ] : SELECT * FROM `jdxy_user` WHERE (
      username='admin'' ) LIMIT 1
    </h1>
    <div class="content">
      <div class="info">
        <div class="title">
          <h3>
            错误位置
          </h3>
```

存储型跨站脚本攻击

漏洞原理：存储型 XSS 的特点是攻击 Payload 被永久存储在服务器端（如数据库、文件系统），当用户访问包含恶意代码的页面时，浏览器会自动执行 Payload。与反射型 XSS 相比，其危害更持久，影响范围更广（如针对所有访问该页面的用户）。

测试思路：

1、文件上传型（测试文件上传功能点即尝试存储型跨站脚本攻击的文件上传漏洞）
2、如果系统存在框即可尝试测试

哪些是框：

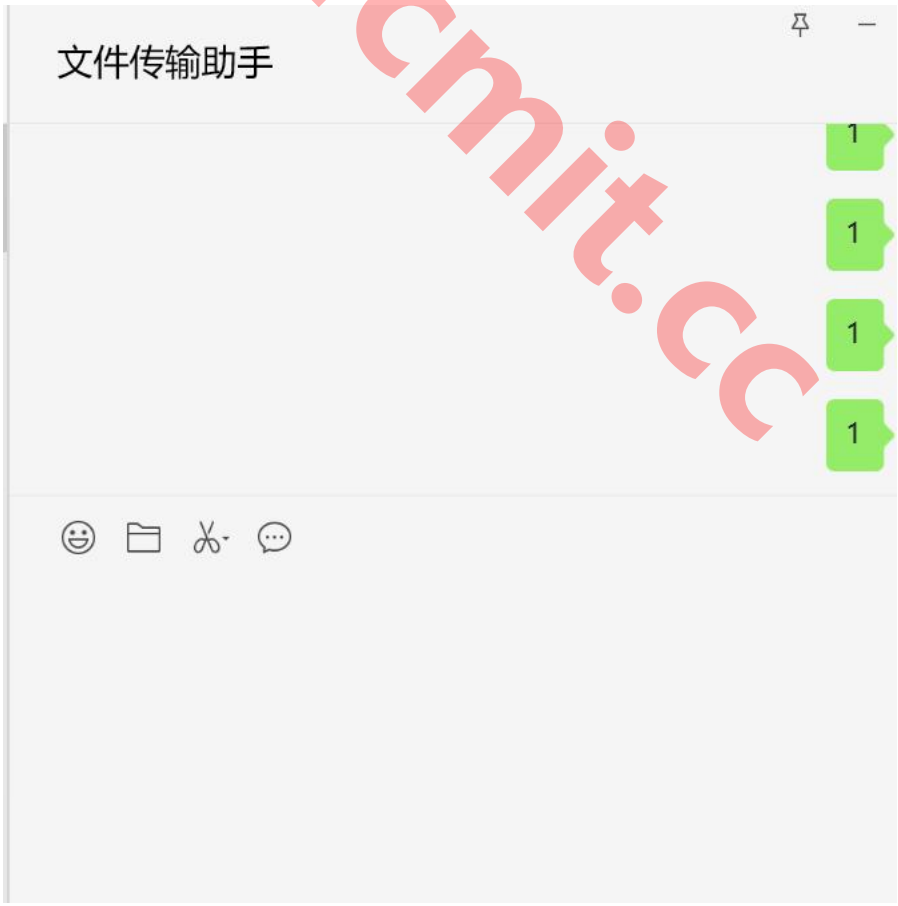
1、登录框：

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc



2、聊天框：



fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc



3、搜索框：



4、注册、意见反馈等常见的框：

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc



fcmit.cc

敏感信息泄露

挖掘敏感信息泄露的诀窍：细致+细致+细致(Hae)

任何存在用户数据交互的都不能放过

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

第一个问题：哪些地方会存在敏感信息

第一个问题：哪些是敏感信息（一般的想法：手机号码、身份证号码、住址信息）

个人身份信息：包括姓名、身份证号码等。

账号与凭证信息：例如用户名、密码（/get/1）、安全问题答案、身份验证信息等。

财务信息：包括银行账号、信用卡号码、支付宝账号等金融相关信息。（比较牵强）

医疗保健信息：涉及健康状况、病历记录、医生诊断等医疗信息。

个人通讯信息：包括电话号码、电子邮箱地址、通讯录等。

商业机密信息：如公司的商业计划、营销策略、客户数据等。

法律文件与合同：包括法律文件、合同协议、诉讼文件等。

比较常见挖掘到的敏感信息：

手机号码、账户、密码、身份证号码、银行的财务信息、内部报告、商业机密、客户资料等

第二个问题，哪些地方会存在敏感信息（存在数据交互的地方）

用户输入界面：例如登录、注册、表单提交等，存在未加密的传输、缺乏输入验证等问题。(敏感信息未脱敏 1872921011 187xxxxxxx 敏感信息 get 型传输)

数据库操作：包括对数据库的读取、写入、更新、删除等操作，未经适当的权限控制和加密存储。（增删改查-用户交互（数据库的交互））

文件存储与传输：未加密的文件存储、文件传输过程中的中间人攻击风险等。（下载文件、发送文件，1.pdf）

日志记录：系统日志中可能会记录用户的操作行为，如果未经适当处理，可能导致敏感信息泄露。（accesstoken、user、password、数据包、文件）

第三方集成：与外部系统、服务或 API 的集成，未对数据传输和存储进行充分的安全控制。（未授权，A 系统给 B 系统）地图 api 付费的接口

通讯与消息传递：包括电子邮件、即时消息等通讯方式，未加密的传输可能导致信息泄露。（聊天，与客服聊天获得他人的聊天记录 高危 3k）

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

打印与备份：未经加密的打印、备份数据，存储介质的丢失或被盗等情况。（SSRF）

系统管理员权限：拥有系统管理员权限的人员可能能够访问到系统中的敏感信息。（拥有高权限的系统 能直接访问到敏感信息 911xxxx111）（在工作中 需要对）

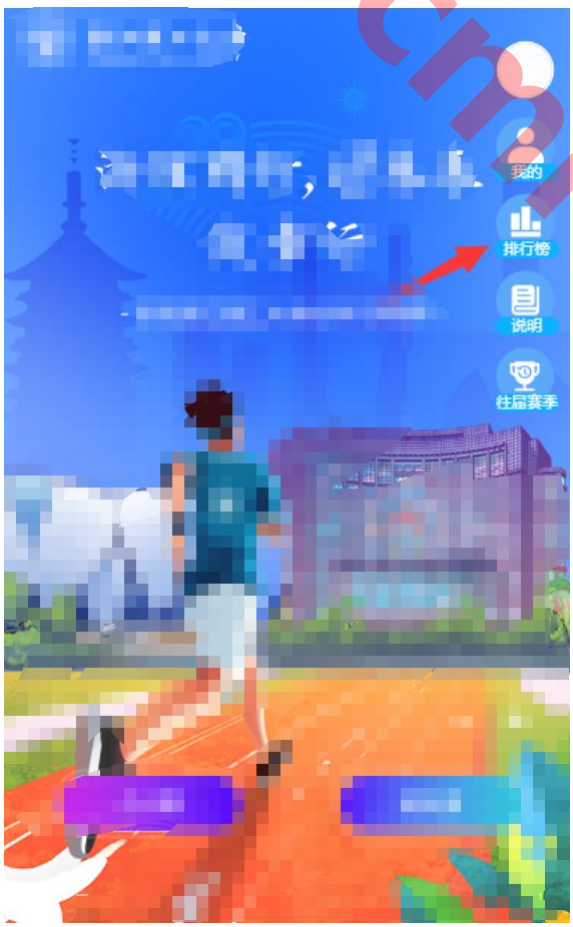
比较常见 功能点容易挖掘到敏感信息泄露

评论区、个人信息编辑、登录后的数据包需重点关注(一个一个数据包去放，若遇到可遍历的或者是说不可遍历的，repeater)、订单提交修改参数越权获得敏感信息（地址修改，userid）、点赞、回复评论等存在与其它用户交互的功能点（特征识别的参数【手机号码、身份证-不可重复、userid、wxopen_id】)Hae

多点击　多修改 多看

案例一

1、点击排行榜（增删改查的查）



2、点击详情的战队信息

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc



3、点进后，发现敏感信息泄露

fcmit.cc

安全课程：www.fcmit.cc

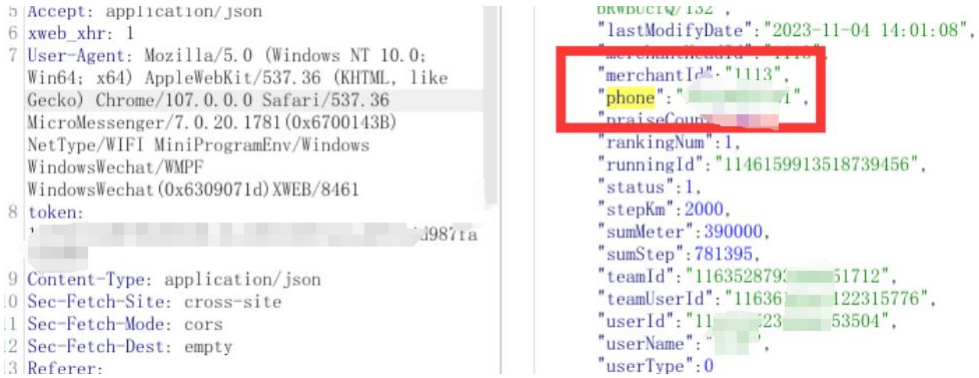
安全课程：www.fcmit.cc



手机号码等敏感数据泄露

除了手机号码还有哪些是敏感数据或者是需要去注意的

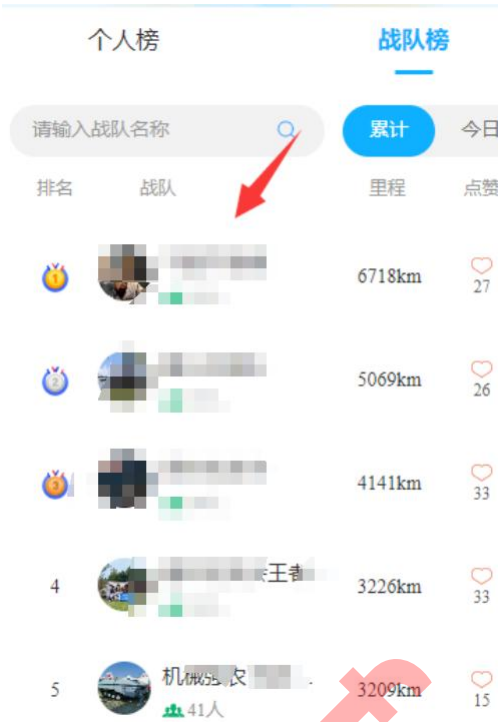
userid



扩大危害，遍历数据包，遍历得到全站战队成员的敏感信息，点击不同的战队

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc



再次扩大危害，若战队排行榜存在敏感信息泄露，那个人榜会不会存在不同 URL 可以分开交，一个漏洞多次嫖

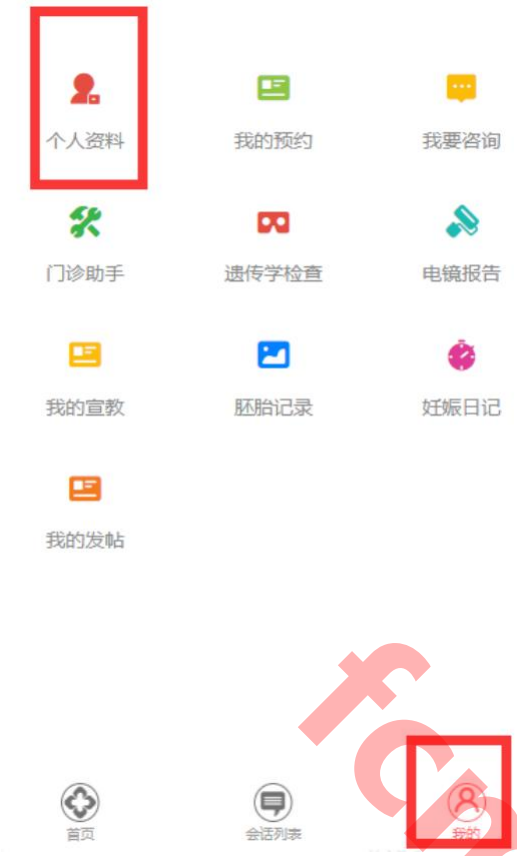
案例二

1、点击我的资料

fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc



2、查看信息



fcmit.cc

安全课程：www.fcmit.cc

安全课程：www.fcmit.cc

发现可疑 id

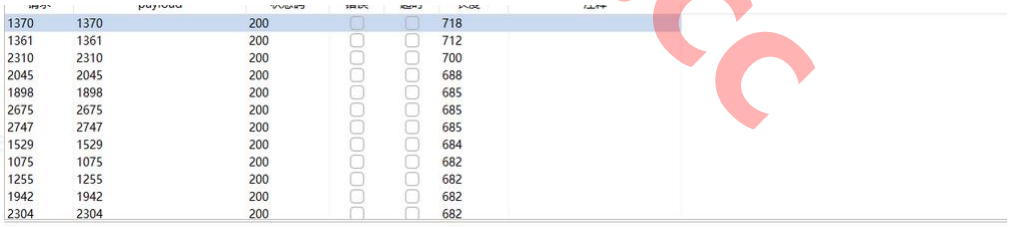
我的小程序 ID 2793

那么此前已有 2792 个用户的数据

3、查看数据包



4、遍历 id 得到其他人的敏感信息



1370	1370	200			718
1361	1361	200			712
2310	2310	200			700
2045	2045	200			688
1898	1898	200			685
2675	2675	200			685
2747	2747	200			685
1529	1529	200			684
1075	1075	200			682
1255	1255	200			682
1942	1942	200			682
2304	2304	200			682

敏感数据：身份证号码、手机号码、姓名、患者信息（病例号）、单位

fcmit.cc

安全课程：www.fcmit.cc